

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

0. Introduction

0.1 General

Almost every organization processes Personally Identifiable Information (PII). Further, the quantity and types of PII processed is increasing, as is the number of situations where an organization needs to cooperate with other organizations regarding the processing of PII. Protection of privacy in the context of the processing of PII is a societal need, as well as the topic of dedicated legislation and/or regulation all over the world.

This document includes mapping to:

- the privacy framework and principles defined in ISO/IEC 29100;
- ISO/IEC 27018;
- ISO/IEC 29151; and
- the EU General Data Protection Regulation.

NOTE These can be interpreted to take into account local legislation or regulation.

This document can be used by PII controllers (including those that are joint PII controllers) and PII processors (including those using subcontracted PII processors and those processing PII as subcontractors to PII processors).

By complying with the requirements in this document, an organization can generate evidence of how it handles the processing of PII. Such evidence can be used to facilitate agreements with business partners where the processing of PII is mutually relevant. This can also assist in relationships with other interested parties. The use of this document can provide independent verification of this evidence.

0.2 Compatibility with other management system standards

This document applies the framework developed by ISO to improve alignment among its management system standards.

This document enables an organization to align or integrate its PIMS with the requirements of other management system standards, and in particular with the information security management system specified in ISO/IEC 27001.

0. 簡介

0.1 概述

幾乎所有組織都會處理個人可識別資訊(personally identifiable information, PII)。此外，所處理的 PII 數量與類別皆持續增加，而組織在 PII 處理過程中需與其他組織合作的情況也愈發普遍。

在處理 PII 的全景下，隱私保護不僅是社會需求，也是全球各地特定法律和/或法規的關注主題。

本文件包括與下列文件之對應：

- ISO/IEC 29100 所定義之隱私框架及原則；
- ISO/IEC 27018；
- ISO/IEC 29151；以及
- 歐盟 <一般資料保護規則> (GDPR)。

備考：詮釋此等標準及規範時，可將當地的法律或法規納入考量。

本文件可供 PII 控制者(包括 PII 共同控制者)及 PII 處理者(包括委託分包的 PII 處理者的組織，以及接受 PII 處理者委託以處理 PII 的的分包商)使用。

透過遵循本文件中的要求事項，組織可以產生其處理 PII 方式的證據。當 PII 處理相互關聯時，此種證據可用以促進與營運夥伴之協議。此亦可有助於與其他利害相關者之關係。本標準之使用，可提供上述證據之獨立查證。

0.2 與其他管理系統標準之相容性

本標準適用 ISO 所制定的框架，以強化各管理系統標準間之一致性。

本標準使組織能將其 PIMS 與其他管理系統標準之要求事項保持一致或與其整合，特別是與 ISO/IEC 27001 所規定的資訊安全管理系統。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Information security, cybersecurity and privacy protection — Privacy information management systems — Requirements and guidance

1. Scope

This document specifies requirements for establishing, implementing, maintaining and continually improving a privacy information management system (PIMS).

Guidance is provided to assist in the implementation of the requirements in this document.

This document is intended for PII controllers and PII processors holding responsibility and accountability for PII processing.

This document is applicable to all types and sizes of organizations, including public and private companies, government entities and not-for-profit organizations.

2. Normative references

The following documents are referred to in the text in such a way that some or all of their content constitutes requirements of this document. For dated references, only the edition cited applies. For undated references, the latest edition of the referenced document (including any amendments) applies.

ISO/IEC 29100, Information technology — Security techniques — Privacy framework

3. Terms, definitions and abbreviations

For the purposes of this document, the terms and definitions given in ISO/IEC 29100 and the following apply.

ISO and IEC maintain terminology databases for use in standardization at the following addresses:

- ISO Online browsing platform: available at <https://www.iso.org/obp>
- IEC Electropedia: available at <http://www.electropedia.org/>

3.1 organization

person or group of people that has its own functions with responsibilities, authorities and relationships to achieve its objectives (3.6)

Note 1 to entry: The concept of organization includes, but is not limited to, sole-trader, company, corporation, firm, enterprise, authority, partnership, charity or institution, or part or combination

資訊安全、網宇安全與隱私保護 — 隱私資訊管理系統 — 要求事項與指引

1. 範圍

本標準規定於建立、實施、維持及持續改進隱私資訊管理系統 (privacy information management system, PIMS) 之要求事項。

所提供實作指引以協助實作本文件中之要求事項。

本文件旨在供對於 PII 的處理，負有責任及可歸責性的 PII 控制者及 PII 處理者之用。

本文件適用所有型式與規模的組織，包括公私立企業、政府機關與非營利組織。

2. 引用標準

下列標準因本標準所引用，成為本標準之一部分。下列引用標準適用最新版。(包括補充增修)。

ISO/IEC 29100 資訊技術 — 安全技術 — 隱私權框架

3. 用語及定義

ISO/IEC 29100

所規定之用語及定義適用於本文件。

ISO 和 IEC 標準用語資料庫維護於以下網址：

- ISO 線上瀏覽平台：<https://www.iso.org/obp>
- IEC 電子百科全書：<https://www.electropedia.org/>

3.1 組織

具有各自的功能，職責，權限和關係以實現其 目標(3.6) 的人或團體

備考 1：組織之概念，包括但不僅限於：個人商號、公司、企業、事務所、事業單位、機關、合夥組織、慈善機構或其他機構，或其一部分或組合體，不論是否具法人資格，其為公有或私有。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

thereof, whether incorporated or not, public or private.

Note 2 to entry: If the organization is part of a larger entity, the term “organization” refers only to the part of the larger entity that is within the scope of the privacy information management system (3.4).

3.2 interested party

person or organization (3.1) that can affect, be affected by, or perceive itself to be affected by a decision or activity

3.3 top management

person or group of people who directs and controls an organization (3.1) at the highest level

Note 1 to entry: Top management has the power to delegate authority and provide resources within the organization.

Note 2 to entry: If the scope of the management system (3.4) covers only part of an organization, then top management refers to those who direct and control that part of the organization.

3.4 management system

set of interrelated or interacting elements of an organization (3.1) to establish policies (3.5) and objectives (3.6), as well as processes (3.8) to achieve those objectives

Note 1 to entry: A management system can address a single discipline or several disciplines.

Note 2 to entry: The management system elements include the organization's structure, roles and responsibilities, planning and operation.

3.5 policy

intentions and direction of an organization (3.1) as formally expressed by its top management (3.3)

3.6 objective

result to be achieved

Note 1 to entry: An objective can be strategic, tactical, or operational.

Note 2 to entry: Objectives can relate to different disciplines (such as finance, health and safety, and environment). They can be, for example, organization-wide or specific to a project, product or process (3.8).

Note 3 to entry: An objective can be expressed in other ways, e.g. as

備考 2: 若組織為較大實體的一部分，則「組織」一詞僅指該較大實體中屬於 隱私資訊管理系統 (3.4) 範圍的部分。

3.2 關注方

能夠影響、受到影響，或認為自身受到某項決策或活動影響的個人或 組織(3.1)

3.3 最高管理階層

於最高層指導與控制 組織(3.1) 之個人或一群人

備考 1: 最高管理階層有權力於組織內授權及提供資源。

備考 2: 若 管理系統(3.4) 範圍僅涵蓋組織之某部分，則最高管理階層係針對指導與控制組織之該部分者。

3.4 管理系統

一組相互關聯或相互作用的 組織(3.1) 元素，以建立 政策(3.5) 和 目標(3.6)，以及實現這些目標的 流程(3.8)

備考 1: 管理系統可以因應單一領域或多個管理主題。

備考 2: 系統元素包括組織之架構、角色及責任、規劃以及運作。

3.5 政策

由 最高管理階層(3.3) 正式表達之 組織(3.1) 意圖與方向

3.6 目標

欲達成之結果

備考 1: 目標可以是策略面的、戰術面的或運作面的。

備考 2: 目標可與不同管理主題相關（如：財務、衛生安全及環境管理）。這些目標可以是組織層級的，也可以針對或特定專案、產品及 過程 (3.8) 的。

備考 3: 目標可以其他方式表達，如：預期結果、目的、營運準則，作

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

an intended result, as a purpose, as an operational criterion, as a privacy objective or by the use of other words with similar meaning (e.g. aim, goal, or target).

Note 4 to entry: In the context of privacy information management systems (3.23), privacy objectives are set by the organization (3.1), consistent with the privacy policy (3.5), to achieve specific results.

3.7 risk

effect of uncertainty

Note 1 to entry: An effect is a deviation from the expected — positive or negative.

Note 2 to entry: Uncertainty is the state, even partial, of deficiency of information related to, understanding or knowledge of, an event, its consequence, or likelihood.

Note 3 to entry: Risk is often characterized by reference to potential events and consequence or a combination of these.

Note 4 to entry: Risk is often expressed in terms of a combination of the consequences of an event (including changes in circumstances) and the associated likelihood of occurrence.

3.8 process

set of interrelated or interacting activities that uses or transforms inputs to deliver a result

Note 1 to entry: Whether the result of a process is called an output, a product or a service depends on the context of the reference.

3.9 competence

ability to apply knowledge and skills to achieve intended results

3.10 documented information

information required to be controlled and maintained by an organization (3.1) and the medium on which it is contained

Note 1 to entry: Documented information can be in any format and media and from any source.

Note 2 to entry: Documented information can refer to:

- the management system (3.4), including related processes (3.8);
- information created in order for the organization to operate (documentation);
- evidence of results achieved (records).

為隱私目標，或使用其他具有類似意義之用語（如：意旨、目標、標的）。

備考 4：於 隱私資訊管理系統(3.23) 全景中，隱私目標由 組織(3.1) 設定，與隱私 政策(3.5) 一致，以達成特定結果。

3.7 風險

不確定性的所造成的影響

備考 1：影響係與預期之偏離，可為正向或負向。

備考 2：不確定性是指對某事件、其後果或可能性之相關資訊、理解或知識的不足狀態，即使是部分不足亦屬之。

備考 3：風險通常係藉由潛在事件與後果，或兩者的組合為特徵來描述。

備考 4：風險通常以事件的結果（包括情況變化）和發生可能性的組合來表達。

3.8 過程

一組將輸入轉換為輸出的相互關聯或交互作用的活動

備考 1：根據參考的情境不同，程序的結果可稱為輸出、產品或服務。

3.9 能力

能夠應用知識及技能來實現預期結果的能力

3.10 文件化資訊

被要求由 組織(3.1) 控制與維護的資訊，以及承載此資訊的媒體

備考 1：文件化資訊，能採任何格式及媒體，且能來自任何來源。

備考 2：文件化資訊可為下列各項：

- 管理系統(3.4)，包括相關 過程(3.8)；
- 為使組織運作而創建的資訊（文件）；
- 達成結果之證據（紀錄）。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

3.11 performance

measurable result

Note 1 to entry: Performance can relate either to quantitative or qualitative findings.

Note 2 to entry: Performance can relate to managing activities, processes (3.8), products, services, systems or organizations (3.1).

3.12 continual improvement

recurring activity to enhance performance (3.11)

3.13 effectiveness

extent to which planned activities are realized and planned results are achieved

3.14 requirement

need or expectation that is stated, generally implied or obligatory

Note 1 to entry: "Generally implied" means that it is custom or common practice for the organization (3.1) and interested parties (3.2) that the need or expectation under consideration is implied.

Note 2 to entry: A specified requirement is one that is stated, e.g. in documented information (3.10).

3.15 conformity

fulfilment of a requirement (3.14)

3.16 nonconformity

non-fulfilment of a requirement (3.14)

3.17 corrective action

action to eliminate the cause(s) of a nonconformity (3.16) and to prevent recurrence

3.18 audit

systematic and independent process (3.8) for obtaining evidence and evaluating it objectively to determine the extent to which the audit criteria are fulfilled

Note 1 to entry: An audit can be an internal audit (first party) or an external audit (second party or third party), and it can be a combined audit (combining two or more disciplines).

Note 2 to entry: An internal audit is conducted by the organization (3.1) itself, or by an external party on its behalf.

3.11 績效

可量測的結果

備考 1：績效可以與定量或定性之結果相關。

備考 2：績效可以與 管理活動、過程(3.8)、產品、服務、系統或 組織(3.1) 相關。

3.12 持續改善

用以增強 績效(3.11) 之經常性活動

3.13 有效性

規劃活動所實現，及所規劃結果達成之程度

3.14 要求事項

被陳述、通常為隱含或具強制性的需求或期望

備考 1：「通常為隱含」意謂對 組織(3.1) 及 關注方(3.2) 而言，該需求或期望已經隱含於習慣或實務通行作法中。

備考 2：規定之要求事項係指已明述的要求，如：文件化資訊(3.10)。

3.15 符合事項

滿足某 要求事項(3.14)

3.16 不符合事項

未能滿足某 要求事項(3.14)

3.17 矯正措施

為消除 不符合事項(3.16) 之原因，並預防其再發生所採取的行動

3.18 稽核

系統化且獨立的 過程(3.8)，透過取得稽核證據以客觀地評估，以判定稽核準則的滿足程度

備考 1：稽核可為內部稽核（第一方稽核）或外部稽核（第二方稽核或第三方稽核），且可為合併稽核（結合兩種或更多管理主題）。

備考 2：內部稽核由 組織(3.1) 自行進行，或由外部單位代表組織執行。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Note 3 to entry: “Audit evidence” and “audit criteria” are defined in ISO 19011.

備考 3：「稽核證據」及「稽核準則」定義於 ISO 19011。

3.19 measurement

process (3.8) to determine a value

3.19 量測

判定某數值的 過程(3.8)

3.20 monitoring

determining the status of a system, a process (3.8) or an activity

3.20 監視

判定一個系統、過程(3.8) 或活動的狀態

Note 1 to entry: To determine the status, there can be a need to check, supervise or critically observe.

備考：判定狀態時，可能需要查驗、督導或批判性觀察。

3.21 joint PII controller

personally identifiable information (PII) controller that determines the purposes and means of the processing of PII jointly with one or more other PII controllers

3.21 PII 共同控制者

指與一個或多個 PII 控制者共同判定 PII 的處理的目的及方式的 PII 控制者

3.22 customer

person or organization (3.1) that could or does receive a product or a service that is intended for or required by this person or organization (3.1)

3.22 客戶

可能或確實接受一項產品或服務的個人或 組織(3.1)，且該產品或服務是為該個人或 組織(3.1)所設計或需求

EXAMPLE Consumer, client, end-user, retailer, receiver of product or service from an internal process (3.8), beneficiary and purchaser.

例如：消費者、客戶、終端用戶、零售商、來自內部 過程(3.8) 的產品或服務接收者、受益者或購買者。

Note 1 to entry: A customer can be internal or external to the organization.

備考 1：客戶可能在組織內部或外部。

Note 2 to entry: A customer can be an organization (3.1) that has a contract with a PII controller, a PII controller who has a contract with a PII processor or a PII processor that has a contract with a subcontractor for PII processing (see 4.2 for further information).

備考 2：客戶可能是與 PII 控制者有契約的 組織(3.1)、與 PII 處理者有契約的 PII 控制者，或與分包商簽訂 PII 處理契約的 PII 處理者（參照 4.2 相關內容）。

3.23 privacy information management system / PIMS

management system (3.4) which addresses the protection of privacy as potentially affected by the processing of personally identifiable information.

3.23 隱私資訊管理系統 / PIMS

一種管理系統(3.4)，用以因應因個人可識別資訊(PII)處理活動可能影響隱私所需的保護事項

3.24 information security programme

set of policies (3.5), objectives (3.6) and processes (3.8) designed to manage risks (3.7) to an organization's (3.1) assets, to ensure confidentiality, integrity and availability of information

3.24 資訊安全方案

由 政策(3.5)、目標(3.6) 及 過程(3.8) 所構成的集合，用以管理 組織(3.1) 資產的 風險(3.7)，以確保資訊的機密性、完整性與可用性

Note 1 to entry: An information security programme can be, for

備考 1：資訊安全方案可以是資訊安全管理系統，例如依據 ISO/IEC

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

example, an information security management system such as one based on ISO/IEC 27001.

27001 所建立的管理系統。

3.25 statement of applicability

documentation of all necessary controls and justification for inclusion or exclusion of controls

3.25 適用性聲明書

記錄所有必要的控制措施，及其納入或排除之理由的文件

Note 1 to entry: Organizations may not require all controls listed in Annex A or may even exceed the list in Annex A with additional controls established by the organization itself.

備考 1：組織可能不需要附錄 A 所列的所有控制措施，亦可能超出附錄 A 表列、由組織自行建立額外的控制措施。

4 Context of the organization

4 組織全景

4.1 Understanding the organization and its context

4.1 瞭解組織及其全景

The organization shall determine external and internal issues that are relevant to its purpose and that affect its ability to achieve the intended result(s) of its privacy information management system.

組織應判定與其目的有關且影響達成其隱私管理系統預期成果能力之外部及內部議題。

The organization shall determine whether climate change is a relevant issue.

組織應判定氣候變遷是否為相關議題。

The organization shall determine if it is acting as a PII controller (including as a joint PII controller) or as a PII processor.

組織應判定其角色為 PII 控制者 (包含 PII 共同控制者) 或 PII 處理者。

The organization shall determine external and internal issues that are relevant to its context and that affect its ability to achieve the intended outcome(s) of its PIMS.

組織應判定與其組織全景有關且影響達成其 PIMS 預期成果能之內部及外部議題。

NOTE 1 External and internal issues can include but are not limited to:

備考 1：內部及外部議題包括，但不限於：

- applicable privacy legislation;
- applicable regulations;
- applicable judicial decisions;
- applicable organizational context, governance, policies and procedures;
- applicable administrative decisions;
- applicable contractual requirements.

- 適用之隱私法律；
- 適用之法規；
- 適用之司法判定；
- 適用之組織全景、治理、政策與程序；
- 適用之行政決策；
- 適用之契約要求事項。

Where the organization acts in both roles (i.e. a PII controller and a PII processor), separate roles shall be determined, each of which is the subject of a separate set of controls.

當組織擔任雙重角色 (如：PII 控制者以及 PII 處理者) 時，應分別判定其角色，個別角色應分別判定其控制措施稽核。

NOTE 2 The role of the organization can be different for each instance of the processing of PII, since it depends on who determines the purposes and means of the processing.

備考 2：在每次 PII 處理活動中，組織所扮演的角色可能不同，因為角色取決於由誰判定該次處理的目的與方式。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

4.2 Understanding the needs and expectations of interested parties

The organization shall determine:

- the interested parties that are relevant to the privacy information management system;
- the relevant requirements of these interested parties;
- which of these requirements will be addressed through the privacy information management system.

NOTE 1 Relevant interested parties can have requirements related to climate change.

The organization shall include among its interested parties those parties having interests or responsibilities associated with the processing of PII, including the PII principals.

NOTE 2 Other interested parties can include customers (see 4.2), supervisory authorities, other PII controllers, PII processors and their subcontractors.

Depending on the role of the organization, "customer" can be understood as either:

- a) an organization who has a contract with a PII controller (e.g. the customer of the PII controller, the case of an organization which is a joint PII controller);

NOTE 3 An individual person in a business to consumer relationship with an organization is referred to as a "PII principal" in this document.

- b) a PII controller who has a contract with a PII processor (e.g. the customer of the PII processor); or
- c) a PII processor who has a contract with a subcontractor for PII processing (e.g. the customer of the subcontracted PII processor).

NOTE 4 Requirements relevant to the processing of PII can be determined by legal and regulatory requirements, by contractual obligations and by self-imposed organizational objectives. The privacy

4.2 瞭解關注方之需要及期望

組織應判定下列事項：

- 與 PIMS 有關之關注各方；
- 此等關注方之相關要求事項；
- 其此等要求事項中之哪些要求事項，將透過隱私資訊管理系統因應。

備考 1：有關之關注各方可提出與氣候變遷相關之要求。

組織應將所有對 PII 的處理，存在利害關係或承擔責任的各方，均納入關注方之列，包括 PII 當事人。

備考 2：其他關注方可能包括客戶（參照 4.2）、主管機關、其他 PII 控制者、PII 處理者及其分包者。

依組織之角色，「客戶」可理解為以下之一：

- a) 組織，其與 PII 控制者具有契約關係（如：PII 控制者的客戶，或作為 PII 共同控制者的組織）；

備考 3：與組織具企業對客戶關係之個人，於本文件中稱為「PII 當事人」。

- b) PII 控制者，其與 PII 處理者具有契約關係（如：PII 處理者之客戶）；或
- c) PII 處理者，其與進行 PII 處理的分包商具契約關係（如：該分包 PII 處理者的客戶）。

備考 4：與 PII 處理有關的要求事項可由法律與法規要求事項、契約義務及自我施加之組織目標判定。ISO/IEC 29100 中所闡述之隱私原則可作為 PII 處理的指引。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

principles set out in ISO/IEC 29100 provide guidance concerning the processing of PII.

NOTE 5 As an element to demonstrate compliance to the organization's obligations, some interested parties can expect that the organization is in conformity with specific standards, such as the management system specified in this document, or any relevant set of specifications. These parties can call for independently audited compliance to these standards.

NOTE 6 To demonstrate conformity with the organization's obligations, some interested parties can expect that the organization is in conformity with specific standards, such as the management system specified in this document or any relevant set of specifications. These parties can call for independently audited conformity to these standards.

4.3 Determining the scope of the privacy information management system

The organization shall determine the boundaries and applicability of the privacy information management system to establish its scope.

When determining this scope, the organization shall consider:

- the external and internal issues referred to in 4.1;
- the requirements referred to in 4.2.

The scope of the organization's privacy information management system shall be available and be maintained as documented information.

When determining the scope of the PIMS, the organization shall include the processing of PII.

4.4 Privacy information management system

The organization shall establish, implement, maintain and continually improve a privacy information management system, including the processes needed and their interactions, in accordance with the requirements of this document.

5 Leadership

5.1 Leadership and commitment

Top management shall demonstrate leadership and commitment with respect to the privacy information management system by:

- a) ensuring that the privacy policy (see 5.2) and privacy objectives (see 6.2) are established and

備考 5：作為展現組織義務遵循性的要素之一，部分關注方會期望組織符合特定標準，如本文件中指定的管理系統，或任何相關標準的集合。這些關注方可能要求組織通過獨立稽核，以證明其符合該等標準。

備考 6：為證明組織符合其義務，部分關注方會期望組織符合特定標準，如本文件中指定的管理系統，或任何相關標準的集合。這些關注方可能要求組織通過獨立稽核，以證明其符合該等標準。

4.3 判定隱私資訊管理系統範圍

組織應判定 PIMS 之邊界及適用性，以建立其範圍。

於判定範圍時，組織應考量下列事項：

- 4.1 中所提及之外部及內部議題；
- 4.2 中所提及之要求事項。

組織之 PIMS 範圍應以文件化資訊，為可取得且予以維持。

判定 PIMS 之範圍時，組織應將 PII 之處理納入。

4.4 隱私資訊管理系統

組織應依據本文件之要求事項，建立、實作、維持及持續改善隱私安全管理系統，包括其必要流程及其相互作用。

5 領導作為

5.1 領導及承諾

最高管理階層應藉由下列事項，展現對 PIMS 之領導及承諾：

- a) 確保已建立隱私政策 (參照5.2) 及隱私目標 (參照 6.2)，並與組織之策略方向相容；

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

are compatible with the strategic direction of the organization;

- | | |
|--|--|
| b) ensuring the integration of the privacy information management system requirements into the organization's business processes; | b) 確保 PIMS 要求事項整合入組織之各項營運過程； |
| c) ensuring that the resources needed for the privacy information management system are available; | c) 確保 PIMS 所需之資源可取得； |
| d) communicating the importance of effective privacy information management and of conforming to the privacy information management system requirements; | d) 傳達有效之隱私資訊管理的重要性，以及符合 PIMS 要求事項之重要性； |
| e) ensuring that the privacy information management system achieves its intended result(s); | e) 確保 PIMS 達成其預期成果； |
| f) directing and supporting persons to contribute to the effectiveness of the privacy information management system; | f) 指導及支援人員，以促進 PIMS 之有效性； |
| g) promoting continual improvement; | g) 推動持續改善； |
| h) supporting other relevant roles to demonstrate their leadership as it applies to their areas of responsibility. | h) 當適用其他相關角色之責任範圍時，加以支持以展現其領導權。 |

NOTE Reference to "business" in this document can be interpreted broadly to mean those activities that are core to the purposes of the organization's existence.

備考：本文件所提及之「營運」，能廣義詮釋為對組織存在目的具核心意義之該等活動。

5.2 Privacy Policy

Top management shall establish a privacy policy that:

- a) is appropriate to the purpose of the organization;
- b) provides a framework for setting privacy objectives;
- c) includes a commitment to meet applicable requirements;
- d) includes a commitment to continual improvement of the privacy information management system.

The privacy policy shall:

- be available as documented information;
- be communicated within the organization;
- be available to interested parties, as appropriate.

5.3 Roles, responsibilities and authorities

Top management shall ensure that the responsibilities and authorities for relevant roles are assigned and communicated within the organization.

Top management shall assign the responsibility and

5.2 隱私政策

最高管理階層應建立包括下列事項之隱私政策：

- a) 適合於組織之目的；
- b) 提供設定隱私目標之框架；
- c) 包括對符合相關適用要求事項的承諾；
- d) 包括對持續改善 PIMS 之承諾。

隱私政策應符合下列項目：

- 以文件化資訊而為可取得；
- 於組織內傳達；
- 適切時，關注方可取得。

5.3 角色、責任及權限

最高管理階層應確保相關角色之責任及權限已於組織內指派並傳達。

最高管理階層應指派下列責任及權限：

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

authority for:

- a) ensuring that the privacy information management system conforms to the requirements of this document;
- b) reporting on the performance of the privacy information management system to top management.
- a) 確保 PIMS 符合本文件之要求事項；
- b) 向最高管理階層報告 PIMS 之績效。

6 Planning

6.1 Actions to address risks and opportunities

6.1.1 General

When planning for the privacy information management system, the organization shall consider the issues referred to in 4.1 and the requirements referred to in 4.2 and determine the risks and opportunities that need to be addressed to:

- give assurance that the privacy information management system can achieve its intended result(s);
- prevent, or reduce undesired effects;
- achieve continual improvement.

The organization shall plan:

- a) actions to address these risks and opportunities;
- b) how to
 - integrate and implement the actions into its privacy information management system processes;
 - evaluate the effectiveness of these actions.

6.1.2 Privacy risk assessment

The organization shall define and apply a privacy risk assessment process that:

- a) establishes and maintains privacy risk criteria that include:
 - 1) the risk acceptance criteria; and
 - 2) criteria for performing privacy risk assessments;
- b) ensures that repeated privacy risk assessments produce consistent, valid and comparable results;
- c) identifies the privacy risks:
 - 1) associated with the protection of privacy and information security risks within the scope of the privacy information management system; and
 - 2) that identify the risk owners;

6 規劃

6.1 因應風險及機會之行動

6.1.1 一般要求

於規劃 PIMS 時，組織應考量 4.1 所提及之議題及 4.2 所提及的要求事項，並判定需因應之風險及機會，以達成下列事項：

- 為 PIMS 能達成其預期成果提供保證；
- 預防或減少非所欲之影響；
- 達成持續改善。

組織應規劃下列事項：

- a) 因應此等風險及機會之行動；
- b) 執行下列事項之方法
 - 將各項行動整合及實作於其 PIMS 過程中；
 - 評估此等行動之有效性。

6.1.2 隱私風險評鑑

組織應定義及應用隱私風險評鑑過程於下列事項中：

- a) 建立及維持包括下列準則之隱私風險準則：
 - 1) 風險接受準則；及
 - 2) 執行隱私風險評鑑之準則；
- b) 確保重複之隱私風險評鑑產生一致、有效及可比較的結果；
- c) 識別隱私風險：
 - 1) 其於 PIMS 範圍內，且與隱私之保護及資訊安全風險相關者；及
 - 2) 識別該風險擁有者；

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

- d) analyses the privacy risks that:
- 1) assess the potential consequences for both the organization and PII principals that would result if the risks identified in 6.1.2 c) 1) were to materialize;
 - 2) assess the realistic likelihood of the occurrence of the risks identified in 6.1.2 c) 1); and
 - 3) determine the levels of risk;
- e) evaluates the privacy risks that:
- 1) compare the results of risk analysis with the risk criteria established in 6.1.2 a); and
 - 2) prioritize the analysed risks for risk treatment.

The organization shall retain documented information about the privacy risk assessment process.

NOTE For further information on the privacy risk assessment process, see ISO/IEC 27557.

6.1.3 Privacy risk treatment

The organization shall define and apply a privacy risk treatment process to treat risks related to the processing of PII, including risks to PII principals, and including the security of PII, by:

- a) selecting appropriate privacy risk treatment options, taking account of the risk assessment results;
- b) determining all controls that are necessary to implement the privacy risk treatment option(s) chosen;

NOTE 1 Organizations can design controls as required, or identify them from any source.

- c) identifying and documenting the information security programme implemented by the organization, including the appropriate security controls;
- The information security programme at a minimum should address the following:
- information security risk management;
 - policies for information security;
 - organization of information security;
 - human resources security;

- d) 分析隱私風險。
- 1) 評鑑若 6.1.2 c) 1) 中所識別之風險實際發生時，對組織及 PII 當事人可能導致之潛在後果；
 - 2) 評鑑 6.1.2 c) 1) 中所識別之風險發生的實際可能性；及
 - 3) 判定風險的等級；
- e) 評估隱私風險：
- 1) 以 6.1.2 a) 中所建立之風險準則，比較風險分析結果；及
 - 2) 訂定已分析風險之風險處理優先序。

組織應保存關於隱私風險評鑑過程之文件化資訊。

備考：關於隱私風險評鑑過程之更多資訊，參照 ISO/IEC 27557。

6.1.3 隱私風險處理

組織應定義並應用隱私風險處理過程，以處理 PII 處理的相關風險，包括對 PII 當事人的風險，以及 PII 安全的風險，透過：

- a) 考量風險評鑑結果，選擇適切之隱私風險處理選項；
- b) 對所選定隱私風險處理選項，判定所有必須實作之控制措施；

備考 1：組織可依要求設計控制措施，或由任何來源識別之。

- c) 識別並記錄組織所實施的資訊安全方案，包括適當的安全控制措施；

資訊安全方案最少宜闡明下列：

- 資訊安全風險管理；
- 資訊安全政策；
- 資訊安全組織；
- 人力資源安全；

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

- asset management;
- access control;
- operations security;
- network security management;
- development security;
- supplier management;
- incident management;
- information security continuity;
- information security reviews;
- cryptography; and
- physical and environmental security.

- 資產管理；
- 存取控制；
- 運作安全；
- 網路安全管理；
- 開發安全；
- 供應商管理；
- 事故管理；
- 資訊安全持續；
- 資訊安全審查；
- 密碼學；及
- 實體與環境安全。

NOTE 2 ISO/IEC 27002 provides a list of possible information security controls. If the information security programme is based on ISO/IEC 27001, users of this document are directed to ISO/IEC 27002 to ensure that no necessary information security controls are overlooked.

備考 2：ISO/IEC 27002 提供資訊安全控制措施的可能清單。若資訊安全計畫是基於 ISO/IEC 27001，本文件的使用者可參照 ISO/IEC 27002 以確保未忽略必要之控制措施。

- d) comparing the controls determined in 6.1.3 b) above with those in Annex A and verifying that no necessary controls have been omitted;

- d) 比較上述 6.1.3 b) 中所判定之控制措施與附錄 A 中者，並查證未忽略必要的控制措施。

NOTE 3 Annex A contains a list of possible privacy controls. Users of this document are directed to Annex A to ensure that no necessary privacy controls are overlooked.

備考 3：附錄 A 包含隱私控制措施的可能清單。本文件之使用者參照附錄 A，以確保未忽略必要的隱私控制措施。

NOTE 4 The privacy controls listed in Annex A are not exhaustive and additional privacy controls can be included if needed.

備考 4：附錄 A 所列隱私控制措施非詳盡窮舉，需要時可納入額外之控制措施。

NOTE 5 Organizations can address security and privacy in an integrated manner when considering the security of PII processing, combining security and privacy risk assessments for example, or as separate entities with overlapping areas.

備考 5：組織在考量 PII 處理之安全時，可以整合方式同時因應安全與隱私，例如結合安全與隱私風險評鑑，或視為獨立管理主題個別處理。

- e) producing a statement of applicability that includes:
- the necessary controls [see 6.1.3 b), c) and d)];
 - justification for their inclusion;
 - whether the necessary controls are implemented or not; and
 - the justification for excluding any of the controls from Annex A.

- e) 產生適用性聲明，包含下列各項：
- 必要之控制措施 [參照 6.1.3 b)、c) 及 d)];
 - 納入之衡量理由；
 - 是否實作必要之控制措施；及
 - 排除任何附錄 A 控制措施之衡量理由。

It is not necessary to include all controls listed in Annex A. For example, controls can be excluded if they are not deemed necessary by the risk assessment or are not

附錄 A 所列之控制措施並非需全數納入。舉例而言，經風險評鑑認定其並非必要，或未涵蓋於適用的法律要求事項（或屬於法律要求事項的例外情形時），包括適用於

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

covered by (or are subject to exceptions under) the applicable legal requirements, including those applicable to the PII principal.

- f) formulating a privacy risk treatment plan;
- g) obtaining the privacy risk owners' approval of the privacy risk treatment plan and acceptance of the residual privacy risks; and
- h) considering the guidance in Annex B for the implementation of controls determined in b) and c).

The organization shall retain documented information about the information privacy risk treatment process.

6.2 Privacy objectives and planning to achieve them

The organization shall establish privacy objectives at relevant functions and levels.

The privacy objectives shall:

- a) be consistent with the privacy policy (see 5.2);
- b) be measurable (if practicable);
- c) take into account applicable requirements;
- d) be monitored;
- e) be communicated;
- f) be updated as appropriate;
- g) be available as documented information.

When planning how to achieve its privacy objectives, the organization shall determine:

- what will be done;
- what resources will be required;
- who will be responsible;
- when it will be completed;
- how the results will be evaluated.

6.3 Planning of changes

When the organization determines the need for changes to the privacy information management system, the changes shall be carried out in a planned manner.

7 Support

7.1 Resources

The organization shall determine and provide the

PII 當事人的要求，即可以排除這些控制措。

- f) 制訂隱私風險處理計畫；
- g) 取得風險擁有者對隱私風險處理計畫之核准，以及對剩餘隱私風險的接受；及
- h) 考量附錄B中的指引，以實作 b) 和 c)中判定的控制措施。

組織應保存關於隱私與隱私風險評鑑過程之文件化資訊。

6.2 隱私目標及其達成之規劃

組織應於各相關部門及層級建立隱私目標。

隱私目標應滿足下列事項：

- a) 與隱私政策一致（參照5.2）；
- b) 可量測的（若可行）；
- c) 考量適用之要求事項；
- d) 被監視；
- e) 被傳達；
- f) 於適切時更新之；
- g) 以文件化資訊而為可取得。

於規劃如何達成隱私目標時，組織應判定下列事項

- 待辦事項；
- 所要求資源；
- 負責人員；
- 完成時間；及
- 結果之評估方式。

6.3 變更之規劃

當組織判定需要對 PIMS 變更時，應以規劃之方式執行變更。

7 支援

7.1 資源

組織應判定並提供建立、實作、維持及持續改善 PIMS

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

resources needed for the establishment, implementation, maintenance and continual improvement of the privacy information management system.

所需之資源。

7.2 Competence

The organization shall:

- determine the necessary competence of person(s) doing work under its control that affects its privacy information management performance;
- ensure that these persons are competent on the basis of appropriate education, training, or experience;
- where applicable, take actions to acquire the necessary competence, and evaluate the effectiveness of the actions taken.

7.2 能力

組織應採取下列措施：

- 判定於組織控制下執行工作，影響其隱私資訊管理績效人員之必要能力；
- 確保此等人員於適切教育、訓練或經驗之基礎上能勝任；
- 於適當時，採取行動取得必要能力，並評估所採取行動之有效性。

Appropriate documented information shall be available as evidence of competence.

具備適切之文件化資訊，作為勝任之證據。

NOTE Applicable actions can include, for example: the provision of training to, the mentoring of, or the re assignment of currently employed persons; or the hiring or contracting of competent persons.

備考：適用之行動可能包括，例如：對現有人員提供訓練、指導或重新指派，或是雇用或約用勝任人員。

7.3 Awareness

Persons doing work under the organization's control shall be aware of:

- the privacy policy (see 5.2);
- their contribution to the effectiveness of the privacy information management system, including the benefits of improved privacy performance;
- the implications of not conforming with the privacy information management system requirements.

7.3 認知

於組織制管下，執行工作之人員應認知下列事項：

- 隱私政策 (參照 5.2)；
- 其對 PIMS 有效性之貢獻，包括改善的隱私績效之益處；
- 未遵循 PIMS 要求事項之可能後果。

7.4 Communication

The organization shall determine the internal and external communications relevant to the privacy information management system including:

- on what it will communicate;
- when to communicate;
- with whom to communicate;
- how to communicate.

7.4 溝通或傳達

組織應判定，相關於 PIMS 之內部及外部溝通或傳達的需要，包括下列事項：

- 溝通或傳達事項；
- 溝通或傳達時間；
- 溝通或傳達對象；
- 溝通或傳達方式。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

7.5 Documented information

7.5.1 General

The organization's privacy information management system shall include:

- a) documented information required by this document;
- b) documented information determined by the organization as being necessary for the effectiveness of the privacy information management system.

NOTE The extent of documented information for a privacy information management system can differ from one organization to another due to:

- the size of organization and its type of activities, processes, products and services;
- the complexity of processes and their interactions;
- the competence of persons.

7.5.2 Creating and updating documented information

When creating and updating documented information, the organization shall ensure appropriate:

- identification and description (e.g. a title, date, author, or reference number);
- format (e.g. language, software version, graphics) and media (e.g. paper, electronic);
- review and approval for suitability and adequacy.

7.5.3 Control of documented information

Documented information required by the privacy information management system and by this document shall be controlled to ensure:

- a) it is available and suitable for use, where and when it is needed;
- b) it is adequately protected (e.g. from loss of confidentiality, improper use, or loss of integrity).

For the control of documented information, the organization shall address the following activities, as applicable:

- distribution, access, retrieval and use;
- storage and preservation, including preservation of legibility;
- control of changes (e.g. version control);

7.5 文件化資訊

7.5.1 一般要求

組織之 PIMS 應包括下列內容：

- a) 本文件要求之文件化資訊；
- b) 由組織所判定對 PIMS 有效性，必要之文件化資訊。

備考：各組織之 PIMS 文件化資訊程度，可能因下列因素而異：

- 組織的規模，及其活動、過程、產品與服務的型式；
- 各過程及其互動之複雜度；
- 人員之能力。

7.5.2 制訂及更新

於制訂及更新文件化資訊時，組織應確保適切之下列項目：

- 識別及描述（如：標題、日期、作者、或參引號碼）；
- 格式（如：語言、軟體版本、圖形）及媒體（如：紙本、電子）；
- 合宜性及適切性之審查及核可。

7.5.3 文件化資訊之控制

應控制 PIMS 及本文件要求之文件化資訊，以確保下列事項：

- a) 其於需要處及需要時為可用及適用；及
- b) 其受適切保護（如：防止喪失機密性、不當使用或喪失完整性）。

為控制文件化資訊，組織應於適用時，闡明下列活動：

- 派送、存取、檢索及使用；
- 儲存及保存，包括可讀性之保存；
- 變更之控制（如：版本控制）；

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

— retention and disposition.

Documented information of external origin determined by the organization to be necessary for the planning and operation of the privacy information management system shall be identified as appropriate and controlled.

NOTE Access can imply a decision regarding the permission to view the documented information only, or the permission and authority to view and change the documented information.

8 Operation

8.1 Operational planning and control

The organization shall plan, implement and control the processes needed to meet requirements, and to implement the actions determined in Clause 6, by:

- establishing criteria for the processes;
- implementing control of the processes in accordance with the criteria.

Documented information shall be available to the extent necessary to have confidence that the processes have been carried out as planned.

The organization shall control planned changes and review the consequences of unintended changes, taking action to mitigate any adverse effects, as necessary.

The organization shall ensure that externally provided processes, products or services that are relevant to the privacy information management system are controlled.

8.2 Privacy risk assessment

The organization shall perform privacy risk assessments at planned intervals or when significant changes are proposed or occur, taking account of the criteria established in 6.1.2 a).

The organization shall retain documented information of the results of the privacy risk assessments.

8.3 Privacy risk treatment

The organization shall implement the privacy risk treatment plan.

The organization shall retain documented information of the results of the privacy risk treatment.

— 留存及屆期處置。

於適切時，應識別及控制由組織所判定對 PIMS 之規劃及運作為必要之外部來源的文件化資訊。

備考：存取隱含一項關於許可的決定，例如：僅獲准檢視文件化資訊，或同時具有檢視與變更該資訊的許可與權限。

8 運作

8.1 運作之規劃及控制

組織應規劃、實作及控制符合要求事項所需之流程，並實作第 6 節中所判定之行動，以：

- 為流程建立準則；
- 依準則實作過程之控制措施。

應具備文件化資訊，其程度必須具有足以達成其流程已依規劃執行之信心。

組織應控制所規劃之變更，並審查非預期變更之後果，必要時採取行動以減輕任何負面效果。

組織應確保與 PIMS 相關的外部所提供之流程、產品或服務受到控制。

8.2 隱私風險評鑑

組織應依規劃之期間，或當提議或發生重大變更時，考量 6.1.2 a) 所建立之準則，執行隱私風險評鑑。

組織應保存隱私風險評鑑結果之文件化資訊。

8.3 隱私風險處理

組織應實作隱私風險處理計畫。

組織應保存隱私風險處理結果之文件化資訊。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

9 Performance evaluation

9.1 Monitoring, measurement, analysis and evaluation

The organization shall determine:

- what needs to be monitored and measured;
- the methods for monitoring, measurement, analysis and evaluation, as applicable, to ensure valid results;
- when the monitoring and measuring shall be performed;
- when the results from monitoring and measurement shall be analysed and evaluated.

Documented information shall be available as evidence of the results.

The organization shall evaluate the privacy performance and the effectiveness of the privacy information management system.

9.2 Internal audit

9.2.1 General

The organization shall conduct internal audits at planned intervals to provide information on whether the privacy information management system:

- a) conforms to:
 - the organization's own requirements for its privacy information management system;
 - the requirements of this document;
- b) is effectively implemented and maintained.

9.2.2 Internal audit programme

The organization shall plan, establish, implement and maintain (an) audit programme(s), including the frequency, methods, responsibilities, planning requirements and reporting.

When establishing the internal audit programme(s), the organization shall consider the importance of the processes concerned and the results of previous audits.

The organization shall:

- a) define the audit objectives, criteria and scope for each audit;
- b) select auditors and conduct audits to ensure objectivity and the impartiality of the audit process;
- c) ensure that the results of audits are reported to relevant managers.

Documented information shall be available as evidence

9 績效評估

9.1 監督、量測、分析及評估

組織應判定下列事項：

- 需要監督及量測之事項；
- 監督、量測、分析及評估之適用方法，以確保有效的結果；
- 執行監督及量測之時間；
- 監督及量測結果應分析及評估之時間；

應具備文件化資訊作為其結果之證據。

組織應保存適切之文件化資訊，作為監督及量測結果的證據。

9.2 內部稽核

9.2.1 一般要求

組織應依規劃之期間施行內部稽核，以提供 PIMS 之下列資訊：

- a) 是否遵循下列事項
 - 組織本身對其 PIMS 之要求事項；
 - 本文件之要求事項；
- b) 是否有效實作及維持。

9.2.2 內部稽核計畫

組織應規劃、建立、實作及維持稽核計畫，包括頻率、方法、責任、規劃要求事項與報告。

於建立內部稽核計畫時，組織應考量所關切過程之重要性及先前稽核的結果。

組織應：

- a) 定義各稽核之稽核目標、稽核準則及稽核範圍；
- b) 選擇稽核員及施行稽核，以確保稽核過程之客觀性及公平性；
- c) 確保稽核之結果對相關管理階層報告。

應具備文件化資訊作為稽核計畫實作，及稽核結果之證

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

of the implementation of the audit programme(s) and the audit results.

據。

9.3 Management review

9.3.1 General

Top management shall review the organization's privacy information management system, at planned intervals, to ensure its continuing suitability, adequacy and effectiveness.

9.3 管理審查

9.3.1 一般要求

最高管理階層應於規劃之期間，審查組織之 PIMS，以確保其持續的合宜性、適切性及有效性。

9.3.2 Management review inputs

The management review shall include:

- a) the status of actions from previous management reviews;
- b) changes in external and internal issues that are relevant to the privacy information management system;
- c) changes in needs and expectations of interested parties that are relevant to the privacy information management system;
- d) information on the privacy information management system performance, including trends in:
 - nonconformities and corrective actions;
 - monitoring and measurement results;
 - audit results;
- e) opportunities for continual improvement.

9.3.2 管理審查輸入

管理審查應包括對下列事項之考量：

- a) 過往管理審查之議案的處理狀態；
- b) 與 PIMS 有關之內部及外部議題的變更；
- c) 與 PIMS 相關關注方需要及期望的變更；
- d) PIMS 績效之資訊，包括下列之趨勢：
 - 不符合事項及矯正措施；
 - 監督及量測結果；
 - 稽核結果；
- e) 持續改善之機會。

9.3.3 Management review results

The results of the management review shall include decisions related to continual improvement opportunities and any need for changes to the privacy information management system.

Documented information shall be available as evidence of the results of management reviews.

9.3.3 管理審查結果

管理審查之結果應包括與持續改善機會有關之決策，以及任何對 PIMS 變更之需要。

應具備文件化資訊作為管理審查結果之證據。

10 Improvement

10.1 Continual improvement

The organization shall continually improve the suitability, adequacy and effectiveness of the privacy information management system.

10 改善

10.1 持續改善

組織應持續改善 PIMS 的合宜性、適切性及有效性。

10.2 Nonconformity and corrective action

When a nonconformity occurs, the organization shall:

- a) react to the nonconformity, and as applicable:

10.2 不符合事項及矯正措施

不符合事項發生時，組織應有下列作為：

- a) 對不符合事項反應，並於適用時，採取下列作為：

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

- take action to control and correct it;
- deal with the consequences;
- b) evaluate the need for action to eliminate the cause(s) of the nonconformity, in order that it does not recur or occur elsewhere, by:
 - reviewing the nonconformity;
 - determining the causes of the nonconformity;
 - determining if similar nonconformities exist, or can potentially occur;
- c) implement any action needed;
- d) review the effectiveness of any corrective action taken;
- e) make changes to the privacy information management system, if necessary.

Corrective actions shall be appropriate to the effects of the nonconformities encountered.

Documented information shall be available as evidence of:

- the nature of the nonconformities and any subsequent actions taken;
- the results of any corrective action.

11 Further information on Annexes

Annex C contains a mapping to ISO/IEC 29100.

Annex D contains a mapping of the controls in this document to the European Union General Data Protection Regulation.

Annex E contains a mapping to ISO/IEC 27018 and ISO/IEC 29151.

Annex F shows the correspondence between the controls in this edition of ISO/IEC 27701 and the previous 2019 edition.

- 採取行動，以控制並矯正之；
- 處理其後果；
- b) 藉由下列作為，評估對消除不符合事項之原因的行動之需要，使其不再發生且不於他處發生：
 - 審查不符合事項；
 - 判定不符合事項之原因；
 - 判定是否有類似之不符合事項存在，或可能發生；
- c) 實作所有所需行動；
- d) 審查所有所採取矯正措施之有效性；
- e) 必要時，對 PIMS 進行變更。

矯正措施應切合所遇到之不符合事項之影響。

應具備文件化資訊，以作為下列事項之證據：

- 不符合事項之本質及後續採取的所有行動；
- 所有矯正措施之結果。

11 附錄之額外資訊

附錄 C 包含與 ISO/IEC 29100 之對應。

附錄 D 包含本文件中之控制措施與歐盟一般資料保護規則 (GDPR) 之對應。

附錄 E 包含與 ISO/IEC 27018 及 ISO/IEC 29151 之對應。

附錄 F 說明本版 ISO/IEC 27701 與前一版 (2019 年版) 控制措施之間的對應關係。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Annex A (normative)

PIMS reference control objectives and controls for PII Controllers and PII Processors

This annex is intended to be used by organizations acting as PII controllers or PII processors, or both.

Not all the control objectives and controls listed in this annex need to be included in the PIMS implementation. A justification for excluding any control objectives shall be included in the statement of applicability [see 6.1.3 e)]. Justification for exclusion can include where the controls are not deemed necessary by the risk assessment, and where they are not required by (or are subject to exceptions under) the applicable legal requirements.

Table A.1 is for PII controllers, Table A.2 is for PII processors and Table A.3 relates to security controls for both PII controllers and PII processors.

NOTE The references under 'Control reference' in tables A.1, A.2 and A.3 refer to the equivalent clause numbers in Annex B (e.g. guidance for control A.1.2.2 can be found in B.1.2.2).

Table A.1 — Control objectives and controls for PII controllers

Conditions for collection and processing Objective

To demonstrate that processing is lawful, with legal basis as per applicable jurisdictions, with clearly defined and legitimate purposes.

A.1.2.2 Identify and document purpose

The organization shall identify and document the specific purposes for which the PII will be processed.

A.1.2.3 Identify lawful basis

The organization shall determine, document and be able to demonstrate compliance with the relevant lawful basis for the processing of PII for the identified purposes.

A.1.2.4 Determine when and how consent is to be

附錄 A (規定)

適用於 PII 控制者及 PII 處理者之 PIMS 參考控制目標與控制措施

本附錄旨在供作為 PII 控制者或 PII 處理者，或兼具兩者角色之組織使用。

PIMS 實作中並非需納入本附錄中列出之所有控制目標及控制措施。適用性聲明中應包含排除任何控制目標之理由 [參照 6.1.3 e)]。排除理由可涵蓋風險評鑑認為控制措施非必要之情況，以及適用法律要求事項（或有例外狀況）未要求控制措施之情況。

表 A.1 適用於 PII 控制者，表 A.2 適用於 PII 處理者，表 A.3 與適用於 PII 控制者及 PII 處理者之安全控制措施相關。

備考：表格 A.1、A.2 和 A.3 「控制參考」中之引用為附錄 B 對應條款編號（如：有關控制 A.1.2.2 的指導可在 B.1.2.2 中找到）。

表 A.1 — PII 控制者之控制目標與控制措施

蒐集及處理的條件 控制目標

為證明處理是合法的，具備所適用司法管轄區域的法律基礎，並具備清楚定義且正當之目的。

A.1.2.2 識別與文件化特定目的

組織應識別並文件化 PII 處理的特定目的。

A.1.2.3 識別合法基礎

組織應為所識別之特定目的，判定、文件化並能夠證明其處理 PII 所依據之相關合法基礎的遵循性。

A.1.2.4 判定取得同意之方式與時機

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

obtained

The organization shall determine and document a process by which it can demonstrate if, when and how consent for the processing of PII was obtained from PII principals.

組織應判定並文件化一項過程，該過程可證明是否、何時以及如何自 PII 當事人取得其對 PII 處理之同意。

A.1.2.5 Obtain and record consent

The organization shall obtain and record consent from PII principals according to the documented processes.

A.1.2.5 取得並記錄同意

組織應依據文件化過程，自 PII 當事人取得並記錄其同意。

A.1.2.6 Privacy impact assessment

The organization shall assess the need for, and implement where appropriate, a privacy impact assessment whenever new processing of PII or changes to existing processing of PII is planned.

A.1.2.6 隱私衝擊評鑑

當計劃進行新的 PII 處理，或變更現有 PII 處理時，組織應評估是否需要進行隱私衝擊評估，並於適當時實施之。

A.1.2.7 Contracts with PII processors

The organization shall have a written contract with any PII processor that it uses, and shall ensure that their contracts with PII processors address the implementation of the appropriate controls in Annex A (see Table A.2).

A.1.2.7 與 PII 處理者之契約

組織應與其使用的所有 PII 處理者簽訂書面契約，並確保該契約闡明附錄 A (參照表 A.2) 所列適當控制措施的實作。

A.1.2.8 Joint PII controller

The organization shall determine respective roles and responsibilities for the processing of PII (including PII protection and security requirements) with any joint PII controller.

A.1.2.8 PII 共同控制者

組織應與任何 PII 共同控制者判定處理 PII (包括 PII 保護及安全要求事項) 之各自角色及責任。

A.1.2.9 Records related to processing PII

The organization shall determine and securely maintain the necessary records in support of its obligations for the processing of PII.

A.1.2.9 與處理 PII 有關之紀錄

組織應判定並安全維護必要之紀錄，以支援其對 PII 之處理的義務。

Obligations to PII principals

Objective

To ensure that PII principals are provided with appropriate information about the processing of their PII, and to meet any other applicable obligations to PII principals related to the processing of their PII.

對 PII 當事人之義務

控制目標

確保向 PII 當事人提供有關處理其 PII 之適當資訊，並履行與 PII 處理有關、其他任何適用的對 PII 當事人義務。

A.1.3.2 Determining and fulfilling obligations to PII principals

A.1.3.2 判定並符合對 PII 當事人之義務

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

The organization shall determine and document their legal, regulatory and business obligations to PII principals related to the processing of their PII and provide the means to meet these obligations.

組織應判定並文件化，其在處理 PII 方面，對 PII 當事人的法律，法規和營運義務，並提供履行這些義務的方式。

A.1.3.3 Determining information for PII principals

The organization shall determine and document the information to be provided to PII principals regarding the processing of their PII and the timing of such a provision.

A.1.3.3 判定提供予 PII 當事人之資訊

組織應判定並文件化需提供給 PII 當事人、關於其 PII 之處理的資訊，以及該資訊的提供時機。

A.1.3.4 Providing information to PII principals

The organization shall provide PII principals with clear and easily accessible information identifying the PII controller and describing the processing of their PII.

A.1.3.4 提供資訊予 PII 當事人

組織應向 PII 當事人提供清晰且易於存取的資訊，以識別 PII 控制者，並描述對其 PII 之處理。

A.1.3.5 Providing mechanism to modify or withdraw consent

The organization shall provide a mechanism for PII principals to modify or withdraw their consent.

A.1.3.5 提供修訂或撤回同意之機制

組織應為 PII 當事人提供機制，以修訂或撤回其同意。

A.1.3.6 Providing mechanism to object to PII processing

The organization shall provide a mechanism for PII principals to object to the processing of their PII.

A.1.3.6 提供拒絕 PII 處理之機制

組織應為 PII 當事人提供機制，以拒絕其 PII 之處理。

A.1.3.7 Access, correction or erasure

The organization shall implement policies, procedures or mechanisms to meet its obligations to PII principals to access, correct or erase their PII.

A.1.3.7 存取、更正或抹除

組織應實作政策、程序或機制，以履行其對 PII 當事人的存取、更正或抹除其 PII 之義務。

A.1.3.8 PII controllers' obligations to inform third parties

The organization shall inform third parties with whom PII has been shared of any modification, withdrawal or objections pertaining to the shared PII, and implement appropriate policies, procedures or mechanisms to do so.

A.1.3.8 PII 控制者通知第三方之義務

組織應將已分享的 PII 相關之任何修訂、撤回或拒絕，告知分享 PII 的第三方，並實作並落實適當政策、程序或機制。

A.1.3.9 Providing copy of PII processed

The organization shall be able to provide a copy of the PII that is processed, when requested by the PII principal.

A.1.3.9 提供所處理 PII 之複本

當受 PII 當事人請求時，組織應能夠提供所處理 PII 的複本。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

A.1.3.10 Handling requests

The organization shall define and document policies and procedures for handling and responding to legitimate requests from PII principals.

A.1.3.10 處置請求

組織應定義並文件化政策及程序，供處置及回應 PII 當事人的合法請求。

A.1.3.11 Automated decision making

The organization shall identify obligations, including legal obligations, to the PII principals resulting from decisions made by the organization which are related to the PII principal based solely on automated processing of PII, and be able to demonstrate how it addresses these obligations.

A.1.3.11 自動化決策

組織應識別其因完全基於 PII 的自動化處理所作的決策，而對 PII 當事人產生的義務 (包括法律義務)，並能夠證明其如何因應這些義務。

Privacy by design and privacy by default

Objective:

To ensure that processes and systems are designed such that the collection and processing of PII (including use, disclosure, retention, transmission and disposal) are limited to what is necessary for the identified purpose.

隱私設計及隱私預設

控制目標：

確保過程及系統的設計，可使 PII 的蒐集與處理 (包括利用、揭露、保存、傳輸與處置)，限制於已識別目的所必要。

A.1.4.2 Limit collection

The organization shall limit the collection of PII to the minimum that is relevant, proportional and necessary for the identified purposes.

A.1.4.2 限制蒐集

組織應極小化對 PII 的蒐集，並僅限制於與已識別目的的相關的、比例合理的且必要的。

A.1.4.3 Limit processing

The organization shall limit the processing of PII to that which is adequate, relevant and necessary for the identified purposes.

A.1.4.3 限制處理

組織應將 PII 的處理，限制於對已識別目的而言，為適切的、相關的且必要的。

A.1.4.4 Accuracy and quality

The organization shall ensure and document that PII is as accurate, complete and up to date as necessary for the purposes for which it is processed, throughout the life cycle of the PII.

A.1.4.4 正確性與品質

組織應確保並文件化，PII 在其生命週期全程，能夠與處理目的所需相符的正確性、完整性及最新性。

A.1.4.5 PII minimization objectives

The organization shall define and document data minimization objectives and what mechanisms (such as de-identification) are used to meet those objectives.

A.1.4.5 PII 最小化目標

組織應定義並文件化其資料最小化目標，以及用於符合該等目標的機制 (如去識別化)。

A.1.4.6 PII de-identification and deletion at the

A.1.4.6 處理終止時之 PII 去識別化及刪除

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

end of processing

The organization shall either delete PII or render it in a form which does not permit identification or re-identification of PII principals, as soon as the original PII is no longer necessary for the identified purpose(s).

當已識別的目的已不再需要原始 PII 時，組織應刪除 PII，或使其成為無法識別或重新識別 PII 當事人之形式提供之。

A.1.4.7 Temporary files

The organization shall ensure that temporary files created as a result of the processing of PII are disposed of (e.g. erased or destroyed) following documented procedures within a specified, documented period.

A.1.4.7 暫存檔

組織應確保因處理 PII 而產生的暫存檔，於指定文件化期限內，依據文件化程序處置（如：抹除或銷毀）。

A.1.4.8 Retention

The organization shall not retain PII for longer than is necessary for the purposes for which the PII is processed.

A.1.4.8 保存

組織保存 PII 之時間，不應長於對 PII 處理目的而言所必要的時間。

A.1.4.9 Disposal

The organization shall have documented policies, procedures or mechanisms for the disposal of PII.

A.1.4.9 處置

組織應具備處置 PII 的文件化政策、程序或機制。

A.1.4.10 PII transmission controls

The organization shall subject PII transmitted (e.g. sent to another organization) over a data-transmission network to appropriate controls designed to ensure that the data reaches its intended destination.

A.1.4.10 PII 傳輸控制措施

組織應為透過資料傳輸網路傳輸之 PII（如：發送至另一組織），設計適當的控制措施，以確保資料到達其預期之目的地。

PII sharing, transfer and disclosure

Objective:

To determine whether and document when PII is shared, transferred to other jurisdictions or third parties or disclosed in accordance with applicable obligations.

PII 分享、移轉及揭露

控制目標：

判定並文件化 PII 是否、以及何時，被分享、被轉移至其他司法管轄區域、或第三方，或依適用的義務被揭露。

A.1.5.2 Identify basis for PII transfer between jurisdictions

The organization shall identify and document the relevant basis for transfers of PII between jurisdictions.

A.1.5.2 識別司法管轄區域間的 PII 移轉基礎

組織應識別並文件化，PII 於司法管轄區域間移轉之相關基礎。

A.1.5.3 Countries and international organizations to which PII can be transferred

A.1.5.3 PII 可能被轉移到的國家和國際組織

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

The organization shall specify and document the countries and international organizations to which PII can possibly be transferred.

組織應指明並文件化，PII 可能被轉移到的國家和國際組織。

A.1.5.4 Records of transfer of PII

The organization shall record transfers of PII to or from third parties and ensure cooperation with those parties to support future requests related to obligations to the PII principals.

A.1.5.4 PII 傳輸紀錄

組織應記錄與第三方間的 PII 傳輸與接收，並確保與該等第三方合作，以支援未來與對 PII 當事人之義務有關之請求。

A.1.5.5 Records of PII disclosures to third parties

The organization shall record disclosures of PII to third parties, including what PII has been disclosed, to whom and at what time.

A.1.5.5 向第三方揭露 PII 之紀錄

組織應記錄對第三方的 PII 揭露，包括已揭露的 PII、對象與時間。

Table A.2 — Control objectives and controls for PII processors

Conditions for collection and processing

Objective

To demonstrate that processing is lawful, with legal basis as per applicable jurisdictions, and with clearly defined and legitimate purposes.

表 A.2 — PII 處理者之控制目標與控制措施

蒐集及處理的條件

控制目標

證明處理是合法的、具備適用司法管轄區域之法律基礎，並具備明確定義且合法正當的目的。

A.2.2.2 Customer agreement

The organization shall ensure, where relevant, that the contract to process PII addresses the organization's role in providing assistance with the customer's obligations (taking into account the nature of processing and the information available to the organization).

A.2.2.2 客戶協議

組織應確保有關 PII 處理的契約，闡明組織於客戶應承擔義務，提供相關協助時之角色（，並將處理的特性，及組織可取得的資訊納入考量）。

A.2.2.3 Organization's purposes

The organization shall ensure that PII processed on behalf of a customer are only processed for the purposes expressed in the documented instructions of the customer.

A.2.2.3 組織的目的

組織應確保代表客戶處理的 PII，僅會依據客戶書面指令所表示的目的，進行處理。

A.2.2.4 Marketing and advertising use

The organization shall not use PII processed under a contract for the purposes of marketing and advertising without establishing that prior consent was obtained from the appropriate PII principal. The organization shall not make providing such consent a condition for receiving the service.

A.2.2.4 行銷及廣告使用

組織不應將依契約所處理的 PII，使用於行銷與廣告目的，除非確認已自相關 PII 當事人取得事前同意。組織不應將提供此一同意，列為接受服務的條件。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

A.2.2.5 Infringing instruction

The organization shall inform the customer if, in its opinion, a processing instruction infringes applicable legal requirements.

A.2.2.6 Customer obligations

The organization shall provide the customer with the appropriate information such that the customer can demonstrate compliance with their obligations.

A.2.2.7 Records related to processing PII

The organization shall determine and maintain the necessary records in support of demonstrating compliance with its obligations (as specified in the applicable contract) for the processing of PII carried out on behalf of a customer.

Obligations to PII principals**Objective:**

To ensure that PII principals are provided with the appropriate information about the processing of their PII, and to meet any other applicable obligations to PII principals related to the processing of their PII.

A.2.3.2 Comply with obligations to PII principals

The organization shall provide the customer with the means to comply with its obligations related to PII principals.

Privacy by design and privacy by default**Objective:**

To ensure that processes and systems are designed such that the collection and processing of PII (including use, disclosure, retention, transmission and disposal) are limited to what is necessary for the identified purpose.

A.2.4.2 Temporary files

The organization shall ensure that temporary files created as a result of the processing of PII are disposed of (e.g. erased or destroyed) following documented procedures within a specified, documented period.

A.2.2.5 侵權指令

組織認為處理的指令違反了適用的法律要求事項時，應通知客戶。

A.2.2.6 客戶應承擔的義務

組織應向客戶提供適切之資訊，使客戶能夠證明對其應承擔義務的遵循。

A.2.2.7 與處理 PII 有關之紀錄

組織應判定並維護必要的紀錄，以支持並證明其為所代表客戶執行 PII 處理時，已遵循（如適用契約中所指明的）組織應盡義務。

對 PII 當事人之義務**控制目標：**

確保向 PII 當事人提供有關處理其 PII 之適當資訊，並履行與 PII 處理有關、其他任何適用的對 PII 當事人義務。

A.2.3.2 遵循對 PII 當事人之義務

組織應提供客戶方式，以遵循其與 PII 當事人相關之義務。

隱私設計及隱私預設**控制目標：**

確保設計過程及系統時，將 PII 之蒐集及處理(包括利用、揭露、保存、傳輸及處置) 限制於所敘明目的之必要範圍內。

A.2.4.2 暫存檔

組織應確保因處理 PII 而產生的暫存檔，於指定文件化期限內，依據文件化程序處置（如：抹除或銷毀）。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

A.2.4.3 Return, transfer or disposal of PII

The organization shall be able to return, transfer or dispose of PII in a secure manner. It shall also make its policy available to the customer.

A.2.4.4 PII transmission controls

The organization shall subject PII transmitted over a data-transmission network to appropriate controls, which are designed to ensure that the data reaches its intended destination.

PII sharing, transfer and disclosure**Objective:**

To determine whether and document when PII is shared, transferred to other jurisdictions or third parties or disclosed in accordance with applicable obligations.

A.2.5.2 Basis for PII transfer between jurisdictions

The organization shall inform the customer in a timely manner of the basis for PII transfers between jurisdictions and of any intended changes in this regard, so that the customer can object to such changes or to terminate the contract.

A.2.5.3 Countries and international organizations to which PII can be transferred

The organization shall specify and document the countries and international organizations to which PII can possibly be transferred.

A.2.5.4 Records of PII disclosures to third parties

The organization shall record disclosures of PII to third parties, including what PII has been disclosed, to whom and when.

A.2.5.5 Notification of PII disclosure requests

The organization shall notify the customer of any legally binding requests for disclosure of PII.

A.2.5.6 Legally binding PII disclosures

The organization shall reject any requests for PII disclosures that are not legally binding, consult the corresponding customer before making any PII disclosures and accept any contractually agreed

A.2.4.3 PII 之歸還、傳輸或處置

組織應能夠以安全方式歸還、傳輸或處置 PII。亦應使客戶可取得其政策。

A.2.4.4 PII 傳輸控制措施

組織應對透過資料傳輸網路傳輸的 PII 採取適當的控制措施，其設計可確保資料抵達其預期之目的地。

PII 分享、傳輸及揭露**控制目標：**

判定並文件化 PII 是否、以及何時，被分享、被轉移至其他司法管轄區域、或第三方，或依適用的義務被揭露。

A.2.5.2 司法管轄區域間 PII 轉移基礎

組織應及時通知客戶有關司法管轄區域間 PII 轉移基礎之依據，及應告知客戶任何相關的預期變更，以便客戶可以對此提出異議或終止契約。

A.2.5.3 PII 傳輸至其他國家及國際組織

組織應指明並文件化，PII 可能被轉移到的國家和國際組織。

A.2.5.4 向第三方揭露 PII 之紀錄

組織應記錄對第三方的 PII 揭露，包括已揭露的 PII，對象與時間。

A.2.5.5 PII 揭露請求之通知

組織應通知客戶所有具法律約束力之 PII 揭露請求。

A.2.5.6 具法律約束力之 PII 揭露

組織應拒絕任何未具法律約束力的 PII 揭露請求，於進行任何 PII 揭露前應諮詢對應客戶，並接受經契約約定且由該客戶授權的 PII 揭露請求。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

requests for PII disclosures that are authorized by the corresponding customer.

A.2.5.7 Disclosure of subcontractors used to process PII

Before use, the organization shall disclose whether any subcontractors are used to process PII to the customer.

A.2.5.8 Engagement of a subcontractor to process PII

The organization shall only engage a subcontractor to process PII according to the customer contract.

A.2.5.9 Change of subcontractor to process PII

The organization shall, in the case of having general written authorization, inform the customer of any intended changes concerning the addition or replacement of subcontractors to process PII, thereby giving the customer the opportunity to object to such changes.

Table A.3 — Control objectives and controls for PII controllers and PII processors

Security considerations for PII controllers and processors

Objective

To ensure the security of PII processing.

A.3.3 Policies for information security

Information security policies related to PII processing shall be defined, approved by management, published, communicated to and acknowledged by relevant personnel and relevant interested parties, and reviewed at planned intervals and if significant changes occur.

A.3.4 Information security roles and responsibilities

Information security roles and responsibilities related to PII processing shall be defined and allocated according to the organization needs.

A.3.5 Classification of information

Information shall be classified according to the

A.2.5.7 揭露用於處理 PII 之分包商

組織應在使用分包商處理 PII 前向客戶進行揭露。

A.2.5.8 聘用 PII 處理分包商

組織應僅依客戶契約聘用分包商處理 PII。

A.2.5.9 變更 PII 處理分包商

在通則性書面授權的情況下，組織應通知客戶有關增加或變更 PII 處理分包商的任何預期變更，讓客戶有機會拒絕此類變更。

表 A.3 — 適用於 PII 控制者與 PII 處理者之控制目標與控制措施

PII 控制者與處理者之安全考量

控制目標

確保 PII 處理之安全。

A.3.3 資訊安全政策

與 PII 處理相關的資訊安全政策應予以定義、由管理階層核可、發布、傳達予相關人員及相關關注方，且其係知悉，並依規劃期間及發生重大變更時審查。

A.3.4 資訊安全之角色及責任

應依組織需要，定義並配置，與 PII 處理相關的資訊安全之角色及責任。

A.3.5 資訊之分類分級

資訊應依組織之資訊安全需要，並納入 PII 考量，

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

information security needs of the organization, taking into consideration PII, based on confidentiality, integrity, availability and relevant interested party requirements.

依機密性、完整性、可用性及相關關注方要求事項分類分級。

A.3.6 Labelling of information

An appropriate set of procedures for information labelling that considers PII shall be developed and implemented in accordance with the information classification scheme adopted by the organization.

A.3.6 資訊之標示

應依組織所採用，並納入 PII 考量之資訊分級方案，發展及實作一套適切的資訊標示程序。

A.3.7 Information transfer

Information transfer rules, procedures, or agreements related to processing PII shall be in place for all types of transfer facilities within the organization and between the organization and other parties.

A.3.7 資訊傳送

應備妥關於 PII 處理的資訊傳送規則、程序或協議，用於組織內及組織與其他各方間之所有型式的傳送設施。

A.3.8 Identity management

The full life cycle of identities related to PII processing shall be managed.

A.3.8 身分管理

應管理與 PII 處理相關身分之整個生命週期。

A.3.9 Access rights

Access rights to PII and other associated assets related to PII processing shall be provisioned, reviewed, modified and removed in accordance with the organization's topic-specific policy on and rules for access control.

A.3.9 存取權限

應依組織之存取控制的主題特定政策及規則，提供、審查、修改及刪除對 PII 及其他與 PII 處理相關聯資產之存取權限。

A.3.10 Addressing information security within supplier agreements

Relevant information security requirements related to PII processing shall be established and agreed with each supplier based on the type of supplier relationship.

A.3.10 於供應者協議中闡明資訊安全

應依供應者關係之型式，建立與 PII 處理相關的資訊安全要求事項，並與各供應者議定。

A.3.11 Information security incident management planning and preparation

The organization shall plan and prepare for managing information security incidents related to PII processing by defining, establishing and communicating incident management processes, roles and responsibilities.

A.3.11 資訊安全事故管理規劃及準備

組織應藉由定義、建立並溝通或傳達事故管理過程、角色及責任，規劃並準備管理與 PII 處理相關資訊安全事故。

A.3.12 Response to information security

A.3.12 對資訊安全事故之回應

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

incidents

Responses to information security incidents related to PII processing shall be according to the documented procedures.

應依書面記錄程序，回應與 PII 處理相關的資訊安全事故。

A.3.13 Legal, statutory, regulatory and contractual requirements

Legal, statutory, regulatory and contractual requirements relevant to information security related to PII processing and the organization's approach to meet these requirements shall be documented and this documentation kept up to date.

A.3.13 法律、法令、法規及契約要求事項

應書面記錄及保持更新與 PII 處理相關的資訊安全相關法律、法令、法規及契約之要求事項，以及組織為符合此等要求事項的作法。

A.3.14 Protection of records

Records related to PII processing shall be protected from loss, destruction, falsification, unauthorized access and unauthorized release.

A.3.14 紀錄之保護

應保護與 PII 處理相關的紀錄，免於遺失、毀損、偽造、未經授權存取及未經授權發布。

A.3.15 Independent review of information security

The organization's approach to managing information security related to PII processing and its implementation including people, processes and technologies shall be reviewed independently at planned intervals, or when significant changes occur.

A.3.15 資訊安全之獨立審查

應依規劃之期間或當發生重大變更時，獨立審查組織對管理與 PII 處理相關的資訊安全的作法及其實作（包括人員、過程及技術）。

A.3.16 Compliance with policies, rules and standards for information security

Compliance with the organization's information security policy, topic-specific policies, rules and standards related to PII processing shall be regularly reviewed.

A.3.16 對資訊安全政策、規則及標準之遵循性

應定期審查組織與 PII 處理相關的資訊安全政策、主題特定政策、規則及標準之遵循性。

A.3.17 Information security awareness, education and training

Personnel of the organization and relevant interested parties shall receive appropriate information security awareness, education and training and regular updates of the organization's information security policy, topic-specific policies and procedures, as relevant for their job function, as they relate to PII processing.

A.3.17 資訊安全認知及教育訓練

組織及相關關注方之人員，當其與 PII 處理相關時，均應接受與其工作職能相關的組織資訊安全政策、主題特定政策及程序之適切資訊安全認知及教育訓練，並定期更新。

A.3.18 Confidentiality or non-disclosure

A.3.18 機密性或保密協議

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

agreements

Confidentiality or non-disclosure agreements reflecting the organization's needs for the protection of PII shall be identified, documented, regularly reviewed and signed by personnel and other relevant interested parties.

反映組織對 PII 保護之需要的機密性或保密協議，應由人員及其他相關關注方，識別、書面記錄、定期審查及簽署。

A.3.19 Clear desk and clear screen

Clear desk rules for papers and removable storage media and clear screen rules for information processing facilities shall be defined and appropriately enforced.

A.3.19 桌面淨空及螢幕淨空

應定義對紙本及可移除式儲存媒體之桌面淨空規則，以及對資訊處理設施的螢幕淨空規則，並適切實施之。

A.3.20 Storage media

Storage media with PII shall be managed through its life cycle of acquisition, use, transportation and disposal in accordance with the organization's classification scheme and handling requirements.

A.3.20 儲存媒體

儲存 PII 的媒體應依組織之分類分級方案及處置要求事項，於其獲取、使用、運送及處置的整個生命週期內進行管理。

A.3.21 Secure disposal or re-use of equipment

Items of equipment containing storage media with PII shall be verified to ensure that any sensitive data and licensed software has been removed or securely overwritten prior to disposal or re-use.

A.3.21 設備汰除或重新使用之保全

應查證包含存有 PII 的儲存媒體之設備項目，以確保於汰除或重新使用前，所有敏感性資料及具使用授權的軟體已移除或安全覆寫。

A.3.22 User endpoint devices

PII stored on, processed by or accessible via user endpoint devices shall be protected.

A.3.22 使用者端點裝置

應保護儲存於使用者端點裝置、由使用者端點裝置處理或經由使用者端點裝置可存取之 PII。

A.3.23 Secure authentication

Secure authentication technologies and procedures related to PII processing shall be implemented based on information access restrictions.

A.3.23 安全鑑別

與 PII 處理相關的安全鑑別技術及程序，應依資訊存取限制策實作。

A.3.24 Information backup

Backup copies of PII, and software and systems related to PII processing shall be maintained and regularly tested.

A.3.24 資訊備份

應維護與 PII 處理相關的 PII、軟體與硬體的備份，並定期測試。

A.3.25 Logging

Logs that record activities, exceptions, faults and other relevant events related to PII processing shall be produced, stored, protected and analysed.

A.3.25 存錄

記錄與 PII 處理相關的活動、異常、錯誤及其他相關事件之日誌，應產生、儲存、保護及分析之。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

A.3.26 Use of cryptography

Rules for the effective use of cryptography related to PII processing, including cryptographic key management, shall be defined and implemented.

A.3.26 密碼技術之使用

應定義並實作與 PII 處理相關的有效使用密碼技術之規則 (包括密碼金鑰管理)。

A.3.27 Secure development life cycle

Rules for the secure development of software and systems related to PII processing shall be established and applied.

A.3.27 安全開發生命週期

應建立並施行與 PII 處理相關的安全開發軟體及系統的規則。

A.3.28 Application security requirements

Information security requirements related to PII processing shall be identified, specified and approved when developing or acquiring applications.

A.3.28 應用系統安全要求事項

開發或獲取應用系統時，應識別、規定並核可與 PII 處理相關之資訊安全要求事項。

A.3.29 Secure system architecture and engineering principles

Principles for engineering secure systems related to processing PII shall be established, documented, maintained and applied to any information system development activities.

A.3.29 安全系統架構及工程原則

應建立、書面記錄及維護與 PII 處理相關之工程化安全系統原則，並套用於所有資訊系統開發活動。

A.3.30 Outsourced development

The organization shall direct, monitor and review the activities related to outsourced PII processing system development.

A.3.30 委外開發

組織應指引、監視及審查，與 PII 處理相關的委外系統開發相關之活動。

A.3.31 Test information

Test information related to PII processing shall be appropriately selected, protected and managed.

A.3.31 測試資訊

應適切選擇、保護及管理與 PII 處理相關的測試資訊。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Annex B
(normative)

附錄 B
(規定)

Implementation guidance for PII Controllers and PII processors

B.1 Implementation guidance for PII controllers

B.1.1 General

This clause provides PIMS guidance for PII controllers, which relates to the controls listed in Table A.1.

B.1.2 Conditions for collection and processing

B.1.2.1 Objective

To demonstrate that processing is lawful, with legal basis as per applicable jurisdictions, and with clearly defined and legitimate purposes.

B.1.2.2 Identify and document purpose

Control

The organization should identify and document the specific purposes for which the PII will be processed.

Implementation guidance

The organization should ensure that PII principals understand the purpose for which their PII is processed. It is the responsibility of the organization to clearly document and communicate this to PII principals. Without a clear statement of the purpose for processing, consent and choice cannot be adequately given.

Documentation of the purpose(s) for processing PII should be sufficiently clear and detailed so that it can be used as part of the information to be provided to PII principals (see B.1.3.3). This documentation should include information necessary to obtain consent (see B.1.2.4), as well as documented information of policies and procedures (see B.1.2.9).

Other information

In the deployment of cloud computing services, the taxonomy and definitions in ISO/IEC 19944-1

PII 控制者及 PII 處理者之實作指引

B.1 PII 控制者及之實作指引

B.1.1 一般要求

本節提供 PII 控制者 PIMS 實作指引，表 A.1 中列出的控制措施相關。

B.1.2 蒐集及處理的條件

B.1.2.1 控制目標

為證明處理是合法的，具備所適用司法管轄區域的法律基礎，並具備清楚定義且正當之目的。

B.1.2.2 識別與文件化特定目的

控制措施

組織宜識別並文件化 PII 處理的特定目的。

實作指引

組織應確保 PII 主體了解其 PII 被處理的目的。明確記錄並傳達此目的給 PII 主體是組織的責任。若未清楚說明處理目的，將無法充分取得同意與選擇。

PII 處理目的的文件化應足夠清晰且詳盡，以便作為提供給 PII 主體的資訊的一部分 (參照 B.1.3.3)。此文件應包含取得同意所需的資訊 (參照 B.1.2.4)，以及政策與程序的文件化資訊 (參照 B.1.2.9)。

其它資訊

在部署雲端運算服務時，ISO/IEC 19944-1 中的分類架構與定義可協助提供描述 PII 處理目的的術

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

can be helpful in providing terms for describing the purpose of the processing of PII.

語。

B.1.2.3 Identify lawful basis

Control

The organization should determine, document and be able to demonstrate compliance with the relevant lawful basis for the processing of PII for the identified purposes.

Implementation guidance

Some jurisdictions require the organization to be able to demonstrate that the lawfulness of processing was duly established before the processing.

The legal basis for the processing of PII can include:

- consent from PII principals;
- performance of a contract;
- compliance with a legal obligation;
- protection of the vital interests of PII principals;
- performance of a task carried out in the public interest;
- legitimate interests of the PII controller.

The organization should document this basis for each PII processing activity (see B.1.2.9).

The legitimate interests of the organization can include, for instance, information security objectives, which should be balanced against the obligations to PII principals with regards to the protection of privacy.

Whenever special categories of PII are defined, either by the nature of the PII (e.g. health information) or by the PII principals concerned (e.g. PII relating to children) the organization should include those categories of PII in its classification schemes.

The classification of PII that falls into these categories can vary from one jurisdiction to another and can vary between different regulatory

B.1.2.3 識別合法基礎

控制措施

組織宜為所識別之特定目的，判定、文件化並能夠證明其處理 PII 所依據之相關合法基礎的遵循性。

實作指引

部分司法管轄區域要求組織能夠證明，在進行處理之前，已適當建立處理的合法性。

PII 處理之法律基礎可包括：

- PII 當事人之同意；
- 契約之履行；
- 對法律義務之遵循；
- PII 當事人切身利益之保護；
- 為公共利益而執行之任務的履行；
- PII 控制者之合法利益。

組織宜針對各 PII 處理活動，登載此基礎 (參照 B.1.2.9)。

組織的合法利益可以包括，例如：資訊安全目標，但應與保護隱私的義務進行平衡。

當定義特殊類別的 PII 時，無論是基於 PII 的性質 (如：健康資訊)，或基於 PII 當事人 (如：涉及兒童的 PII)，組織應將這些類別納入其分類架構。

屬於這些類別的 PII 分類可能因司法管轄區域而異，並可能因不同業務適用的監管制度而不同，因此組織需要了解適用於其所執行 PII 處理的分類。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

regimes that apply to different kinds of business, so the organization needs to be aware of the classification(s) that apply to the PII processing being performed.

The use of special categories of PII can also be subject to more stringent controls.

Changing or extending the purposes for the processing of PII can require updating or revision of the legal basis. It can also require additional consent to be obtained from the PII principal.

特殊 PII 種類之利用亦可能採用較嚴格之控制措施。

變更或延伸 PII 處理之目的，可能要求更新或修訂法律基礎，亦可要求額外取得 PII 當事人之同意。

B.1.2.4 Determine when and how consent is to be obtained

Control

The organization should determine and document a process by which it can demonstrate if, when and how consent for the processing of PII was obtained from PII principals.

Implementation guidance

Consent can be required for processing of PII. The organization should clearly document when consent needs to be obtained and the requirements for obtaining consent. It can be useful to correlate the purpose(s) for processing with information about if and how consent is obtained.

NOTE Legal requirements can apply.

Some jurisdictions have specific requirements for how consent is collected and recorded (e.g. not bundled with other agreements). Additionally, certain types of data collection (e.g. for scientific research) and certain types of PII principals, such as children, can be subject to additional requirements. The organization should take into account such requirements and document how mechanisms for consent meet those requirements.

B.1.2.5 Obtain and record consent

Control

B.1.2.4 判定取得同意之方式與時機

控制措施

組織宜判定並文件化一項過程，該過程可證明是否、何時以及如何自 PII 當事人取得其對 PII 處理之同意。

實作指引

處理 PII 時可能需要取得同意。組織應明確記錄何時需要取得同意，以及取得同意的要求。將處理目的與是否以及如何取得同意的資訊進行關聯，可能會有所幫助。

備考：可適用法律遵循事項。

部分司法管轄區域對於如何蒐集及記錄同意有特定要求（例如：不得與其他協議綁定）。此外，某些類型的資料收集（例如：用於科學研究），以及某些類型的 PII 當事人，例如兒童，可能會受到額外要求的約束。組織宜考慮此類要求，並文件化同意機制如何符合這些要求。

B.1.2.5 取得並記錄同意

控制措施

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

The organization should obtain and record consent from PII principals according to the documented processes.

Implementation guidance

The organization should obtain and record consent from PII principals in such a way that it can provide details by request of the consent provided (e.g. the time that consent was provided, the identification of the PII principal and the consent statement).

The information delivered to the PII principal before the consent process should follow the guidance in B.1.3.4.

The consent should be:

- freely given;
- specific regarding the purpose for processing; and
- unambiguous and explicit.

B.1.2.6 Privacy impact assessment

Control

The organization should assess the need for, and implement where appropriate, a privacy impact assessment whenever new processing of PII or changes to existing processing of PII is planned.

Implementation guidance

PII processing generates risks for PII principals. These risks should be assessed through a privacy impact assessment. Some jurisdictions define cases for which a privacy impact assessment is mandated. Criteria can include automated decision making which produces legal effects on PII principals, large scale processing of special categories of PII (e.g. health-related information, racial or ethnic origin, political opinions, religious or philosophical beliefs, trade-union membership, genetic data or biometric data), or systematic monitoring of a publicly accessible area on a large scale.

The organization should determine the elements

組織宜依據文件化過程，自 PII 當事人取得並記錄其同意。

實作指引

組織宜以能在要求時提供所給予同意的詳細資訊的方式，取得並記錄 PII 當事人的同意 (例如：同意提供的時間、PII 當事人的識別資訊以及同意聲明)。

在同意程序之前提供給 PII 當事人的資訊宜遵循 B.1.3.4 中的指導方針。

同意宜：

- 基於自由意志給予；
- 指明處理的目的；及
- 明確且不含糊。

B.1.2.6 隱私衝擊評鑑

控制措施

當計劃進行新的 PII 處理，或變更現有 PII 處理時，組織宜評估是否需要進行隱私衝擊評估，並於適當時實施之。

實作指引

PII 處理會對 PII 當事人產生風險。這些風險宜透過隱私衝擊評鑑進行評鑑。部分司法管轄區域會定義必須進行隱私衝擊評估的情況。判斷標準可包括：自動化決策對 PII 當事人產生法律效力、大規模處理特殊類別的 PII (例如：與健康相關的資訊、種族或民族出身、政治觀點、宗教或哲學信仰、工會會員資格、基因資料或生物特徵資料)，或對公共可訪問區域的大規模系統性監控。

組織宜確定完成隱私影響評鑑所需的要素。這些要

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

that are necessary for the completion of a privacy impact assessment. These can include a list of the types of PII processed, where the PII is stored and where it can be transferred. Data flow diagrams and data maps can also be helpful in this context.

NOTE See B.1.2.9 for details of documented information of the processing of PII that can inform a privacy impact or other risk assessment.

Other information

Guidance on privacy impact assessments related to the processing of PII can be found in ISO/IEC 29134.

B.1.2.7 Contracts with PII processors

Control

The organization should have a written contract with any PII processor that it uses and should ensure that its contracts with PII processors address the implementation of the appropriate controls in Table A.2.

Implementation guidance

The contract between the organization and any PII processor processing PII on its behalf should require the PII processor to implement the appropriate controls specified in Table A.2, taking account of the information security risk assessment process (see 6.1.2) and the scope of the processing of PII performed by the PII processor. By default, all controls specified in Table A.2 should be assumed as relevant. If the organization decides that the PII processor is not required to implement a control from Table A.2, it should justify its exclusion (see 6.1.3).

A contract can define the responsibilities of each party differently but, to be consistent with this document, all controls should be considered and included in the documented information.

B.1.2.8 Joint PII controller

Control

The organization should determine respective roles

素可包括：處理的 PII 類型清單、PII 的儲存位置及其可能的傳輸位置。資料流程圖和資料地圖在此情境中也可能有幫助。

備考：請參閱 B.1.2.9 以取得有關 PII 處理的文件化資訊細節，該資訊可用於隱私衝擊評鑑或其他風險評鑑。

其他資訊

與 PII 處理相關的隱私衝擊評鑑實作指引可參閱 ISO/IEC 29134。

B.1.2.7 與 PII 處理者之契約

控制措施

組織宜與其使用的所有 PII 處理者簽訂書面契約，並確保該契約闡明表 A.2 所列適當控制措施的實作。

實作指引

組織與任何代表其處理 PII 的 PII 處理者之間的契約，宜要求 PII 處理者實施 (表 A.2) 中規定的適當控制措施，並考量資訊安全風險評估程序 (參照：6.1.2)，以及 PII 處理者所執行的 PII 處理範圍。預設情況下，(表 A.2) 中規定的所有控制措施宜視為相關。如果組織決定 PII 處理者不必實施 (表 A.2) 中的某項控制措施，則宜對其排除進行合理化說明 (參照：6.1.3)。

契約可對各方責任進行不同定義，但為與本文件保持一致，所有控制措施宜被考慮並納入文件化資訊中。

B.1.2.8 PII 共同控制者

控制措施

組織宜與任何 PII 共同控制者判定處理 PII (包括

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

and responsibilities for the processing of PII
(including PII protection and security requirements)
with any joint PII controller.

Implementation guidance

Roles and responsibilities for the processing of PII should be determined in a transparent manner.

These roles and responsibilities should be documented in a contract or any similar binding document that contains the terms and conditions for the joint processing of PII. In some jurisdictions, such an agreement is called a data sharing agreement.

A joint PII controller agreement can include:

- the purpose of PII sharing / joint PII controller relationship;
- the identity of the organizations (PII controllers) that are part of the joint PII controller relationship;
- The categories of PII to be shared or transferred and processed under the agreement;
- an overview of the processing operations (e.g. transfer, use);
- a description of the respective roles and responsibilities;
- the responsibility for implementing technical and organizational security measures for PII protection;
- the definition of responsibility in case of a PII breach (e.g. who will notify, when, mutual information);
- terms of retention or disposal of PII;
- liabilities for failure to comply with the agreement;
- how obligations to PII principals are met;
- how to provide PII principals with information covering the essence of the arrangement between the joint PII controllers;
- how PII principals can obtain other information they are entitled to receive; and
- a contact point for PII principals.

PII 保護及安全要求事項) 之各自角色及責任。

實作指引

PII 處理的角色與責任宜以透明方式加以判定。

這些角色和責任宜記錄在契約或任何有類似約束力的文件中，其中應包含共同處理 PII 的條款和條件。在部分司法管轄區域，此協議稱為資料分享協議。

PII 共同控制者協議可包含

- PII 分享的目的/ PII 共同控制者關係；
- 參與 PII 共同控制者關係的組織 (PII 控制者) 的識別資訊；
- 協議下預定分享或傳輸並處理的 PII 類別；
- 處理作業概況 (如：傳輸、利用)；
- 描述各自的角色與責任；
- 實作 PII 保護技術與組織性安全措施之責任；
- 發生 PII 違規事件時責任的定義 (例如：由誰通報、通報時間、以及相互提供的資訊)；
- PII 保存或處置的條件；
- 無法遵循協議之責任；
- 如何符合對 PII 當事人之義務；
- 如何向 PII 當事人提供，涵蓋與 PII 共同控制者間安排的實質內容資訊；
- PII 當事人如何可獲得其他應有的資訊；及
- 對 PII 當事人的聯絡窗口。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

B.1.2.9 Records related to processing PII

Control

The organization should determine and securely maintain the necessary records in support of its obligations for the processing of PII.

Implementation guidance

Documented information of the processing of PII can be maintained through an inventory or list of the PII processing activities that the organization performs. Such an inventory can include:

- the type of processing;
- the purposes for the processing;
- a description of the categories of PII and PII principals (e.g. children);
- the categories of recipients to whom PII has been or will be disclosed, including recipients in third countries or international organizations;
- a general description of the technical and organizational security measures; and
- a privacy impact assessment report.

Such an inventory should have an owner who is responsible for its accuracy and completeness.

B.1.3 Obligations to PII principals

B.1.3.1 Objective

To ensure that PII principals are provided with appropriate information about the processing of their PII, and to meet any other applicable obligations to PII principals related to the processing of their PII.

B.1.3.2 Determining and fulfilling obligations to PII principals

Control

The organization should determine and document their legal, regulatory and business obligations to PII principals related to the processing of their PII and provide the means to meet these obligations.

Implementation guidance

Obligations to PII principals and the means to support them vary from one jurisdiction to another.

B.1.2.9 與處理 PII 有關之紀錄

控制措施

組織宜判定並安全維護必要之紀錄，以支援其對 PII 之處理的義務。

實作指引

PII 處理的文件化資訊，可透過組織所執行 PII 處理活動的清冊或列表加以維護，此類清冊可包括：

- 處理型式；
- 處理目的；
- PII 種類及 PII 當事人種類 (例如：未成年人) 之描述；
- 曾經或將揭露 PII 予接收者之種類，包括第三國或國際組織中的接收者；
- 技術性及組織性安全控制措施之一般說明；及
- 隱私衝擊評鑑報告。

此種清冊宜具對其準確性及完備性負責之當責者。

B.1.3 對 PII 當事人之義務

B.1.3.1 控制目標

確保向 PII 當事人提供有關處理其 PII 之適當資訊，並履行與 PII 處理有關、其他任何適用的對 PII 當事人義務。

B.1.3.2 判定並符合對 PII 當事人之義務

控制措施

組織宜判定並文件化，其在處理 PII 方面，對 PII 當事人的法律、法規和營運義務，並提供履行這些義務的方式。

實作指引

對 PII 當事人之義務及其義務的方式，因司法管轄區域而異。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

The organization should ensure that they provide the appropriate means to meet the obligations to PII principals in an accessible and timely manner. Clear documentation should be provided to the PII principal describing the extent to which the obligations to them are fulfilled and how, along with an up-to-date contact point where they can address their requests.

The contact point should be provided in a similar way to that used to collect PII and consent (e.g. if PII are collected by email or a website, the contact point should be by email or the website, not an alternative such as phone or fax).

B.1.3.3 Determining information for PII principals **Control**

The organization should determine and document the information to be provided to PII principals regarding the processing of their PII and the timing of such a provision.

Implementation guidance

The organization should determine the legal, regulatory or business requirements for providing information to the PII principal (e.g. prior to processing, within a certain time from when it is requested) and for the type of information to be provided.

Depending on the requirements, the information can take the form of a notice. Examples of types of information that can be provided to PII principals are:

- information about the purpose of the processing (see B.1.2.2);
- contact details for the PII controller or its representative;
- information about the lawful basis for the processing (see B.1.2.3);
- information on where the PII was obtained, if not obtained directly from the PII principal;
- information about whether the provision of

組織宜確保其以可存取且及時的方式，提供適當方式以符合對 PII 當事人的義務。宜向 PII 當事人提供明確文件，說明其義務符合的程度及方式，並提供最新的聯絡窗口，以便其提出請求。

聯絡窗口宜以與蒐集 PII 及同意所採用方式類似的方式提供 (例如：若 PII 係透過電子郵件或網站收集，則聯絡窗口宜為電子郵件或網站，而非電話或傳真等替代方式)。

B.1.3.3 判定提供予 PII 當事人之資訊 **控制措施**

組織宜判定並文件化需提供給 PII 當事人、關於其 PII 之處理的資訊，以及該資訊的提供時機。

實作指引

組織宜判定法令或營運要求事項，以判定何時將提供資訊予 PII 當事人 (如：處理前、自請求起之特定時間內等)，以及將提供之資訊型式。

依要求事項，資訊可採取告知之形式。可對 PII 當事人提供之資訊型式例如：

- 關於處理目的之資訊 (參照 B.1.2.2)；
- PII 控制者或其代表之聯絡細節；
- 關於處理之法律基礎的資訊 (參照 B.1.2.3)；
- 有有關 PII 資料取得來源之資訊 (若並非直接自 PII 當事人取得)；
- 有關提供 PII 是否屬於法定或契約上的要

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

- PII is a statutory or contractual requirement, and where appropriate, the possible consequences of failure to provide PII;
- information on obligations to PII principals, as determined in B.1.3.2, and how PII principals can benefit from them, especially regarding accessing, amending, correcting, requesting erasure, receiving a copy of their PII and objecting to the processing;
 - information on how the PII principal can withdraw consent (see B.1.3.5);
 - information about transfers of PII;
 - information about recipients or categories of recipients of PII;
 - information about the period for which the PII will be retained;
 - information about the use of automated decision making based on the automated processing of PII;
 - information about the right to lodge a complaint and how to lodge such a complaint;
 - information regarding the frequency with which information is provided (e.g. “just in time” notification, organization defined frequency).

The organization should provide updated information if the purposes for the processing of PII are changed or extended.

B.1.3.4 Providing information to PII principals

Control

The organization should provide PII principals with clear and easily accessible information identifying the PII controller and describing the processing of their PII.

Implementation guidance

The organization should provide the information detailed in B.1.3.3 to PII principals in a timely, concise, complete, transparent, intelligible and easily accessible form, using clear and plain language, as appropriate to the target audience. Where appropriate, the information should be

求，以及在適當情況下未能提供 PII 的可能後果之資訊；

- 有關對 PII 當事人之義務的資訊，依 B.1.3.2 判定，以及 PII 當事人權益(尤其有關請求存取、修改、更正、抹除、取得複本及反對該處理)之資訊；
- 關於 PII 當事人如何能撤回同意之資訊(參照 B.1.3.5)；
- 關於 PII 傳輸之資訊；
- 關於 PII 接收者或 PII 接收者種類之資訊；
- 關於保存 PII 期限之資訊；
- 關於依 PII 自動化處理，使用自動化決策之資訊；
- 關於提出訴怨之權利及如何提出此種訴怨的資訊；
- 有關提供資訊之頻率的資訊(如：「及時」告知、組織定義之頻率等)。

若變更或延伸 PII 處理之目的，則組織宜提供更新資訊。

B.1.3.4 提供資訊予 PII 當事人

控制措施

組織宜向 PII 當事人提供清晰且易於存取之資訊，以識別 PII 控制者，並描述對其 PII 之處理。

實作指引

組織宜使用清晰、淺白的語言，以適時、簡潔、完備、透明、可理解且易於存取的形式，向 PII 當事人提供 B.1.3.3 所述資訊，並應依目標受眾調整語言與呈現方式。

適當時，宜於 PII 蒐集時提供資訊。其亦宜永久可

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

given at the time of PII collection. It should also be permanently accessible.

存取。

NOTE Icons and images can be helpful to the PII principal by giving a visual overview of the intended processing.

備考：藉由提供預期處理之視覺概觀，圖示及影像可能有助於 PII 當事人。

B.1.3.5 Providing mechanism to modify or withdraw consent

Control

The organization should provide a mechanism for PII principals to modify or withdraw their consent.

Implementation guidance

The organization should inform PII principals of their rights related to withdrawing consent (which may vary by jurisdiction) at any time, and provide the mechanism to do so. The mechanism used for withdrawal depends on the system; it should be consistent with the mechanisms used for obtaining consent when possible. For example, if the consent is collected by email or a website, the mechanism for withdrawing it should be the same, not an alternative solution such as phone or fax.

Modifying consent can include placing restrictions on the processing of PII, which can include restricting the PII controller from deleting the PII in some cases.

Some jurisdictions impose restrictions on when and how a PII principal can modify or withdraw their consent.

The organization should record any request to withdraw or change consent in a similar way to the recording of the consent itself.

Any change of consent should be disseminated, through appropriate systems, to authorized users and to relevant third parties.

The organization should define a response time and requests should be handled according to it.

B.1.3.5 提供修訂或撤回同意之機制

控制措施

組織宜為 PII 當事人提供機制，以修訂或撤回其同意。

實作指引

組織宜隨時告知 PII 當事人撤回同意相關之權利 (可能因司法管轄區域而異)，並提供如此做之機制。用以撤回之機制取決於系統，宜儘可能與用以取得同意之機制一致。例如：若同意係藉由電子郵件或網站蒐集，則撤回同意之機制亦宜相同，而非諸如電話或傳真之替代解決方案。

修改同意可能包括對 PII 處理加以限制，其中在某些情況下，可能包括禁止或限制 PII 控制者刪除該 PII。

某些司法管轄區域對 PII 當事人何時及如何可修改或撤回其同意施加限制。

組織宜記錄撤回或變更同意之所有請求，其方式類似於記錄同意本身。

對同意之所有變更均宜 (透過適當系統) 分送予經授權之使用者及相關的第三方。

組織宜定義回應時間，並宜依回應時間處置請求。

Additional information

額外資訊

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

When consent for processing of specific PII is withdrawn, all the processing of PII performed before withdrawal should normally be considered as appropriate, but the results of such processing should not be used for new processing. For example, if a PII principal withdraws their consent for profiling, their profile should not be further used or consulted.

當針對特定 PII 的處理同意被撤回時，撤回前已完成的 PII 處理一般仍視為適當，但該等處理所產生的結果不應再用於新的處理。例如，如果 PII 當事人撤回對剖析行為的同意，則不應進一步使用或諮詢其個人資料。

B.1.3.6 Providing mechanism to object to PII processing

Control

The organization should provide a mechanism for PII principals to object to the processing of their PII.

Implementation guidance

Some jurisdictions provide PII principals with a right to object to the processing of their PII. Organizations subject to the legal requirements of such jurisdictions should be able to demonstrate how they ensure that they retain records of PII principals exercising this right.

The organization should document the legal and regulatory requirements related to objections by the PII principals to processing (e.g. objection relating to the processing of PII for direct marketing purposes). The organization should provide information to principals regarding the ability to object in these situations. Mechanisms to object can vary, but should be consistent with the type of service provided (e.g. online services should provide this capability online).

B.1.3.7 Access, correction or erasure

Control

The organization should implement policies, procedures or mechanisms to meet its obligations to PII principals to access, correct or erase their PII.

Implementation guidance

The organization should implement policies, procedures or mechanisms for enabling PII principals to obtain access to, correct and erase their PII, if requested and without undue delay.

B.1.3.6 提供拒絕 PII 處理之機制

控制措施

組織宜為 PII 當事人提供機制，以拒絕其 PII 之處理。

實作指引

某些司法管轄區域提供 PII 當事人反對其 PII 被處理之權利。受此類法規約束的組織，應能證明其如何確保保留 PII 當事人行使此項權利之紀錄。

組織宜登載與 PII 當事人對處理提出反對（如：與用於直接行銷目的而處理 PII 有關之反對）相關之法令要求事項。組織宜向當事人提供有關在此等情況下反對能力之資訊。反對之機制可能有所不同，但宜與所提供之服務型式一致（如：線上服務宜於線上提供此能力）。

B.1.3.7 存取、更正或抹除

控制措施

組織宜實作政策、程序或機制，以履行其對 PII 當事人的存取、更正或抹除其 PII 之義務。

實作指引

組織宜實作政策、程序或機制，以使 PII 當事人在提出請求時，能於沒有不當延遲的情況下取得其 PII，並進行存取、更正或抹除。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

The organization should define a response time and requests should be handled according to it.

組織宜定義回應時間，並依回應時間處置請求。

Any corrections or erasures should be disseminated through the system or to authorized users, and should be passed to third parties (see B.1.3.8) to whom the PII has been transferred.

所有更正或抹除宜透過系統散播或予經授權之使用者，並宜傳遞予已將 PII 傳輸至之第三方（參照 B.1.3.8）。

NOTE Documented information generated by the control specified in B.1.5.4 can help in this regard.

備考：由 B.1.5.4 所規定控制措施所產生之紀錄可於此方面有所幫助。

The organization should implement policies, procedures or mechanisms for use when there can be a dispute about the accuracy or correction of the data by the PII principal. These policies, procedures or mechanisms should include informing the PII principal of what changes were made, and of reasons why corrections cannot be made (where this is the case).

組織宜實作政策、程序或機制，供 PII 當事人對資料準確性或更正可能有爭議時使用。此等政策、程序或機制宜包括向 PII 當事人告知已進行之變更，以及無法進行更正的原因（於此情況下）。

Some jurisdictions impose restrictions on when and how a PII principal can request correction or erasure of their PII. The organization should keep abreast of such restrictions.

部分司法管轄區域對 PII 當事人何時以及如何請求更正或抹除其 PII 的權利提出限制。組織應隨時掌握這些限制的最新情況。

B.1.3.8 PII controllers' obligations to inform third parties

Control

The organization should inform third parties with whom PII has been shared of any modification, withdrawal or objections pertaining to the shared PII, and implement appropriate policies, procedures or mechanisms to do so.

B.1.3.8 PII 控制者通知第三方之義務

控制措施

組織宜將已分享的 PII 相關之任何修訂、撤回或拒絕，告知分享 PII 的第三方，並實作並落實適當政策、程序或機制。

Implementation guidance

The organization should take appropriate steps, bearing in mind the available technology, to inform third parties of any modification or withdrawal of consent, or objections pertaining to the shared PII.

實作指引

組織宜考量可用技術，採取適當步驟，將分享 PII 有關之任何修改、撤回同意或反對告知第三方。

The organization should determine and maintain active communication channels with third parties. Related responsibilities can be assigned to individuals in charge of their operations and

組織宜判定並維護與第三方的有效溝通管道。相關職責可指派給負責其運作和維護的人員。通知第三方時，組織應監督其對資訊接收的確認。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

maintenance. When informing third parties, the organization should monitor its acknowledgement of receipt of the information.

NOTE Changes resulting from the obligations to PII principals can include modification or withdrawal of consent, requests for correction, erasure, or restrictions on processing, or objections to the processing of PII as requested by the PII principal.

B.1.3.9 Providing copy of PII processed

Control

The organization should be able to provide a copy of the PII that is processed when requested by the PII principal.

Implementation guidance

The organization should provide a copy of the PII that is processed in a structured, commonly used, format accessible by the PII principal.

Some jurisdictions define cases where the organization should provide a copy of the PII processed in a format allowing portability to the PII principals or to recipient PII controllers (typically structured, commonly used and machine readable).

The organization should ensure that any copies of PII provided to a PII principal relate specifically to that PII principal.

Where the requested PII has already been deleted subject to the retention and disposal policy (as described in B.1.4.8), the PII controller should inform the PII principal that the requested PII has been deleted.

In cases where the organization is no longer able to identify the PII principal (e.g. as a result of a de-identification process), the organization should not seek to (re-)identify the PII principals for the sole reason of implementing this control. However, in some jurisdictions, legitimate requests can require that additional information should be requested

備考：由於對 PII 當事人之義務而產生的變更，可能包括修改或撤回同意、請求更正、抹除或限制處理，或依 PII 當事人請求反對 PII 處理。

B.1.3.9 提供所處理 PII 之複本

控制措施

當受 PII 當事人請求時，組織宜能夠提供所處理 PII 的複本。

實作指引

組織宜以 PII 當事人可存取之結構化、常用格式，提供所處理 PII 之複本。

某些司法管轄區域定義某些情況下，組織宜以允許可攜至 PII 當事人或接收者 PII 控制者之格式(通常為結構化、常用且機器可讀)，提供所處理 PII 之複本。

組織宜確保提供予 PII 當事人之所有 PII 複本均與該 PII 當事人特定相關。

若已依保存及處置政策 (如 B.1.4.8 中所述) 刪除所請求之 PII，則 PII 控制者宜告知 PII 當事人所請求 PII 已刪除。

若組織不再能識別 PII 當事人 (如：由於去識別化過程)，則組織不宜僅由於實作此控制措施之理由而尋求 (再) 識別 PII 當事人。然而，於某些司法管轄區域中，合法請求可能要求宜由 PII 當事人請求額外資訊，以便能重新識別及隨後揭露。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

from the PII principal to enable re-identification and subsequent disclosure.

Where technically feasible, it should be possible to transfer a copy of the PII from one organization directly to another organization, at the request of the PII principal.

技術可行時，宜能於 PII 當事人請求時，將 PII 之複本由一組織直接傳輸至另一組織。

B.1.3.10 Handling requests

Control

The organization should define and document policies and procedures for handling and responding to legitimate requests from PII principals.

Implementation guidance

Legitimate requests can include requests for a copy of PII processed, or requests to lodge a complaint.

Some jurisdictions allow the organization to charge a fee in certain cases (e.g. excessive or repetitive requests).

Requests should be handled within the appropriate defined response times.

Some jurisdictions define response times, depending on the complexity and number of the requests, as well as requirements to inform PII principals of any delay. The appropriate response times should be defined in the privacy policy.

B.1.3.10 處置請求

控制措施

組織宜定義並文件化政策及程序，供處置及回應 PII 當事人的合法請求。

實作指引

合法請求可能包括對所處理 PII 複本之請求，或提出訴怨的請求。

某些司法管轄區域允許組織於某些情況下（如：過多或重複請求）收取費用。

請求宜於適當定義之回應時間內處置。

某些司法管轄區域依請求之複雜性及數量，定義回應時間，以及定義將所有延遲告知 PII 當事人之要求事項，宜於隱私政策中定義適切之回應時間。

B.1.3.11 Automated decision making

Control

The organization should identify obligations, including legal obligations, to the PII principals resulting from decisions made by the organization which are related to the PII principal based solely on automated processing of PII, and be able to demonstrate how it addresses these obligations.

Implementation guidance

Some jurisdictions define specific obligations to PII principals when a decision based solely on automated processing of PII significantly affects

B.1.3.11 自動化決策

控制措施

組織宜識別其因完全基於 PII 的自動化處理所作的決策，而對 PII 當事人產生的義務（包括法律義務），並能夠證明其如何因應這些義務。

實作指引

當僅依 PII 自動化處理之決策對 PII 當事人產生重大影響時，某些司法管轄區域定義特定的對 PII 當事人之義務，諸如通知存在自動化決策、允許

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

them, such as notifying the existence of automated decision making, allowing for the PII principals to object to such decision making, or obtaining human intervention.

NOTE In some jurisdictions, some processing of PII cannot be fully automated.

Organizations operating in these jurisdictions should be able to demonstrate how they take compliance with these obligations into account.

B.1.4 Privacy by design and privacy by default

B.1.4.1 Objective

To ensure that processes and systems are designed such that the collection and processing of PII (including use, disclosure, retention, transmission and disposal) are limited to what is necessary for the identified purpose.

B.1.4.2 Limit collection

Control

The organization should limit the collection of PII to the minimum that is relevant, proportional and necessary for the identified purposes.

Implementation guidance

The organization should limit the collection of PII to what is adequate, relevant and necessary in relation to the identified purposes. This includes limiting the amount of PII that the organization collects indirectly (e.g. through web logs, system logs).

Privacy by default implies that, where any optionality in the collection and processing of PII exists, each option should be disabled by default and only enabled by explicit choice of the PII principal.

B.1.4.3 Limit processing

Control

The organization should limit the processing of PII to that which is adequate, relevant and necessary for the identified purposes.

PII 當事人反對此種決策或取得人工干預。

備考：於某些司法管轄區域中，某些 PII 處理無法完全自動化。於此等司法管轄區域中運作之組織宜考量遵循此等義務。

在這些司法管轄區域內，組織應證明其如何將遵守這些義務納入考量。

B.1.4 隱私設計及隱私預設

B.1.4.1 控制目標

確保過程及系統的設計，可使 PII 的蒐集與處理（包括利用、揭露、保存、傳輸與處置），限制於已識別目的所必要。

B.1.4.2 限制蒐集

控制措施

組織宜極小化對 PII 的蒐集，並僅限制於與已識別目的的相關的、比例合理的且必要的。

實作指引

組織宜將 PII 蒐集限制於與所敘明目的有關之合宜、相關且必要的範圍內。此包括限制組織間接蒐集之 PII 數量（如：透過網頁日誌、系統日誌等）。

預設保護隱私意味，於 PII 蒐集及處理中存在任何選項時，預設各選項皆宜停用，且僅由 PII 當事人之明確選擇而啟用。

B.1.4.3 限制處理

控制措施

組織宜將 PII 的處理，限制於對已識別目的而言，為適切的、相關的且必要的。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Implementation guidance

Limiting the processing of PII should be managed through information security and privacy policies (see 5.2) along with documented procedures for their adoption and compliance.

Processing of PII should be limited by default to the minimum necessary relative to the identified purposes:

- the disclosure;
- the period of PII storage; and
- who can access their PII;

B.1.4.4 Accuracy and quality

Control

The organization should ensure and document that PII is as accurate, complete and up to date as necessary for the purposes for which it is processed, throughout the life cycle of the PII.

Implementation guidance

The organization should implement policies, procedures or mechanisms to minimize inaccuracies in the PII it processes. There should also be policies, procedures or mechanisms to respond to instances of inaccurate PII. These policies, procedures or mechanisms should be included in the documented information (e.g. through technical system configurations) and should apply throughout the PII life cycle.

Additional information

For further information on the PII processing life cycle, see ISO/IEC 29101:2018, 6.2.

B.1.4.5 PII minimization objectives

Control

The organization should define and document data minimization objectives and what mechanisms (such as de-identification) are used to meet those objectives.

Implementation guidance

Organizations should identify how the specific PII

實作指引

限制 PII 之處理宜透過資訊安全及隱私政策 (參照 5.2) 以及其採用並遵循的書面程序進行管理。

PII 處理宜預設限定為與已識別目的相關之最低必要程度：

- 揭露；
- PII 儲存期限；及
- 誰能存取其 PII。

B.1.4.4 正確性與品質

控制措施

組織宜確保並文件化，PII 在其生命週期全程，能夠與處理目的所需相符的正確性、完整性及最新性。

實作指引

組織宜實作政策、程序或機制，以使其處理之 PII 的不準確性降至最低。亦宜具政策、程序或機制，以回應不準確 PII 之事例。此等政策、程序或機制宜納入文件化資訊中(如：透過技術系統組態等)，並宜適用於整個 PII 生命週期。

額外資訊

關於 PII 處理生命週期之更多資訊，參照 ISO/IEC 29101:2018 之 6.2

B.1.4.5 PII 最小化目標

控制措施

組織宜定義並文件化其資料最小化目標，以及用於符合該等目標的機制 (如去識別化)。

實作指引

組織宜敘明，相對於所敘明目的，如何限制所蒐集

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

and amount of PII collected and processed is limited relative to the identified purposes. This can include the use of de-identification or other data minimization techniques.

The identified purpose (see B.1.2.2) can require the processing of PII that has not been de-identified, in which case the organization should be able to describe such processing.

In other cases, the identified purpose does not require the processing of the original PII, and the processing of PII which has been de-identified can suffice to achieve the identified purpose. In these cases, the organization should define and document the extent to which the PII should be associated with the PII principal, as well as the mechanisms and techniques designed to process PII, such that the de-identification and PII minimization objectives are achieved.

Mechanisms used to minimize PII vary depending on the type of processing and the systems used for the processing. The organization should document any mechanisms (technical system configurations, etc.) used to implement data minimization.

In cases where processing of de-identified data is sufficient for the purposes, the organization should document any mechanisms (technical system configurations, etc.) designed to implement de-identification objectives set by the organization in a timely manner. For instance, the removal of attributes associated with PII principals can be sufficient to allow the organization to achieve its identified purpose. In other cases, other de-identification techniques, such as generalization (e.g. rounding) or randomization techniques (e.g. noise addition) can be used to achieve an adequate level of de-identification.

並處理之特定 PII 及 PII 數量。此可能包括使用去識別化或其他資料最小化技術。

所敘明目的 (參照 B.1.2.2) 可能要求處理尚未去識別化之 PII，於此情況下，組織宜能描述此種處理。

於其他情況下，所敘明目的未要求處理原始 PII，且已去識別化 PII 之處理即可滿足所敘明目的。於此等情況下，組織宜定義並登載 PII 需與 PII 當事人相關聯之程度，以及設計用以處理 PII 的機制及技術，以使去識別化及 PII 最小化目標得以達成。

用以最小化 PII 之機制，依處理型式及用於處理的系統而異。組織宜登載用以實作資料最小化之所有機制 (技術系統組態等)。

若處理已去識別化之資料足以達成目的，則組織宜及時登載所有旨在實作其所設定之去識別化目標的機制 (技術系統組態等)。例如：移除與 PII 當事人相關聯之屬性能足以使組織達成其所敘明目的。於其他情況下，可使用諸如概化 (如：捨入) 或隨機化技術 (如：加入雜訊) 之其他去識別化技術達成合宜去識別化等級。

NOTE 1 For further information on de-identification techniques, refer to ISO/IEC 20889.

備考 1：關於去識別化技術之更多資訊，參照 ISO/IEC 20889。

NOTE 2 For cloud computing, ISO/IEC 19944-1 provides a definition

備考 2：針對雲端運算，ISO/IEC 19944 提供資料識別限定符之定

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

of data identification qualifiers that can be used to classify the degree to which the data can identify a PII principal or associate a PII principal with a set of characteristics in the PII.

義，該定義可用以對資料可識別 PII 當事人之程度，或將 PII 當事人與 PII 中一組特性相關聯的程度，進行分級。

B.1.4.6 PII de-identification and deletion at the end of processing

Control

The organization should either delete PII or render it in a form which does not permit identification or re-identification of PII principals, as soon as the original PII is no longer necessary for the identified purpose(s).

Implementation guidance

The organization should have mechanisms to erase the PII when no further processing is anticipated. Alternatively, some de-identification techniques can be used as long as the resulting de-identified data cannot reasonably permit re-identification of PII principals.

B.1.4.7 Temporary files

Control

The organization should ensure that temporary files created as a result of the processing of PII are disposed of (e.g. erased or destroyed) following documented procedures within a specified, documented period.

Implementation guidance

The organization should perform periodic checks that unused temporary files are deleted within the identified time period.

Other information

Information systems can create temporary files in the normal course of their operation. Such files are specific to the system or application but can include file system roll-back journals and temporary files associated with the updating of databases and the operation of other application software. Temporary files are not needed after the related information processing task has been completed but there are circumstances in which they cannot be deleted. The length of time for

B.1.4.6 處理終止時之 PII 去識別化及刪除

控制措施

當已識別的目的已不再需要原始 PII 時，組織宜刪除 PII，或使其成為無法識別或重新識別 PII 當事人之形式提供之。

實作指引

當不期望進一步處理時，組織宜具抹除 PII 之機制。或者，可使用某些去識別化技術處理，只要處理後之去識別化資料無法合理允許重新識別 PII 當事人即可。

B.1.4.7 暫存檔

控制措施

組織宜確保因處理 PII 而產生的暫存檔，於指定文件化期限內，依據文件化程序處置（如：抹除或銷毀）。

實作指引

組織宜進行定期核對，以確保於所敘明時段內，刪除未使用之暫時檔案。

其他資訊

資訊系統可於其正常運作過程中建立暫時檔案。此種檔案係特定於系統或應用程式，但可能包括檔案系統還原 (roll-back) 日誌，以及與資料庫更新及其他應用軟體運作相關聯之暫時檔案。相關之資訊處理任務完成後，不再需要暫時檔案，然於某些情況下可能無法刪除。此等檔案保持使用之時間長短並非恆為確定，然「垃圾蒐集」程序宜識別出相關之檔案，並判定自前次使用後已歷經多長時間。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

which these files remain in use is not always deterministic but a “garbage collection” procedure should identify the relevant files and determine how long it has been since they were last used.

B.1.4.8 Retention

Control

The organization should not retain PII for longer than is necessary for the purposes for which the PII is processed.

Implementation guidance

The organization should develop and maintain retention schedules for information it retains, taking into account the requirement to retain PII for no longer than is necessary. Such schedules should take into account legal, regulatory and business requirements. Where such requirements conflict, a business decision needs to be taken (based on a risk assessment) and documented in the appropriate schedule.

B.1.4.9 Disposal

Control

The organization should have documented policies, procedures or mechanisms for the disposal of PII.

Implementation guidance

The choice of PII disposal techniques depends on a number of factors, as disposal techniques differ in their properties and outcomes (e.g. in the granularity of the resultant physical media, or the ability to recover deleted information on electronic media). Factors to consider when choosing an appropriate disposal technique include, but are not limited to, the nature and extent of the PII to be disposed of, whether or not there is metadata associated with the PII, and the physical characteristics of the media on which the PII is stored.

B.1.4.10 PII transmission controls

Control

The organization should subject PII transmitted The organization should subject PII that has been

B.1.4.8 保存

控制措施

組織保存 PII 之時間，不宜長於對 PII 處理目的而言所必要的時間。

實作指引

組織宜制定並維護其保存資訊的保存時間表，並考量保存 PII 不得超過必要時間之要求。此種時間表宜考量法令及營運要求事項。若此種要求事項相衝突，則需做出營運決策（基於風險評鑑）並登載於適當時間表中。

B.1.4.9 處置

控制措施

組織宜具備處置 PII 的文件化政策、程序或機制。

實作指引

PII 最終處置技術之選擇取決於許多因素，因最終處置技術的性質及結果不同（如：最終實體媒體之精細度或於電子媒體上復原已刪除資訊的能力）。選擇適當最終處置技術時考量之因素包括（但不限於）待處置 PII 的性質及範圍、是否具與 PII 相關聯之詮釋資料，以及儲存 PII 之媒體的物理特性。

B.1.4.10 PII 傳輸控制措施

控制措施

組織宜為透過資料傳輸網路傳輸之 PII（如：發送至另一組織），設計適當的控制措施，以確保資料到達

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

transmitted (e.g. sent to another organization) over a data-transmission network to the appropriate controls designed to ensure that the data reaches its intended destination.

Implementation guidance

Transmission of PII needs to be controlled, typically by ensuring that only authorized individuals have access to transmission systems, and by following the appropriate processes (including the retention of audit logs) to ensure that PII is transmitted without compromise to the correct recipients.

B.1.5 PII sharing, transfer and disclosure

B.1.5.1 Objective

To determine whether and document when PII is shared, transferred to other jurisdictions or third parties or disclosed in accordance with applicable obligations.

B.1.5.2 Identify basis for PII transfer between jurisdictions

Control

The organization should identify and document the relevant basis for transfers of PII between jurisdictions.

Implementation guidance

PII transfer can be subject to legal requirements, depending on the jurisdiction or international organization to which data are to be transferred (and from where the data originate). The organization should document compliance to such requirements as the basis for transfer.

Some jurisdictions can require that information transfer agreements be reviewed by a designated supervisory authority. Organizations operating in such jurisdictions should be aware of any such requirements.

NOTE Where transfers take place within a specific jurisdiction, the applicable legislation or regulation are the same for the sender and recipient.

其預期之目的地。

實作指引

PII 之傳輸需受控制，通常係藉由確保僅經授權的個人方能接取傳輸系統，並藉由遵循適當之過程（包括保存稽核日誌），以確保 PII 的傳輸未危害正確之接收者。

B.1.5 PII 分享、傳輸及揭露

B.1.5.1 控制目標

判定並文件化 PII 是否、以及何時，被分享、被轉移至其他司法管轄區域、或第三方，或依適用的義務被揭露。

B.1.5.2 識別司法管轄區域間的 PII 移轉基礎

控制措施

組織宜識別並文件化，PII 於司法管轄區域間移轉之相關基礎。

實作指引

PII 傳輸可能受法令所約束，具體之約束取決於資料將傳輸至（及資料起源自）之司法管轄區域或國際組織。組織宜登載符合此類要求事項，以做為傳輸之基礎。

某些司法管轄區域可能要求資訊傳輸協議由指定之主管機關審查。於此種司法管轄區域運作之組織宜認知所有此種要求事項。

備考：於特定司法管轄區域內進行傳輸之情況下，適用的法令對發送者及接收者皆相同。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

B.1.5.3 Countries and international organizations to which PII can be transferred

Control

The organization should specify and document the countries and international organizations to which PII can possibly be transferred.

Implementation guidance

The identities of the countries and international organizations to which PII can possibly be transferred in normal operations should be made available to customers. The identities of the countries arising from the use of subcontracted PII processing should be included. The countries included should be considered in relation to B.1.5.2.

Outside of normal operations, there can be cases of transfer made at the request of a legal authority, for which the identity of the countries cannot be specified in advance, or such transfer can be prohibited by applicable jurisdictions to preserve the confidentiality of a law enforcement investigation (see B.1.5.2, B.2.5.5 and B.2.5.6).

B.1.5.4 Records of transfer of PII

Control

The organization should record transfers of PII to or from third parties and ensure cooperation with those parties to support future requests related to obligations to the PII principals.

Implementation guidance

Recording can include transfers from third parties of PII which has been modified as a result of PII controllers' managing their obligations, or transfers to third parties to implement legitimate requests from PII principals, including requests to erase PII (e.g. after consent withdrawal).

The organization should have a policy defining the retention period of these records.

The organization should apply the data

B.1.5.3 PII 可能被轉移到的國家和國際組織

控制措施

組織宜指明並文件化，PII 可能被轉移到的國家和國際組織。

實作指引

宜向客戶提供於正常運作中，可能將 PII 傳輸至之國家及國際組織的識別資訊。宜包括使用分包 PII 處理所引發國家之識別資訊。宜考量納入與 B.1.5.2 相關之國家。

於正常運作外，可能具執法機關請求進行傳輸之情況，此等情況的國家識別資訊無法事先規定，或受適用之司法管轄區域禁止，以保護執法調查的機密性（參照 B.1.5.2、B.2.5.5 及 B.2.5.6）。

B.1.5.4 PII 傳輸紀錄

控制措施

組織宜記錄與第三方間的 PII 傳輸與接收，並確保與該等第三方合作，以支援未來與對 PII 當事人之義務有關之請求。

實作指引

紀錄可包括由於 PII 控制者履行其義務而修改之來自 PII 第三方的傳輸，或傳輸至第三方以執行 PII 當事人之合法請求，包括抹除 PII 之請求（如：撤回同意後）。

組織宜具定義此等紀錄之保存期限的政策。

組織宜應用資料最小化原則於傳輸之紀錄，僅保存

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

minimization principle to the records of transfers by retaining only the strictly needed information.

嚴格需要之資訊。

B.1.5.5 Records of PII disclosure to third parties

Control

The organization should record disclosures of PII to third parties, including what PII has been disclosed, to whom and at what time.

Implementation guidance

PII can be disclosed during normal operations. These disclosures should be recorded. Any additional disclosures to third parties, such as those arising from lawful investigations or external audits, should also be recorded. The records should include the source of the disclosure and the source of the authority to make the disclosure.

B.1.5.5 向第三方揭露 PII 之紀錄

控制措施

組織宜記錄對第三方的 PII 揭露，包括已揭露的 PII、對象與時間。

實作指引

可能於正常運作過程期間揭露 PII。宜記錄此等揭露。亦宜記錄所有向第三方之額外揭露，諸如合法調查或外部稽核所引發的揭露。紀錄宜包括揭露之來源及揭露的授權來源。

B.2 Implementation guidance for PII processors

B.2.1 General

This clause provides PIMS guidance for PII processors, which relates to the controls listed in Table A.2.

B.2 PII 處理者之實作指引

B.2.1 一般要求

本節為 PII 處理者提供 PIMS 實作指引，其與表 A.2 中列出的控制措施有關。

B.2.2 Conditions for collection and processing

B.2.2.1 Objective

To demonstrate that processing is lawful, with legal basis as per applicable jurisdictions, and with clearly defined and legitimate purposes.

B.2.2 蒐集及處理的條件

B.2.2.1 控制目標

證明處理是合法的、具備適用司法管轄區域之法律基礎，並具備明確定義且合法正當的目的。

B.2.2.2 Customer agreement

Control

The organization should ensure, where relevant, that the contract to process PII addresses the organization's role in providing assistance with the customer's obligations (taking into account the nature of processing and the information available to the organization).

B.2.2.2 客戶協議

控制措施

組織宜確保有關 PII 處理的契約，闡明組織於客戶應承擔義務，提供相關協助時之角色（，並將處理的特性，及組織可取得的資訊納入考量）。

Implementation guidance

The contract between the organization and the customer should include the following aspects, where relevant and depending on the customer's role (i.e. PII controller or PII processor):

實作指引

組織與客戶間之契約，於相關情況下，並視客戶角色（如：PII 控制者或 PII 處理者）而定，宜包括下列面向：

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

- privacy by design and privacy by default (see B.1.4 and B.2.4);
- achieving security of processing;
- notification of breaches involving PII to a supervisory authority;
- notification of breaches involving PII to customers and PII principals;
- conducting privacy impact assessments; and
- the assurance of assistance by the PII processor if prior consultations with relevant PII protection authorities are needed.

Some jurisdictions require that the contract include the subject matter and duration of the processing, the nature and purpose of the processing, the type of PII and categories of PII principals.

B.2.2.3 Organization's purposes

Control

The organization should ensure that PII processed on behalf of a customer are only processed for the purposes expressed in the documented instructions of the customer.

Implementation guidance

The contract between the organization and the customer should include, but not be limited to, the objective and time frame to be achieved by the service.

In order to achieve the customer's purpose, there can be technical reasons why it is appropriate for the organization to determine the method for processing PII, consistent with the general instructions of the customer but without the customer's express instruction. For example, in order to efficiently utilize network or processing capacity it can be necessary to allocate specific processing resources depending on certain characteristics of the PII principal.

The organization should allow the customer to verify their compliance with the purpose specification and limitation principles. This also

- 於設計即保護隱私及預設保護隱私 (參照 B.1.4、B.2.4) ;
- 達成處理之安全性 ;
- 將涉及 PII 之洩漏事件告知主管機關 ;
- 向客戶及 PII 當事人告知涉及 PII 之洩漏事件 ;
- 進行隱私衝擊評鑑 (PIA) ; 及
- 若需事先與相關 PII 保護機關諮詢，則由 PII 處理者提供協助之保證。

部分司法管轄區域要求契約內包括處理主題與期間、性質與目的；PII 型態與 PII 當事人類別。

B.2.2.3 組織的目的

控制措施

組織宜確保代表客戶處理的 PII，僅會依據客戶書面指令所表示的目的，進行處理。

實作指引

組織與客戶間之契約宜包括 (但不限於) 服務將達成的目標及時程。

為達成客戶之目的，可能基於技術理由，由組織決定 PII 之處理方法；此決定無需客戶明確指示，但應符合客戶的一般性指示。例如：為有效利用網路或處理容量，可能須依據 PII 當事人之特定特性配置特定處理資源。

組織宜允許客戶查驗其是否遵循目的規格與限制原則。此亦確保組織或其分包者不會基於客戶書面指示之外之其他目的而處理 PII。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

ensures that no PII is processed by the organization or any of its subcontractors for other purposes than those expressed in the documented instructions of the customer.

B.2.2.4 Marketing and advertising use

Control

The organization should not use PII processed under a contract for the purposes of marketing and advertising without establishing that prior consent was obtained from the appropriate PII principal. The organization should not make providing such consent a condition for receiving the service.

Implementation guidance

Compliance of PII processors with the customer's contractual requirements should be documented, especially where marketing or advertising is planned.

Organizations should not insist on the inclusion of marketing or advertising uses where express consent has not been fairly obtained from PII principals.

NOTE This control is in addition to the more general control in B.2.2.3 and does not replace or otherwise supersede it.

B.2.2.5 Infringing instruction

Control

The organization should inform the customer if, in its opinion, a processing instruction infringes applicable legal requirements.

Implementation guidance

The organization's ability to verify if the instruction infringes legal requirements can depend on the technological context, on the instruction itself, and on the contract between the organization and the customer.

B.2.2.6 Customer obligations

Control

The organization should provide the customer with

B.2.2.4 行銷及廣告使用

控制措施

組織不宜將依契約所處理的 PII，使用於行銷與廣告目的，除非確認已自相關 PII 當事人取得事前同意。組織不應將提供此一同意，列為接受服務的條件。

實作指引

PII 處理者遵循客戶之契約要求事項宜登載之，尤其在規劃行銷或廣告時。

當未公允地取得 PII 當事人之明確同意時，組織不宜堅持將 PII 納入行銷或廣告用途。

備考：此控制措施係補充 B.2.2.3 中較通用之控制措施，並非替換或優先之。

B.2.2.5 侵權指令

控制措施

組織認為處理的指令違反了適用的法律要求事項時，宜通知客戶。

實作指引

組織對指示是否違反法令之查證能力，可能取決於技術環境、指示本身，以及組織與客戶間之契約。

B.2.2.6 客戶應承擔的義務

控制措施

組織宜向客戶提供適切之資訊，使客戶能夠證明對其

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

the appropriate information such that the customer can demonstrate compliance with their obligations.

Implementation guidance

The information needed by the customer can include whether the organization allows for and contributes to audits conducted by the customer or another auditor mandated or otherwise agreed by the customer.

B.2.2.7 Records related to processing PII

Control

The organization should determine and maintain the necessary records in support of demonstrating compliance with its obligations (as specified in the applicable contract) for the processing of PII carried out on behalf of a customer.

Implementation guidance

Some jurisdictions can require the organization to record information such as:

- categories of processing carried out on behalf of each customer;
- transfers to third countries or international organizations; and
- a general description of the technical and organizational security measures.

B.2.3 Obligations to PII principals

B.2.3.1 Objective

To ensure that PII principals are provided with the appropriate information about the processing of their PII, and to meet any other applicable obligations to PII principals related to the processing of their PII.

B.2.3.2 Comply with obligations to PII principals

Control

The organization should provide the customer with the means to comply with its obligations related to PII principals.

Implementation guidance

A PII controller's obligations can be defined by legislation, by regulation or by contract. These

應承擔義務的遵循。

實作指引

客戶所需之資訊可包括組織是否允許並配合由客戶執行之稽核，或由客戶指派或另行議定之稽核員所進行的稽核。

B.2.2.7 與處理 PII 有關之紀錄

控制措施

組織宜判定並維護必要之紀錄，以支援證明對其代表客戶執行 PII 處理時，已遵循（如適用契約中所指明的）組織應盡義務。

實作指引

某些司法管轄區域可能要求組織記錄資訊，諸如：

- 代表各客戶執行之處理種類；
- 傳輸至他國或國際組織；及
- 技術性及組織性之安全措施的一般說明。

B.2.3 對 PII 當事人之義務

B.2.3.1 控制目標

確保向 PII 當事人提供有關處理其 PII 之適當資訊，並履行與 PII 處理有關、其他任何適用的對 PII 當事人義務。

B.2.3.2 遵循對 PII 當事人之義務

控制措施

組織宜提供客戶方式，以遵循其與 PII 當事人相關之義務。

實作指引

PII 控制者之義務可由法令、法規或契約所界定。此等義務可能包括客戶利用組織所提供之服務來協

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

obligations can include matters where the customer uses the services of the organization for implementation of these obligations. For example, this can include the correction or deletion of PII in a timely fashion.

Where a customer depends on the organization for information or technical measures to facilitate meeting the obligations to PII principals, the relevant information or technical measures should be specified in a contract.

助履行其義務的事項。例如，這可能包括以及時方式更正或刪除 PII。

若客戶依組織所提供資訊或技術措施，以協助符合對 PII 當事人之義務，則宜於契約中規定相關的資訊或技術措施。

B.2.4 Privacy by design and privacy by default

B.2.4.1 Objective

To ensure that processes and systems are designed such that the collection and processing of PII (including use, disclosure, retention, transmission and disposal) are limited to what is necessary for the identified purpose.

B.2.4 隱私設計及隱私預設

B.2.4.1 控制目標

確保設計過程及系統時，將 PII 之蒐集及處理（包括利用、揭露、保存、傳輸及處置）限制於所敘明目的之必要範圍內。

B.2.4.2 Temporary files

Control

The organization should ensure that temporary files created as a result of the processing of PII are disposed of (e.g. erased or destroyed) following documented procedures within a specified, documented period.

B.2.4.2 暫存檔

控制措施

組織宜確保因處理 PII 而產生的暫存檔，於指定文件化期限內，依據文件化程序處置（如：抹除或銷毀）。

Implementation guidance

The organization should conduct periodic verification that unused temporary files are deleted within the identified time period.

實作指引

組織宜進行定期查證，以確保在所敘明時段內刪除未使用之暫時檔案。

Other information

Information systems can create temporary files in the normal course of their operation. Such files are specific to the system or application but can include file system roll-back journals and temporary files associated with the updating of databases and the operation of other application software. Temporary files are not needed after the related information processing task has been completed but there are circumstances in which they cannot be deleted. The length of time for which these files remain in use is not always

其他資訊

資訊系統可能於其正常運作過程中建立暫時檔案。此種檔案係特定於系統或應用程式，但可包括檔案系統還原日誌，以及與資料庫更新及其他應用軟體運作相關聯之暫時檔案。相關資訊處理工作完成後，不需暫時檔案，但於某些情況下無法刪除。此等檔案保持使用之時間長短並非恆為確定，然「垃圾回收」程序宜識別相關檔案，並判定自前次使用後已歷經多長時間。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

deterministic but a “garbage collection” procedure should identify the relevant files and determine how long it has been since they were last used.

B.2.4.3 Return, transfer or disposal of PII

Control

The organization should be able to return, transfer or dispose of PII in a secure manner. It should also make its policy available to the customer.

Implementation guidance

At some point in time, it can be necessary to dispose of PII in some manner. This can involve returning the PII to the customer, transferring it to another organization or to a PII controller (e.g. as a result of a merger), deleting or otherwise destroying it, de-identifying it or archiving it. The capability for the return, transfer or disposal of PII should be managed in a secure manner.

The organization should provide the assurance necessary to allow the customer to ensure that PII processed under a contract is erased (by the organization and any of its subcontractors) from wherever they are stored, including for the purposes of backup and business continuity, as soon as they are no longer necessary for the identified purposes of the customer.

The organization should develop and implement a policy in respect to the disposal of PII and should make this policy available to customers when requested.

The policy should cover the retention period for PII before its disposal after termination of a contract, to protect the customer from losing PII through an accidental lapse of the contract.

NOTE This control and guidance is also relevant under the retention principle (see B.1.4.8).

B.2.4.4 PII transmission controls

Control

The organization should subject PII transmitted over

B.2.4.3 PII 之歸還、傳輸或處置

控制措施

組織宜能夠以安全方式歸還、傳輸或處置 PII。亦宜使客戶可取得其政策。

實作指引

於某個時間點，可能需要以某種方式處置 PII。此處置方式可能包括：將 PII 歸還給客戶、將其移轉至另一組織或 PII 控制者（如：因併購所致）、刪除或以其他方式銷毀、去識別化，或予以歸檔。對 PII 進行歸還、移轉或其他處置之能力，應以安全方式加以管理。

組織應提供必要之保證，使客戶能確保依契約處理之 PII（包括因備份與營運持續目的所產生之資料），於不再為客戶所敘明之目的所需時，能自組織及其所有分包者的所有儲存位置予以刪除。

組織應制定並實作與 PII 處置相關之政策，並於客戶提出請求時提供該政策。

該政策應涵蓋契約終止後、PII 進行處置前的保存期間，以保護客戶避免因契約意外失效而遺失 PII。

備考：此控制措施與指引亦適用於保存原則（參照 B.1.4.8）。

B.2.4.4 PII 傳輸控制措施

控制措施

組織宜對透過資料傳輸網路傳輸的 PII 採取適當的

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

a data-transmission network to appropriate controls, which are designed to ensure that the data reaches its intended destination.

Implementation guidance

Transmission of PII needs to be controlled, typically by ensuring that only authorized individuals have access to transmission systems, and by following the appropriate processes (including the retention of audit data) to ensure that PII is transmitted without compromise to the correct recipients. Requirements for transmission controls can be included in the contract between the PII processor and the customer.

Where no contractual requirements related to transmission are in place, it can be appropriate to take advice from the customer prior to transmission.

B.2.5 PII sharing, transfer and disclosure

B.2.5.1 Objective

To determine whether and document when PII is shared, transferred to other jurisdictions or third parties or disclosed in accordance with applicable obligations.

B.2.5.2 Basis for PII transfer between jurisdictions Control

The organization should inform the customer in a timely manner of the basis for PII transfers between jurisdictions and of any intended changes in this regard, so that the customer can object to such changes or to terminate the contract.

Implementation guidance

PII transfer between jurisdictions can be subject to legal requirements depending on the jurisdiction or organization to which PII is to be transferred (and from where it originates). The organization should document compliance with such requirements as the basis for transfer.

The organization should inform the customer of any transfer of PII, including transfers to:

控制措施，其設計可確保資料抵達其預期之目的地。

實作指引

PII 之傳輸需受控制，通常透過確保僅有經授權之人員可存取傳輸系統，以及遵循適當之過程（包括保存稽核資料），以確保 PII 無遭受洩露或損害地正確傳送予預定接收者。傳輸控制措施之要求可納入 PII 處理者與客戶間之契約

若無與傳輸相關之契約要求事項，則傳輸前宜徵詢客戶的建議。

B.2.5 PII 分享、傳輸及揭露

B.2.5.1 控制目標

判定並文件化 PII 是否、以及何時，被分享、被轉移至其他司法管轄區域、或第三方，或依適用的義務被揭露。

B.2.5.2 司法管轄區域間 PII 轉移基礎控制措施

組織宜及時通知客戶有關司法管轄區域間 PII 轉移基礎之依據，及應告知客戶任何相關的預期變更，以便客戶可以對此提出異議或終止契約。

實作指引

司法管轄區域間之 PII 傳輸可能受法律要求之拘束，其要求視 PII 所欲傳輸至之司法管轄區域或組織（以及其來源地）而定。組織宜紀錄其遵循此等要求之情形，作為進行傳輸之依據

組織宜告知客戶關於 PII 之所有傳輸，包括傳輸至：

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

- suppliers;
- other parties;
- other countries or international organizations.

- 供應者；
- 其他方；
- 其他國家或國際組織。

In case of changes, the organization should inform the customer in advance, according to an agreed time frame, so that the customer has the ability to object to such changes or to terminate the contract.

若有變更，則組織宜依議定之時限前告知客戶，以使客戶能反對此種變更或終止契約。

The agreement between the organization and the customer can have clauses where the organization can implement changes without informing the customer. In these cases, the limits of this allowance should be set (e.g. the organization can change suppliers without informing the customer but cannot transfer PII to other countries).

組織與客戶間之協議可能有某些條款，使組織可於未告知客戶的情況下，實作變更。於此等情況下，宜設定此容許之限制（如：組織可於未告知客戶之情況下，變更供應者，然不能將 PII 傳輸至其他國家）。

In case of international transfer of PII, agreements such as model contract clauses, binding corporate rules or cross border privacy rules, the countries involved and the circumstances in which such agreements apply, should be identified.

就跨國傳輸 PII 而言，宜敘明諸如定型化契約條款、共同約束規則或跨境隱私規則等之協議、涉及的國家及適用此種協議之情況。

B.2.5.3 Countries and international organizations to which PII can be transferred

Control

The organization should specify and document the countries and international organizations to which PII can possibly be transferred.

Implementation guidance

The identities of the countries and international organizations to which PII can possibly be transferred in normal operations should be made available to customers. The identities of the countries arising from the use of subcontracted PII processing should be included. The countries included should be considered in relation to B.2.5.2.

Outside of normal operations, there can be cases of transfer made at the request of a legal authority,

B.2.5.3 PII 傳輸至其他國家及國際組織

控制措施

組織宜指明並文件化，PII 可能被轉移到的國家和國際組織。

實作指引

宜向客戶提供於正常營運中可能將 PII 傳輸至之國家與國際組織的名稱，並包括因使用分包者處理 PII 所涉及之國家。所列國家宜依 B.2.5.2 進行考量。

於正常運作之外，若因法律機關要求而須進行傳輸，則相關國家之名稱可能無法事先明示；或適用

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

for which the identity of the countries cannot be specified in advance, or such transfer can be prohibited by applicable jurisdictions to preserve the confidentiality of a law enforcement investigation (see B.1.5.2, B.2.5.5 and B.2.5.6).

之司法管轄區域可能禁止揭露此資訊，以維護執法調查的機密性 (參照 B.1.5.2、B.2.5.5 及 B.2.5.6)。

B.2.5.4 Records of PII disclosures to third parties

Control

The organization should record disclosures of PII to third parties, including what PII has been disclosed, to whom and when.

Implementation guidance

PII can be disclosed during normal operations. These disclosures should be recorded. Any additional disclosures to third parties, such as those arising from legal investigations or external audits, should also be recorded. The records should include the source of the disclosure and the source of the authority to make the disclosure.

B.2.5.4 向第三方揭露 PII 之紀錄

控制措施

組織宜記錄對第三方的 PII 揭露，包括已揭露的 PII，對象與時間。

實作指引

PII 可能於正常運作過程中被揭露。宜記錄此等揭露。亦宜記錄向第三方之所有額外揭露，諸如合法調查或外部稽核所引發的揭露。紀錄宜包括揭露之來源，以及作成該揭露所依據之授權來源。

B.2.5.5 Notification of PII disclosure requests

Control

The organization should notify the customer of any legally binding requests for the disclosure of PII.

Implementation guidance

The organization can receive legally binding requests for the disclosure of PII (e.g. from legal authorities). In these cases, the organization should notify the customer of any such request within agreed time frames and according to an agreed procedure which can be included in the customer contract.

In some cases, the legally binding requests include the requirement for the organization not to notify anyone about the event. An example of a possible prohibition on disclosure would be a prohibition under criminal law to preserve the confidentiality of a legal investigation.

B.2.5.5 PII 揭露請求之通知

控制措施

組織宜通知客戶所有具法律約束力之 PII 揭露請求。

實作指引

組織可能接收到具法律約束力之 PII 揭露請求 (如：來自司法機關)。組織宜於議定之時限內，並依議定之程序 (可能納入客戶契約中)，將所有此等請求告知客戶。

在某些情況下，具法律約束力的請求中會包含要求組織不得向任何人通報該事件。例如：刑法下為了維護法律調查的機密性，可能會禁止資訊的揭露。

B.2.5.6 Legally binding PII disclosures

Control

The organization should reject any requests for PII

B.2.5.6 具法律約束力之 PII 揭露

控制措施

組織宜拒絕任何未具法律約束力的 PII 揭露請求。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

disclosures that are not legally binding, consult the corresponding customer before making any PII disclosures and accept any contractually agreed requests for PII disclosures that are authorized by the corresponding customer.

Implementation guidance

Details relevant to the implementation of the control can be included in the customer contract. Such requests can originate from several sources, including courts, tribunals and administrative authorities. They can arise from any jurisdiction.

B.2.5.7 Disclosure of subcontractors used to process PII

Control

Before use, the organization should disclose whether any subcontractors are used to process PII to the customer.

Implementation guidance

Provisions for the use of subcontractors to process PII should be included in the customer contract.

Information disclosed should cover the fact that subcontracting is used and the names of relevant subcontractors. The information disclosed should also include the countries and international organizations to which subcontractors can transfer data (see B.2.5.3) and the means by which subcontractors are obliged to meet or exceed the obligations of the organization (see B.2.5.8).

Where public disclosure of subcontractor information is assessed to increase security risk beyond acceptable limits, disclosure should be made under a non-disclosure agreement or on the request of the customer. The customer should be made aware that the information is available.

This does not concern the list of countries where the PII can be transferred. This list should be disclosed to the customer in all cases in a way that allows them to inform the appropriate PII

於進行任何 PII 揭露前宜諮詢對應客戶，並接受經契約約定且由該客戶授權的 PII 揭露請求。

實作指引

與控制措施實作相關之詳細資訊，可納入客戶契約中。

此等請求可能來自多個來源，包括法院、仲裁機構，以及行政主管機關。其可能來自任何司法管轄區域。

B.2.5.7 揭露用於處理 PII 之分包商

控制措施

組織宜在使用分包商處理 PII 前向客戶進行揭露。

實作指引

客戶契約中，宜納入使用分包者處理 PII 之條款。

所揭露之資訊宜涵蓋使用分包的事實及相關分包者之名稱。揭露之資訊亦宜包括分包者可能將資料傳輸之國家及國際組織 (參照 B.2.5.3)，以及分包者有義務符合或超過組織義務之方法 (參照 B.2.5.8)。

若評估公開揭露分包者之資訊，將使安全風險增加至超過可接受的限制之外，則宜於保密協議下或依客戶請求進行揭露。宜使客戶知悉該資訊可供取得。

此不涉及 PII 可能被傳輸至之國家 / 地區的表列。於所有情況下，皆宜以允許客戶告知適切 PII 當事人之方式向客戶揭露此表列。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

principals.

B.2.5.8 Engagement of a subcontractor to process PII

Control

The organization should only engage a subcontractor to process PII according to the customer contract.

Implementation guidance

Where the organization subcontracts some or all of the processing of that PII to another organization, a written authorization from the customer is required prior to the PII processed by the subcontractor. This can be in the form of appropriate clauses in the customer contract or can be a specific "one-off" agreement.

The organization should have a written contract with any subcontractors that it uses for PII processing on its behalf. The organization should ensure that its contracts with subcontractors address the implementation of the appropriate controls in Table A.2.

The contract between the organization and any subcontractor processing PII on its behalf should require the subcontractor to implement the appropriate controls specified in Table A.2, taking account of the information security risk assessment process (see 6.1.2) and the scope of the processing of PII performed by the PII processor. By default, all controls specified in Table A.2 should be assumed as relevant. If the organization decides to not require the subcontractor to implement a control from Table A.2, it should justify its exclusion.

A contract can define the responsibilities of each party differently but, to be consistent with this document, all controls should be considered and included in the documented information.

B.2.5.8 聘用 PII 處理分包商

控制措施

組織宜僅依客戶契約聘用分包商處理 PII。

實作指引

若組織將某些或全部之 PII 處理分包予另一組織，則於該分包商開始處理 PII 之前，須先取得客戶的書面授權。此可採用客戶契約中適切條款之形式，或可為特定「一次性」協議。

組織宜與代表其進行 PII 處理的分包商簽訂書面契約，並宜確保其與分包商之契約中說明表 A.2 中適當控制措施之實作要求。

組織與代表其處理 PII 的任何分包商之間的契約，應要求分包商依表 A.2 所規定之適當控制措施加以實作，並同時考量資訊安全風險評估過程（見 6.1.2）以及由 PII 處理者所執行之 PII 處理範圍。預設情況下，表 A.2 中規定的所有控制措施均應視為相關控制措施。若組織決定不要求分包商實作表 A.2 中的某項控制措施，則應提出其排除理由。

契約可定義各方之不同責任，但為與本文件保持一致，宜考量所有控制措施並將其納入文件化資訊中。

B.2.5.9 Change of subcontractor to process PII

Control

B.2.5.9 變更 PII 處理分包商

控制措施

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

The organization should, in the case of having general written authorization, inform the customer of any intended changes concerning the addition or replacement of subcontractors to process PII, thereby giving the customer the opportunity to object to such changes.

Implementation guidance

Where the organization changes the organization with which it subcontracts some or all of the processing of PII, then written authorization from the customer is required for the change, prior to the PII processed by the new subcontractor. This can be in the form of appropriate clauses in the customer contract or a specific “one-off” agreement.

B.3 Implementation guidance for PII controllers and PII processors

B.3.1 Objective

To ensure the security of PII processing.

B.3.2 General

This clause provides PIMS guidance for PII controllers and PII processors, which relates to the controls listed in Table A.3. Unless otherwise stated by the specific provisions in Table A.3, or determined by the organization, the same guidance applies for PII controllers and PII processors.

B.3.3 Policies for information security Control

Information security policies related to PII processing should be defined, approved by management, published, communicated to and acknowledged by relevant personnel and relevant interested parties, and reviewed at planned intervals and if significant changes occur.

Implementation guidance

Either by the development of separate privacy policies, or by the augmentation of information security policies, the organization should produce a statement concerning support for and commitment to achieving compliance with legal

在通則性書面授權的情況下，組織宜通知客戶有關增加或變更 PII 處理分包商的任何預期變更，讓客戶有機會拒絕此類變更。

實作指引

若組織變更與其分包該 PII 之某些或全部處理的組織，則於新分包者處理 PII 之前，需取得客戶的書面授權方能進行變更。此可採用客戶契約中適當條款之形式，或可為特定「一次性」協議。

B.3 PII 控制者與 PII 處理者的實作指引

B.3.1 控制目標

確保 PII 處理之安全。

B.3.2 一般要求

本節為 PII 控制者與 PII 處理者提供 PIMS 指引，該指引與表 A.3 中所列的控制措施相關。若表 A.3 中的具體條款另有說明，或由組織自行判定，否則相同的指引適用於 PII 控制者與 PII 處理者。

B.3.3 資訊安全政策 控制措施

與 PII 處理相關的資訊安全政策宜予以定義、由管理階層核可、發布、傳達予相關人員及相關關注方，且其係知悉，並依規劃期間及發生重大變更時審查。

實作指引

無論藉由制定單獨隱私政策，或藉由增強資訊安全政策，組織宜就關於支援及承諾達成對適用之 PII 保護法令，以及對組織與其合作夥伴、分包者及適用之第三方（客戶、供應者等）間議定的契約條款（宜明確配置其間之責任）等之遵循性，提出聲明。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

requirements applicable to PII protection and with the contractual terms agreed between the organization and its partners, its subcontractors and its applicable third parties (customers, suppliers etc.), which should clearly allocate responsibilities between them.

Any organization that processes PII, whether a PII controller or a PII processor, should consider legal requirements applicable to PII protection during the development and maintenance of information security policies.

任何處理 PII 的組織，無論其身分為 PII 控管者或 PII 處理者，皆應在資訊安全政策的制定與維護過程中，考量適用於 PII 保護的法律要求。

B.3.4 Information security roles and responsibilities

Control

Information security roles and responsibilities related to PII processing should be defined and allocated according to the organization needs.

Implementation guidance

The organization should designate a point of contact for use by the customer regarding the processing of PII. When the organization is a PII controller, a point of contact should be designated for PII principals regarding the processing of their PII (see B.1.3.4)..

The organization should appoint one or more persons responsible for developing, implementing, maintaining and monitoring an organization-wide governance and privacy programme, to ensure compliance with all applicable legal requirements regarding the processing of PII.

The responsible person should, where appropriate:

- be independent and report directly to the appropriate management level of the organization in order to ensure effective management of privacy risks;
- be involved in the management of all issues which relate to the processing of PII;
- be an expert in data protection legislation, regulation and practice;
- act as a contact point for supervisory

B.3.4 資訊安全之角色及責任

控制措施

宜依組織需要，定義並配置，與 PII 處理相關的資訊安全之角色及責任。

實作指引

組織就有關 PII 之處理宜指定供客戶使用的聯絡窗口。當組織為 PII 控制者時，指定聯絡窗口供 PII 當事人用於有關其 PII 之處理(參照 B.1.3.4)。

組織宜任命 1 或多個人員，負責制定、實作、維護及監視整個組織範圍之治理及隱私計畫，以確保遵循有關 PII 處理之所有適用法令。

適切時，負責人員宜：

- 獨立並直接向組織之適切管理層級報告，以確保有效管理隱私風險；
- 參與與 PII 處理有關之所有議題的管理；
- 精通資料保護法令及實務作法；
- 扮演監督機關之聯絡窗口；

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

- authorities;
- inform top-level management and employees of the organization of their obligations with respect to the processing of PII;
- provide advice in respect of privacy impact assessments conducted by the organization.

- 告知組織高層管理階層及員工有關處理其 PII 之義務；
- 提供有關組織進行隱私衝擊評鑑之建議。

NOTE Some jurisdictions refer to this person as a data protection officer. Jurisdictions define when such a position is required, along with their position and role. This position can be fulfilled by a staff member or outsourced.

備考：在某些區域，此類人員稱為資料保護官，並定義了何時需要這樣的職位，以及他們的職位和角色。該職位可以由工作人員履行或委外。

B.3.5 Classification of information

Control

Information should be classified according to the information security needs of the organization, taking into consideration PII, based on confidentiality, integrity, availability and relevant interested party requirements.

Implementation guidance

The organization's information classification scheme should explicitly consider PII as part of the scheme it implements. Considering PII within the overall classification scheme is integral to understanding what PII the organization processes (e.g. type, special categories), where such PII is stored and the systems through which it can flow.

B.3.5 資訊之分類分級

控制措施

資訊宜依組織之資訊安全需要，並納入 PII 考量，依機密性、完整性、可用性及相關關注方要求事項分類分級。

實作指引

組織之資訊分級系統宜明確將 PII 視為其實作方案的一部分。於整體分級系統中考量 PII，係瞭解組織處理之 PII 為何（如：型式、特殊種類）、此種 PII 儲存處，以及其可能流經之系統等所不可或缺。

B.3.6 Labelling of information

Control

An appropriate set of procedures for information labelling that considers PII should be developed and implemented in accordance with the information classification scheme adopted by the organization.

Implementation guidance

The organization should ensure that people under its control are made aware of the definition of PII and how to recognize information that is PII.

B.3.6 資訊之標示

控制措施

宜依組織所採用，並納入 PII 考量之資訊分級方案，發展及實作一套適切的資訊標示程序。

實作指引

組織宜確保其管理下之人員認知 PII 的定義，以及如何辨識資訊是否為 PII。

B.3.7 Information transfer

Control

B.3.7 資訊傳送

控制措施

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Information transfer rules, procedures, or agreements related to processing PII should be in place for all types of transfer facilities within the organization and between the organization and other parties.

Implementation guidance

The organization should consider procedures for ensuring that rules related to the processing of PII are enforced throughout and outside of the system, where applicable.

B.3.8 Identity management

Control

The full life cycle of identities related to PII processing should be managed.

Implementation guidance

Procedures for registration and de-registration of users who administer or operate systems and services that process PII should address the situation where user access control for those users is compromised, such as the corruption or compromise of passwords or other user registration data (e.g. as a result of inadvertent disclosure).

The organization should not reissue to users any de-activated or expired user IDs for systems and services that process PII.

In the case where the organization is providing PII processing as a service, the customer can be responsible for some or all aspects of user ID management. Such cases should be included in the documented information.

Some jurisdictions impose specific requirements regarding the frequency of checks for unused authentication credentials related to systems that process PII. Organizations operating in these jurisdictions should take compliance with these requirements into account.

宜備妥關於 PII 處理的資訊傳送規則、程序或協議，用於組織內及組織與其他各方間之所有型式的傳送設施。

實作指引

於適用時，組織宜考量相關程序，以確保與 PII 處理相關之規則能在系統內部及系統外均獲有效執行。

B.3.8 身分管理

控制措施

宜管理與 PII 處理相關身分之整個生命週期。

實作指引

管理或操作處理 PII 之系統及服務的使用者之註冊及註銷程序，宜因應使用者的使用者存取控制遭破壞之情況，諸如通行碼或其他使用者註冊資料的破壞或破解（如：因非蓄意揭露造成）。

針對處理 PII 之系統及服務，組織不宜向使用者補發任何停用或過期的使用者 ID。

於組織將 PII 處理作為服務提供之情況下，客戶可負責某些或所有層面的使用者 ID 管理。此種情況宜納入文件化資訊中。

某些司法管轄區域對與處理 PII 之系統有關的未使用鑑別信符之核對頻率，施加特定要求事項。於此等司法管轄區域運作之組織宜考量對此等要求事項的遵循性。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

B.3.9 Access rights

Control

Access rights to PII and other associated assets related to PII processing should be provisioned, reviewed, modified and removed in accordance with the organization's topic-specific policy on and rules for access control.

Implementation guidance

The organization should maintain an accurate, up-to-date record of the user profiles created for users who have authorized access to the information system and the PII contained therein. Each profile comprises the set of data about the user, including user ID, necessary to implement the identified technical controls providing authorized access.

Implementing individual user access IDs enables appropriately configured systems to identify who accessed PII and what additions deletions or changes they made. As well as protecting the organization users are also protected as they can identify what they have processed and what they have not processed.

In the case where the organization is providing PII processing as a service, the customer can be responsible for some or all aspects of access management. Where appropriate, the organization should provide the customer with the means to perform access management, such as by providing administrative rights to manage or terminate access. Such cases should be included in the documented information.

B.3.10 Addressing information security within supplier agreements

Control

Relevant information security requirements related to PII processing should be established and agreed with each supplier based on the type of supplier relationship.

Implementation guidance

B.3.9 存取權限

控制措施

宜依組織之存取控制的主題特定政策及規則，提供、審查、修改及刪除對 PII 及其他與 PII 處理相關聯資產之存取權限。

實作指引

組織宜針對經授權存取資訊系統及其中所包含 PII 之使用者所建立的使用者 剖繪，維持準確、最新之紀錄。此剖繪包含關於該使用者之資料集(包括使用者 ID)，其對實作所識別之技術控制措施以提供經授權的存取，實屬必要。

實作個別使用者存取 ID，使經適當組態設定之系統能識別誰存取 PII，以及進行哪些新增、刪除或變更。保護組織之同時，使用者亦受保護，因其可識別已處理及未處理之內容。

於組織將 PII 處理作為服務提供之情況下，客戶可負責某些或所有層面之存取管理。適當時，組織宜向客戶提供執行存取管理之方法，諸如藉由提供管理或終止存取之管理權限。此種情況宜納入文件化資訊中。

B.3.10 於供應者協議中闡明資訊安全

控制措施

宜依供應者關係之型式，建立與 PII 處理相關的資訊安全要求事項，並與各供應者議定。

實作指引

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

The organization should specify in agreements with suppliers whether PII is processed and the minimum technical and organizational measures that the supplier is required to meet for the organization to meet its information security and PII protection obligations (see B.1.2.7 and B.2.2.2).

Supplier agreements should clearly allocate responsibilities between the organization, its partners, its suppliers and its relevant third parties (customers, suppliers, etc.) taking into account the type of PII processed.

The agreements between the organization and its suppliers should provide a mechanism for ensuring the organization supports and manages compliance with all applicable legal requirements. The agreements should call for independently audited compliance, acceptable to the customer.

NOTE For such audit purposes, compliance with relevant and applicable security standards such as ISO/IEC 27001 can be considered.

Where the role of the organization is a PII processor, the organization should specify in contracts with any suppliers that PII is only processed on its instructions.

組織為符合其資訊安全及 PII 保護義務，宜於與供應者之協議中，規定是否處理 PII，以及供應者需滿足之最低技術性及組織性措施（參照 B.1.2.7 及 B.2.2.2）。

供應者協議宜考量所處理 PII 之型式，明確配置組織、其合作夥伴、其供應者與其適用的第三方（客戶、供應者等）間之責任。

組織與其供應者間之協議宜提供機制，以確保組織支援及管理對所有適用的法令之遵循性。協議宜要求客戶可接受之獨立稽核遵循性。

備考：針對此種稽核目的，可考量遵循相關及適用之安全及隱私標準，諸如 ISO/IEC 27001 或本文件。

組織宜於與所有供應者之契約中規定僅依其指示處理 PII。

B.3.11 Information security incident management planning and preparation

Control

The organization should plan and prepare for managing information security incidents related to PII processing by defining, establishing and communicating incident management processes, roles and responsibilities.

Implementation guidance

As part of the overall information security incident management process, the organization should establish responsibilities and procedures for identifying and recording breaches of PII. Additionally, the organization should establish

B.3.11 資訊安全事故管理規劃及準備

控制措施

組織宜藉由定義、建立並溝通或傳達事故管理過程、角色及責任，規劃並準備管理與 PII 處理相關資訊安全事故。

實作指引

作為整個資訊安全事故管理過程之一部分，組織宜建立識別及記錄 PII 危害的責任及程序。此外，組織宜考量適用法令，建立將 PII 危害通知所要求各方（包括此種通知之時機），並向權責機關揭露相關責任及程序。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

responsibilities and procedures related to notifying relevant parties of PII breaches (including the timing of such notifications) and the disclosure to authorities, taking into account the applicable legal requirements.

Some jurisdictions impose specific regulations regarding breach responses, including notification.

Organizations operating in these jurisdictions should ensure that they are aware of, and document how they comply with, these regulations.

某些司法管轄區域將就危害回應（包括通知）制定特定法規。

於此等司法管轄區域運作之組織，宜確保其能展現對此等法規之遵循性。

B.3.12 Response to information security incidents

Control

Responses to information security incidents related to PII processing should be according to the documented procedures.

Implementation guidance for PII controllers

An incident that involves PII should trigger a review by the organization, as part of its information security incident management process, to determine if a breach involving PII that requires a response has taken place.

An event does not necessarily trigger such a review.

NOTE 1 An information security event does not necessarily result in actual, or the significant probability of, unauthorized access to PII or to any of the organization's equipment or facilities storing PII. These can include, but are not limited to, pings and other broadcast attacks on firewalls or edge servers, port scans, unsuccessful log-on attempts, denial of service attacks and packet sniffing.

When a breach of PII has occurred, response procedures should include relevant notifications and records.

Some jurisdictions define cases when the breach should be notified to the relevant supervisory authority and when it should be notified to PII

B.3.12 對資訊安全事故之回應

控制措施

宜依書面記錄程序，回應與 PII 處理相關的資訊安全事故。

實作指引

涉及 PII 之事故宜觸發組織的審查（作為其資訊安全事故管理過程之一部分），以判定是否發生要求回應之涉及 PII 的洩漏。

事件未必觸發此種審查。

備考 1：資訊安全事件未必造成實際（或具顯著機率）之未獲授權存取 PII，或接取進出儲存有 PII 之任何組織設備或設施。其可能包括（但不限於）對防火牆或邊緣伺服器之 ping 及其他廣播攻擊、埠掃描、未成功登錄嘗試、阻絕服務攻擊及封包監測。

發生 PII 洩漏時，回應程序宜包括相關之通知及紀錄。

某些司法管轄區域定義何時宜將 PII 洩漏通知主管機關，以及何時宜將 PII 洩漏通知 PII 當事人等之情況。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

principals.

Notifications should be clear.

通知宜清晰，且可為必要。

NOTE 2 A notification can contain details such as:

- a contact point where more information can be obtained;
- a description of and the likely consequences of the breach;
- a description of the breach including the number of individuals concerned as well as the number of records concerned;
- measures taken or planned to be taken.

備考 2：通知可能包含之細節，諸如：

- 可取得進一步資訊之聯絡窗口。
- PII 洩漏之說明及可能後果。
- PII 洩漏之說明，包括所涉人數及紀錄數。
- 已採取或規劃採取之措施。

NOTE 3 Information on the management of security incidents can be found in the ISO/IEC 27035 series.

備考 3：關於安全事故管理之資訊參照 ISO/IEC 27035 系列標準。

Where a breach involving PII has occurred, a record should be maintained with sufficient information to provide a report for regulatory or forensic purposes, such as:

- a description of the incident;
- the time period;
- the consequences of the incident;
- the name of the reporter;
- to whom the incident was reported;
- the steps taken to resolve the incident (including the person in charge and the data recovered);
- the fact that the incident resulted in unavailability, loss, disclosure or alteration of PII.

若發生涉及 PII 洩漏，則宜維持具足夠資訊之紀錄，以提供用於監理或鑑識目的之報告，諸如：

- 事故說明；
- 事故期間；
- 事故後果；
- 事故報告者名稱；
- 事故報告對象；
- 解決事故所採取之步驟(包括負責人及所復原之資料)；
- 事故導致 PII 不可用、遺失、揭露或變更之事實。

In the event that a breach involving PII has occurred, the record should also include a description of the PII compromised, if known. If notifications were used, the steps taken to notify PII principals, regulatory agencies or customers should also be recorded.

若發生涉及 PII 洩漏，則紀錄中亦宜包括對遭洩漏 PII 之說明(若已知)；若已通知，則紀錄宜包括通知 PII 當事人、監理機關或客戶所採取之步驟。

Implementation guidance for PII processors

Provisions covering the notification of a breach involving PII should form part of the contract between the organization and the customer. The contract should specify how the organization will provide the information necessary for the

PII 處理者之實作指引

組織與客戶間契約宜納入涵蓋涉及 PII 洩漏通知之條款。契約宜規定組織將如何向客戶提供必要之資訊，以履行通知相關主管機關之雙方義務。此通知義務不會延伸至由客戶或 PII 當事人，或其負責之系統組件內所造成的洩漏。對通知之回應時間，

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

customer to fulfil their obligation to notify relevant authorities. This notification obligation does not extend to a breach caused by the customer or PII principal or within system components for which they are responsible. The contract should also define expected and externally mandated limits for notification response times.

In some jurisdictions, the PII processor should notify the PII controller of the existence of a breach without undue delay (i.e. as soon as it is discovered), so that the PII controller can take the appropriate actions.

Where a breach involving PII has occurred, a record should be maintained with sufficient information to provide a report for regulatory or forensic purposes, such as:

- a description of the incident;
- the time period;
- the consequences of the incident;
- the name of the reporter;
- to whom the incident was reported;
- the steps taken to resolve the incident (including the person in charge and the data recovered);
- the fact that the incident resulted in unavailability, loss, disclosure or alteration of PII.

In the event that a breach involving PII has occurred, the record should also include a description of the PII compromised, if known; and if notifications were performed, the steps taken to notify the customer or the regulatory agencies.

In some jurisdictions, applicable legal requirements can require the organization to directly notify appropriate regulatory authorities (e.g. a PII protection authority) of a breach involving PII.

契約亦宜定義所預期及外部規定之限制。

於某些司法管轄區域中，PII 處理者宜儘速通知 PII 控制者發生 PII 洩漏，最好於發現 PII 洩漏後，立即通知 PII 控制者，以便 PII 控制者可採取適當措施。

若發生 PII 洩漏，則紀錄宜維持足以提供監理或鑑識目的報告之資訊，諸如：

- 事故說明；
- 事故期間；
- 事故後果；
- 事故報告者名稱；
- 事故報告對象；
- 解決事故所採取之步驟 (包括負責人及所恢復之資料)；
- 事故導致 PII 不可用、遺失、揭露或變更之事實。

若發生 PII 洩漏，則紀錄中亦宜包括對遭洩漏 PII 之說明 (若已知)；若已通知，則紀錄宜包括通知客戶或監理機關所採取之步驟。

於某些司法管轄區域，適用之法令可能要求組織將涉及 PII 的洩漏行為直接通知適當之監理機關 (如：PII 保護機關)。

B.3.13 Legal, statutory, regulatory and contractual requirements

Control

B.3.13 法律、法令、法規及契約要求事項

控制措施

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Legal, statutory, regulatory and contractual requirements relevant to information security related to PII processing and the organization's approach to meet these requirements should be documented and this documentation kept up to date.

Implementation guidance

The organization should identify any potential legal sanctions (which can result from some obligations being missed) related to the processing of PII, including substantial fines directly from the local supervisory authority.

In some jurisdictions, International Standards such as this document can be used to form the basis for a contract between the organization and the customer, outlining their respective security, privacy and PII protection responsibilities. The terms of the contract can provide a basis for contractual sanctions in the event of a breach of those responsibilities.

B.3.14 Protection of records

Control

Records related to PII processing should be protected from loss, destruction, falsification, unauthorized access and unauthorized release.

Implementation guidance

Review of current and historical policies and procedures can be required (e.g. in the cases of customer dispute resolution and investigation by a supervisory authority).

The organization should retain copies of its privacy policies and associated procedures for a period as specified in its retention schedule (see B.1.4.8). This includes retention of previous versions of these documents when they are updated.

B.3.15 Independent review of information security

Control

The organization's approach to managing

宜書面記錄及保持更新與 PII 處理相關的資訊安全相關法律、法令、法規及契約之要求事項，以及組織為符合此等要求事項的作法。

實作指引

組織宜識別與 PII 處理有關之所有可能法律制裁 (可能由於違反某些義務而導致)，包括直接由本地主管機關處以巨額罰款。

於某些司法管轄區域中，可使用標準 (如本文件)，以形成組織與客戶間契約之依據，條列其各自安全、隱私及 PII 保護之責任。契約條款可於違反該等責任事件時，提供契約處罰之依據。

B.3.14 紀錄之保護

控制措施

宜保護與 PII 處理相關的紀錄，免於遺失、毀損、偽造、未經授權存取及未經授權發布。

實作指引

可能要求審查目前及過往之政策及程序 (如：於客戶糾紛解決及由主管機關調查之情況)。

組織宜於其保存時間表中所規定期限內，保存其隱私政策及相關聯程序之複本 (參照 B.1.4.8)。此包括當更新此等文件時，保存其先前版本。

B.3.15 資訊安全之獨立審查

控制措施

宜依規劃之期間或當發生重大變更時，獨立審查組織

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

information security related to PII processing and its implementation including people, processes and technologies should be reviewed independently at planned intervals, or when significant changes occur.

Implementation guidance

Where an organization is acting as a PII processor, and where individual customer audits are impractical or can increase risks to security, the organization should make available to customers, prior to entering into, and for the duration of, a contract, independent evidence that information security is implemented and operated in accordance with the organization's policies and procedures. A relevant independent audit, as selected by the organization, should normally be an acceptable method for fulfilling the customer's interest in reviewing the organization's processing operations, if it covers the needs of anticipated users and if results are provided in a sufficiently transparent manner.

B.3.16 Compliance with policies, rules and standards for information security

Control

Compliance with the organization's information security policy, topic-specific policies, rules and standards related to PII processing should be regularly reviewed.

Implementation guidance

As part of technical reviews of compliance with security policies and standards, the organization should include methods of reviewing tools and components related to processing PII. This can include:

- ongoing monitoring to verify that only permitted processing is taking place; or
- specific penetration or vulnerability tests (e.g. de-identified data sets can be subject to a motivated intruder test to validate that de-identification methods are compliant with organizational requirements).

對管理與 PII 處理相關的資訊安全的作法及其實作 (包括人員、過程及技術)。

實作指引

若組織扮演 PII 處理者，且個別客戶之稽核不切實際或可能增加安全風險，則組織宜於簽訂契約之前及契約期間內，向客戶提供獨立證據，以證明資訊安全係依組織政策及程序實作與運作。若組織滿足預期使用者之需要且以足夠透明方式提供結果，則組織所選擇之相關獨立稽核，通常宜為於審查組織處理運作時，可滿足客戶利益之可接受方法。

B.3.16 對資訊安全政策、規則及標準之遵循性

控制措施

宜定期審查組織與 PII 處理相關的資訊安全政策、主題特定政策、規則及標準之遵循性。

實作指引

作為對安全政策及標準之遵循性的技術審查之一部分，組織宜納入與處理 PII 有關之該等工具及組件的審查方法。此可包括：

- 持續監視，以查證僅進行允許之處理；或
- 特定滲透或脆弱性測試(如：可對去識別化資料集進行主動入侵者測試，以驗核去識別化方法是否遵循組織要求事項)。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

B.3.17 Information security awareness, education and training

Control

Personnel of the organization and relevant interested parties should receive appropriate information security awareness, education and training and regular updates of the organization's information security policy, topic-specific policies and procedures, as relevant for their job function, as they relate to PII processing.

Implementation guidance

Measures should be put in place, including raising awareness of incident reporting, to ensure that relevant staff are aware of the possible consequences of breaching privacy or security rules and procedures, especially those addressing the handling of PII. These include consequences for the organization (e.g. legal consequences, loss of business and brand or reputational damage), to the staff member (e.g. disciplinary consequences) and to the PII principal (e.g. physical, material and emotional consequences) of breaching privacy or security rules and procedures, especially those addressing the handling of PII.

NOTE Such measures can include the use of appropriate periodic training for personnel having access to PII.

B.3.18 Confidentiality or non-disclosure agreements

Control

Confidentiality or non-disclosure agreements reflecting the organization's needs for the protection of PII should be identified, documented, regularly reviewed and signed by personnel and other relevant interested parties.

Implementation guidance

The organization should ensure that individuals operating under its control with access to PII are subject to a confidentiality obligation. The confidentiality agreement, whether part of a contract or separate, should specify the length of

B.3.17 資訊安全認知及教育訓練

控制措施

組織及相關關注方之人員，當其與 PII 處理相關時，均宜接受與其工作職能相關的組織資訊安全政策、主題特定政策及程序之適切資訊安全認知及教育訓練，並定期更新。

實作指引

宜採取措施（包括事故報告之認知），以確保相關員工認知違反隱私或安全之規則及程序（尤其是該等因應 PII 處置之規則及程序）可能對組織產生之後果（如：法律後果、營運損失及品牌或聲譽損害）、對員工產生之後果（如：懲處後果），以及對 PII 當事人產生之後果（如：身體、實體及情感後果）。

備考：此種措施可能包括對具存取 PII 權限之人員進行適切的定期訓練。

B.3.18 機密性或保密協議

控制措施

反映組織對 PII 保護之需要的機密性或保密協議，宜由人員及其他相關關注方，識別、書面記錄、定期審查及簽署。

實作指引

組織宜確保其所控制下具存取 PII 權限之個人，受機密性義務約束。機密性協議（無論其屬契約之一部分或另外訂定）宜規定遵守義務之期限。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

time the obligations should be adhered to.

When the organization is a PII processor, a confidentiality agreement, in whatever form, between the organization, its employees and its agents should ensure that employees and agents comply with the policy and procedures concerning data handling and protection.

當組織係 PII 處理者時，組織與其員工及與其受委託者間所有形式之機密性協議，宜確保員工及受委託者遵循有關資料處置及資料保護之政策與程序。

B.3.19 Clear desk and clear screen

Control

Clear desk rules for papers and removable storage media and clear screen rules for information processing facilities should be defined and appropriately enforced.

Implementation guidance

The organization should restrict the creation of hardcopy material including PII to the minimum needed to fulfil the identified processing purpose.

B.3.19 桌面淨空及螢幕淨空

控制措施

宜定義對紙本及可移除式儲存媒體之桌面淨空規則，以及對資訊處理設施的螢幕淨空規則，並適切實施之。

實作指引

組織宜將含有 PII 之紙本材料的產生，限制於符合所識別處理目的所需之最小量。

B.3.20 Storage media

Control

Storage media with PII should be managed through its life cycle of acquisition, use, transportation and disposal in accordance with the organization's classification scheme and handling requirements.

Implementation guidance

The organization should document any use of removable media or devices for the storage of PII. Wherever feasible, the organization should use removable physical media or devices that permit encryption when storing PII. Unencrypted media should only be used where unavoidable, and in instances where unencrypted media or devices are used, the organization should implement procedures and compensating controls (e.g. tamper-evident packaging) to mitigate risks to the PII.

Where removable media on which PII is stored is disposed of, secure disposal procedures should be included in the documented information and implemented to ensure that previously stored PII

B.3.20 儲存媒體

控制措施

儲存 PII 的媒體宜依組織之分類分級方案及處置要求事項，於其獲取、使用、運送及處置的整個生命週期內進行管理。

實作指引

組織宜登載供儲存 PII 之可移除式媒體或裝置的所有使用。可行時，組織宜於儲存 PII 時，使用允許加密之可移除式實體媒體或裝置。宜僅於無法避免時使用未加密之媒體，且於使用未加密的媒體或裝置之情況下，組織宜實作程序及補償控制措施（如：破壞存跡包裝），以降低 PII 之風險。

若處置儲存 PII 之可移除式媒體，則宜於文件化資訊中納入安全處置程序並實作之，以確保之前儲存的 PII 無法存取。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

will not be accessible.

If physical media is used for information transfer, a system should be put in place to record incoming and outgoing physical media containing PII, including the type of physical media, the authorized sender, the authorized recipients, the date and time, and the number of physical media. Where possible, additional measures such as encryption should be implemented to ensure that the data can only be accessed at the point of destination and not in transit.

The organization should subject physical media containing PII before leaving its premises to an authorization procedure and ensure the PII is not accessible to anyone other than authorized personnel.

NOTE One possible measure to ensure PII on physical media leaving the organization's premises is not generally accessible is to encrypt the PII concerned and restrict decryption capabilities to authorized personnel.

Removable media which is taken outside the physical confines of the organization is prone to loss, damage and inappropriate access. Encrypting removable media adds a level of protection for PII, which reduces security and privacy risks if the removable media is compromised.

B.3.21 Secure disposal or re-use of equipment **Control**

Items of equipment containing storage media with PII should be verified to ensure that any sensitive data and licensed software has been removed or securely overwritten prior to disposal or re-use.

Implementation guidance

The organization should ensure that, whenever storage space is re-assigned, any PII previously residing on that storage space is not accessible. With regard to deletion of PII held in an

若使用實體媒體進行資訊運送，則宜建立系統以記錄包含 PII 之實體媒體的進出，包括實體媒體型式、經授權發送者/接收者、日期及時間，以及實體媒體數量。可能時，宜實作額外措施諸如加密，以確保僅能於目的地而非途中存取資料。

組織宜於實體媒體攜離場所前，對包含 PII 之實體媒體進行授權程序，並確保除經授權人員外，其他任何人皆無法存取 PII。

備考：確保攜離組織場所之實體媒體上的 PII 通常無法存取之一種可能措施，係對有關的 PII 加密，並將解密能力限於經授權之人員。

攜出組織實體範圍外之可移除式媒體易於遺失、損壞及不適當存取。加密可移除式媒體增加 PII 保護層級，從而降低可移除式媒體遭危害時之安全及隱私風險。

B.3.21 設備汰除或重新使用之保全 **控制措施**

宜查證包含存有 PII 的儲存媒體之設備項目，以確保於汰除或重新使用前，所有敏感性資料及具使用授權的軟體已移除或安全覆寫。

實作指引

組織宜確保每當儲存空間被重新指派時，先前儲存在該儲存空間中的任何 PII 均無法再被存取。

於刪除資訊系統中保存之 PII 時，基於效能考量，

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

information system, performance issues can mean that explicit erasure of that PII is impractical. This creates the risk that another user can access the PII. Such risk should be avoided by specific technical measures.

For secure disposal or re-use, equipment containing storage media that can possibly contain PII should be treated as though it contains PII.

徹底抹除該 PII 可能不切實際。此可能造成其他使用者得以存取該等 PII 之風險。宜藉由特定技術措施避免此種風險。

為保全汰除或再使用具有儲存媒體之設備，若儲存媒體中可能含有 PII，則宜將其視同確實含有 PII 般處理。

B.3.22 User endpoint devices

Control

PII stored on, processed by or accessible via user endpoint devices should be protected.

Implementation guidance

The organization should ensure that the use of mobile devices does not lead to a compromise of PII.

B.3.22 使用者端點裝置

控制措施

宜保護儲存於使用者端點裝置、由使用者端點裝置處理或經由使用者端點裝置可存取之 PII。

實作指引

組織宜確保行動裝置之使用不致造成 PII 之危害。

B.3.23 Secure authentication

Control

Secure authentication technologies and procedures related to PII processing should be implemented based on information access restrictions.

Implementation guidance

Where required by the customer, the organization should provide the capability for secure log-on procedures for any user accounts under the customer's control.

B.3.23 安全鑑別

控制措施

與 PII 處理相關的安全鑑別技術及程序，宜依資訊存取限制策實作。

實作指引

客戶要求時，組織宜針對客戶控制下之所有使用者帳戶，提供保全登入程序的能力。

B.3.24 Information backup

Control

Backup copies of PII, and software and systems related to PII processing should be maintained and regularly tested.

Implementation guidance

The organization should have a policy which addresses the requirements for backup, recovery and restoration of PII (which can be part of an overall information backup policy) and any further requirements (e.g. contractual or legal requirements) for the erasure of PII contained in

B.3.24 資訊備份

控制措施

宜維護與 PII 處理相關的 PII、軟體與硬體的備份，並定期測試。

實作指引

組織宜有政策以因應 PII 備份、復原及回復之要求事項（可作為整體資訊備份政策的一部分），以及保留供備份要求事項用之資訊所包含 PII 的抹除之任何其他要求事項（如：契約或法律要求事項）。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

information held for backup requirements.

PII-specific responsibilities in this respect can depend on the customer. The organization should ensure that the customer has been informed of the limits of the service regarding backup.

Where the organization explicitly provides backup and restore services to customers, the organization should provide them with clear information about their capabilities with respect to backup and restoration of PII.

Some jurisdictions impose specific requirements regarding the frequency of backups of PII, the frequency of reviews and tests of backup, or regarding the recovery procedures for PII. Organizations operating in these jurisdictions should demonstrate compliance with these requirements.

There can be occasions where PII needs to be restored, perhaps due to a system malfunction, attack or disaster. When PII is restored (typically from backup media), processes need to be in place to ensure that the PII is restored into a state where the integrity of PII can be assured, or where PII inaccuracy or incompleteness is identified and processes put in place to resolve them (which can involve the PII principal).

The organization should have a procedure for, and a log of, PII restoration efforts. At a minimum, the log of the PII restoration efforts should contain:

- the name of the person responsible for the restoration;
- a description of the restored PII.

Some jurisdictions prescribe the content of the logs of PII restoration efforts. Organizations should be able to document compliance with any such requirements for restoration log content. The conclusions of such deliberations should be included in the documented information.

此方面之 PII 特定責任可能取決於客戶。組織宜確保已告知客戶有關備份之服務限制。

若組織明確向客戶提供備份及回復服務，則組織宜向客戶提供有關其於 PII 備份及回復方面能力之清晰資訊。

某些司法管轄區域對 PII 備份頻率、備份審查及測試之頻率，或 PII 復原程序，施加特定要求事項。於此等司法管轄區域運作之組織宜證明對此等要求事項之遵循性。

於某些情況下，可能由於系統故障、攻擊或災難而需回復 PII。當（通常由備份媒體）回復 PII 時，需採取適當過程以確保 PII 回復到可保證 PII 完整性之狀態，或識別出 PII 不準確性或不完整性，並採取適當過程以解決之（可能涉及 PII 當事人）。

組織宜具 PII 回復工作量之程序及日誌。PII 回復工作量之日誌宜至少包含：

- 負責回復人員之姓名；
- 所回復 PII 之說明。

某些司法管轄區域規定 PII 回復工作量日誌之內容。組織宜能登載對回復日誌內容之所有適用的司法管轄區域特定要求事項之遵循性。此種考量之結論宜納入文件化資訊中。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

The use of subcontractors to store replicated or backup copies of PII processed is covered by the controls in this document applying to subcontracted PII processing (see B.3.10, B.3.20). Where physical media transfers take place related to backups and restoration, this is also covered by controls in this document (see B.3.7).

B.3.25 Logging

Control

Logs that record activities, exceptions, faults and other relevant events related to PII processing should be produced, stored, protected and analysed.

Implementation guidance

A process should be put in place to review event logs using continuous, automated monitoring and alerting processes, or else manually where such review should be performed with a specified, documented periodicity, to identify irregularities and propose remediation efforts.

Where possible, event logs should record access to PII, including by whom, when, which PII principal's PII was accessed, and what (if any) changes were made (e.g. additions, modifications or deletions) as a result of the event.

Where multiple service providers are involved in providing services, there can be varied or shared roles in implementing this guidance. These roles should be clearly defined and included in the documented information, and agreement on any log access between providers should be addressed.

Log information recorded for, for example, security monitoring and operational diagnostics, can contain PII. Measures such as controlling access should be put in place to ensure that logged information is only used as intended.

A procedure, preferably automatic, should be put in place to ensure that logged information is either

本文件中適用於分包 PII 處理之控制措施，涵蓋使用分包者儲存所處理 PII 之複製複本或備份複本 (參照 B.3.10、B.3.20)。發生與備份及回復有關之實體媒體運送時，本文件中之控制措施亦涵蓋此內容 (B.3.7)。

B.3.25 存錄

控制措施

記錄與 PII 處理相關的活動、異常、錯誤及其他相關事件之日誌，宜產生、儲存、保護及分析之。

實作指引

宜使用連續、自動監視及警示過程，制定事件日誌之審查過程，或另以人工方式以書面所規定之週期進行此種審查，以識別違規行為並提出補救措施。

可能時，事件日誌宜記錄對 PII 之存取，包括遭誰存取、何時存取、存取哪位 PII 當事人的 PII 及事件造成之變更 (新增、修改或刪除) (若有)。

若多個服務提供者參與提供服務，則於實作此指引時，可能扮演不同或分享之角色。此等角色宜明確定義並納入文件化資訊中，且宜闡明提供者間關於所有日誌存取之協議。

例：用於安全監視及運作診斷所記錄之日誌資訊可能包含 PII，宜採取諸如控制存取之措施，以確保僅依預期使用存錄資訊。

宜備妥程序 (最好為自動化程序)，以確保依保存時間表中規定，刪除或去識別存錄資訊 (參照

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

deleted or de-identified as specified in the retention schedule (see B.1.4.8).

Implementation guidance for PII processors:

The organization should define criteria regarding if, when and how log information can be made available to or usable by the customer. These criteria should be made available to the customer.

Where the organization permits its customers to access log records controlled by the organization, the organization should implement appropriate controls to ensure that the customer:

- can only access records that relate to that customer's activities,
- cannot access any log records which relate to the activities of other customers, and
- cannot amend the logs in any way.

B.3.26 Use of cryptography

Control

Rules for the effective use of cryptography related to PII processing, including cryptographic key management, should be defined and implemented.

Implementation guidance

Some jurisdictions can require the use of cryptography to protect particular kinds of PII, such as health data, resident registration numbers, passport numbers and driver's licence numbers.

The organization should provide information to the customer regarding the circumstances in which it uses cryptography to protect the PII it processes. The organization should also provide information to the customer about any capabilities it provides that can assist the customer in applying their own cryptographic protection.

B.3.27 Secure development life cycle

Control

B.1.4.8)。

PII 處理者之實作指引

組織宜定義有關是否、何時及如何向客戶提供 (或客戶可使用) 日誌資訊之準則。此等準則宜提供予客戶。

若組織允許其客戶存取由組織控制之日誌紀錄，則組織宜實作適當的控制措施，以確保客戶僅能存取與該客戶活動有關之紀錄，而無法存取與其他客戶活動有關的任何日誌紀錄，且無法以任何方式修改日誌。

- 只能存取與該客戶活動相關的紀錄，
- 無法存取與其他客戶活動相關的任何日誌紀錄，
- 且無法以任何方式修改這些日誌。

B.3.26 密碼技術之使用

控制措施

宜定義並實作與 PII 處理相關的有效使用密碼技術之規則 (包括密碼金鑰管理)。

實作指引

某些司法管轄區域可能要求使用加密技術，以保護特定 PII，諸如健康資料、身分證統一編號、護照號碼。

組織宜向客戶提供有關使用密碼學保護其處理之 PII 的情況之資訊。組織亦宜向客戶提供關於其提供可幫助客戶應用客戶自身密碼式保護之所有能力的資訊。

B.3.27 安全開發生命週期

控制措施

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Rules for the secure development of software and systems related to PII processing should be established and applied.

Implementation guidance

Policies for system development and design should include guidance for the organization's processing of PII needs, based on obligations to PII principals or any applicable legal requirements and the types of processing performed by the organization.

Policies that contribute to privacy by design and privacy by default should consider the following aspects:

- a) guidance on PII protection and the implementation of the privacy principles (see ISO/IEC 29100) in the software development life cycle;
- b) privacy and PII protection requirements in the design phase, which can be based on the output from a privacy risk assessment or a privacy impact assessment (see B.1.2.6);
- c) PII protection checkpoints within project milestones;
- d) required privacy and PII protection knowledge;
- e) by default minimize processing of PII.

B.3.28 Application security requirements

Control

Information security requirements related to PII processing should be identified, specified and approved when developing or acquiring applications.

Implementation guidance

The organization should ensure that PII that is transmitted over untrusted data transmission networks is encrypted for transmission.

Untrusted networks can include the public internet and other facilities outside of the operational control of the organization.

宜建立並施行與 PII 處理相關的安全開發軟體及系統的規則。

實作指引

依對 PII 當事人之義務或所有適用的法令，以及組織所履行之處理型式，系統開發及設計之政策宜納入組織之 PII 處理需要的指引。附錄 A 及附錄 B 提供 PII 處理之控制措施考量事項，其可能有助於制定系統設計中之隱私政策。

有助於「於設計即保護隱私」及「預設保護隱私」之政策，宜考量下列層面：

- a) PII 保護指引及軟體開發生命週期中實作隱私原則(參照 ISO/IEC 29100)之指引；
- b) 設計階段中之隱私及 PII 保護的要求事項，可依隱私風險評鑑或隱私衝擊評鑑的輸出(參照 B.1.2.6)；
- c) 專案里程碑內之 PII 保護查核點；
- d) 所要求之隱私及 PII 保護的知識；
- e) 預設為最小化 PII 處理。

B.3.28 應用系統安全要求事項

控制措施

開發或獲取應用系統時，宜識別、規定並核可與 PII 處理相關之資訊安全要求事項。

實作指引

組織宜確保經不受信賴之資料傳輸網路傳送的 PII 採加密傳輸。

不受信賴之網路可能包括公共網際網路及非由組織運作控制的其他設施。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

NOTE In some cases (e.g. the exchange of email) the inherent characteristics of untrusted data transmission network systems can require that some header or traffic data be exposed for effective transmission.

備考：於某些情況下（如：電子郵件交換），依不受信賴之資料傳輸網路系統的自身特性，可能要求暴露某標頭或訊務資料，以達有效傳輸。

B.3.29 Secure system architecture and engineering principles

Control

Principles for engineering secure systems related to processing PII should be established, documented, maintained and applied to any information system development activities.

Implementation guidance

Systems or components related to the processing of PII should be designed following the principles of privacy by design and privacy by default, and to anticipate and facilitate the implementation of relevant controls (as described in B.1 and B.2 for PII controllers and PII processors respectively), in particular such that the collection and processing of PII in those systems is limited to what is necessary for the identified purposes of the processing of PII (see B.1.2.2).

For example, an organization that processes PII should ensure that it disposes of PII after a specified period. The system that processes that PII should be designed in a way to facilitate this deletion requirement.

NOTE Legal requirements can apply.

B.3.30 Outsourced development

Control

The organization should direct, monitor and review the activities related to outsourced PII processing system development.

Implementation guidance

The same principles (see B.3.29) of privacy by design and privacy by default should be applied, if applicable, to outsourced information systems.

B.3.31 Test information

B.3.29 安全系統架構及工程原則

控制措施

宜建立、書面記錄及維護與 PII 處理相關之工程化安全系統原則，並套用於所有資訊系統開發活動。

實作指引

與 PII 處理相關之系統或組件，宜依於設計即保護隱私及預設保護隱私之原則進行設計，以預期並促進相關控制措施的實作（如 B1 及 B2，分別針對 PII 控制者及 PII 處理者所述），特別是使該等系統中之 PII 蒐集及處理，得僅限於所識別 PII 處理目的所必要者（參照 B.1.2.2）。

例如：處理 PII 之組織宜確保依相關司法管轄區域規定期限後最終處置 PII。處理該 PII 之系統宜以促進此刪除要求的方式進行設計。

備考：請提供您需要翻譯的英文內容，我會協助您翻譯成繁體中文。

B.3.30 委外開發

控制措施

組織宜指引、監視及審查，與 PII 處理相關的委外系統開發相關之活動。

實作指引

適用時，於設計即保護隱私及預設保護隱私之相同原則（參照 B.3.29），宜適用於所委外的資訊系統。

B.3.31 測試資訊

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Control

Test information related to PII processing should be appropriately selected, protected and managed.

Implementation guidance

PII should not be used for testing purposes; false or synthetic PII should be used. Where the use of PII for testing purposes cannot be avoided, technical and organizational measures equivalent to those used in the production environment should be implemented to minimize the risks. Where such equivalent measures are not feasible, a risk assessment should be undertaken and used to identify the selection of appropriate mitigating controls.

控制措施

宜適切選擇、保護及管理與 PII 處理相關的測試資訊。

實作指引

PII 不宜用於測試目的；宜使用虛假或合成之 PII。若無法避免將 PII 使用於測試目的，則宜實作等同生產環境中使用之技術及組織措施，以最小化風險。若此種等同措施不可行，則宜進行風險評鑑，並用以告知合適降低控制措施之選擇。

訓練專用 禁止翻印

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Annex C (informative)

Mapping to ISO/IEC 29100

Table C.1 and C.2 give an indicative mapping between the provisions of this document and the privacy principles from ISO/IEC 29100. Tables C.1 and C.2 show in a purely indicative manner how conformity to the requirements and controls of this document relates to the general privacy principles specified in ISO/IEC 29100. The cross-references in Tables C.1 and C.2 correspond to where the controls are cited in Tables A.1 to A.3.

附錄 C (參考)

與 ISO/IEC 29100 之對應

表 C.1 與 C.2 提供本文件條文與 ISO/IEC 29100 隱私原則之間的指示性對應。表 C.1 與 表 C.2 以純指示性方式顯示，遵循本文件要求與控制措施如何與 ISO/IEC 29100 所規定的一般隱私原則相關聯。表 C.1 與 C.2 中的交叉引用對應於控制措施在 表 A.1 至 A.3 中被引用的位置。

Table C.1 — Mapping of controls for PII controllers and ISO/IEC 29100

表 C.1 — PII 控制者控制措施與 ISOIEC 29100 之對應

Privacy principles of ISO/IEC 29100	ISO/IEC 29100 之隱私原則
Related controls for PII controllers	用於 PII 控制者之相關控制措施
1. Consent and Choice (ISO/IEC 29100:2024, 6.2)	1. 同意及選擇 (ISO/IEC 29100:2024, 6.2)
A.1.2.2 Identify and document purpose	A.1.2.2 識別與文件化特定目的
A.1.2.3 Identify lawful basis	A.1.2.3 識別合法基礎
A.1.2.4 Determine when and how consent is to be obtained	A.1.2.4 判定取得同意之方式與時機
A.1.2.5 Obtain and record consent	A.1.2.5 取得並記錄同意
A.1.2.6 Privacy impact assessment	A.1.2.6 隱私衝擊評鑑
A.1.3.5 Providing mechanism to modify or withdraw consent	A.1.3.5 提供修訂或撤回同意之機制
A.1.3.6 Providing mechanism to object to PII processing	A.1.3.6 提供拒絕 PII 處理之機制
A.1.3.8 PII controllers' obligations to inform third parties	A.1.3.8 PII 控制者通知第三方之義務
2. Purpose legitimacy and specification	2. 目的適法性及規定
A.1.2.2 Identify and document purpose	A.1.2.2 識別與文件化特定目的
A.1.2.3 Identify lawful basis	A.1.2.3 識別合法基礎
A.1.2.6 Privacy impact assessment	A.1.2.6 隱私衝擊評鑑
A.1.3.3 Determining information for PII principals	A.1.3.3 判定提供予 PII 當事人之資訊
A.1.3.4 Providing information to PII principals	A.1.3.4 提供資訊予 PII 當事人
A.1.3.11 Automated decision making	A.1.3.11 自動化決策
3. Collection limitation	3. 蒐集限制
A.1.2.6 Privacy impact assessment	A.1.2.6 隱私衝擊評鑑
A.1.4.2 Limit collection	A.1.4.2 限制蒐集
4. Data minimization	4. 資料最小化
A.1.4.3 Limit processing	A.1.4.3 限制處理
A.1.4.5 PII minimization objectives	A.1.4.5 PII 最小化目標

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

A.1.4.6	PII de-identification and deletion at the end of processing	A.1.4.6	處理終止時之 PII 去識別化及刪除
5.	Use, retention and disclosure limitation	5.	利用、持有及揭露限制
A.1.4.5	PII minimization objectives	A.1.4.5	PII 最小化目標
A.1.4.6	PII de-identification and deletion at the end of processing	A.1.4.6	處理終止時之 PII 去識別化及刪除
A.1.4.7	Temporary files	A.1.4.7	暫存檔
A.1.4.8	Retention	A.1.4.8	保存
A.1.4.9	Disposal	A.1.4.9	處置
A.1.5.2	Identify basis for PII transfer between jurisdictions	A.1.5.2	識別司法管轄區域間 PII 移轉基礎
A.1.5.5	Records of PII disclosure to third parties	A.1.5.5	向第三方揭露 PII 之紀錄
6.	Accuracy and quality	6.	準確性及品質
A.1.4.4	Accuracy and quality	A.1.4.4	正確性與品質
7.	Openness, transparency and notice	7.	公開、透明及告知
A.1.3.3	Determining information for PII principals	A.1.3.3	判定提供予 PII 當事人之資訊
A.1.3.4	Providing information to PII principals	A.1.3.4	提供資訊予 PII 當事人
8.	Individual participation and access	8.	個人參與及存取
A.1.3.2	Determining and fulfilling obligations to PII principals	A.1.3.2	判定並符合對 PII 當事人之義務
A.1.3.4	Providing information to PII principals	A.1.3.4	提供資訊予 PII 當事人
A.1.3.7	Access, correction or erasure	A.1.3.7	存取、更正或抹除
A.1.3.9	Providing copy of PII processed	A.1.3.9	提供所處理 PII 之複本
A.1.3.10	Handling requests	A.1.3.10	處置請求
9.	Accountability	9.	可歸責性
A.1.2.7	Contracts with PII processors	A.1.2.7	與 PII 處理者之契約
A.1.2.8	Joint PII controller	A.1.2.8	PII 共同控制者
A.1.2.9	Records related to processing PII	A.1.2.9	與處理 PII 有關之紀錄
A.1.3.10	Handling requests	A.1.3.10	處置請求
A.1.5.2	Identify basis for PII transfer between jurisdictions	A.1.5.2	識別司法管轄區域間 PII 移轉基礎
A.1.5.3	Countries and international organizations to which PII can be transferred	A.1.5.3	PII 可能被轉移到的國家和國際組織
A.1.5.4	Records of transfer of PII	A.1.5.4	PII 傳輸紀錄
10.	Information Security	10.	資訊安全
A.1.2.7	Contracts with PII processors	A.1.2.7	與 PII 處理者之契約
A.1.4.10	PII transmission controls	A.1.4.10	PII 傳輸控制措施
11.	Privacy compliance	11.	隱私遵循
A.1.2.6	Privacy impact assessment	A.1.2.6	隱私衝擊評鑑

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Table C.2 — Mapping of controls for PII processors and ISO/IEC 29100	表 C.2 — PII 處理者控制措施與 ISO/IEC 29100 之對應
Privacy principles of ISO/IEC 29100	ISO/IEC 29100 之隱私原則
Related controls for PII processors	用於 PII 處理者之相關控制措施
1. Consent and choice	1. 同意及選擇
A.2.2.6 Customer obligations	A.2.2.6 客戶應承擔的義務
2. Purpose legitimacy and specification	2. 目的適法性及規定
A.2.2.2 Customer agreement	A.2.2.2 客戶協議
A.2.2.3 Organization's purposes	A.2.2.3 組織的目的
A.2.2.4 Marketing and advertising use	A.2.2.4 行銷及廣告使用
A.2.2.5 Infringing instruction	A.2.2.5 侵權指令
A.2.3.2 Comply with obligations to PII principals	A.2.3.2 遵循對 PII 當事人之義務
3. Collection limitation	3. 蒐集限制
N/A	不適用
4. Data minimization	4. 資料最小化
A.2.4.2 Temporary files	A.2.4.2 暫存檔
5. Use, retention and disclosure limitation	5. 利用、持有及揭露限制
A.2.5.4 Records of PII disclosure to third parties	A.2.5.4 向第三方揭露 PII 之紀錄
A.2.5.5 Notification of PII disclosure requests	A.2.5.5 PII 揭露請求之告知
A.2.5.6 Legally binding PII disclosures	A.2.5.6 具法律約束力之 PII 揭露
6. Accuracy and quality	6. 準確性及品質
N/A	不適用
7. Openness, transparency and notice	7. 公開、透明及告知
A.2.5.7 Disclosure of subcontractors used to process PII	A.2.5.7 揭露用於處理 PII 之分包商
A.2.5.8 Engagement of a subcontractor to process PII	A.2.5.8 聘用 PII 處理分包商
A.2.5.9 Change of subcontractor to process PII	A.2.5.9 變更 PII 處理分包商
8. Individual participation and access	8. 個人參與及存取
A.2.3.2 Comply with obligations to PII principals	A.2.3.2 遵循對 PII 當事人之義務
9. Accountability	9. 可歸責性
A.2.2.7 Records related to processing PII	A.2.2.7 與處理 PII 有關之紀錄
A.2.4.3 Return, transfer or disposal of PII	A.2.4.3 PII 之歸還、傳輸或處置
A.2.5.2 Basis for PII transfer between jurisdictions	A.2.5.2 司法管轄區域間 PII 移轉基
A.2.5.3 Countries and international organizations to which PII can be transferred	A.2.5.3 PII 傳輸至其他國家及國際組織
10. Information security	10. 資訊安全
A.2.4.4 PII transmission controls	A.2.4.4 PII 傳輸控制措施
11. Privacy compliance	11. 隱私遵循
A.2.2.6 Customer obligations	A.2.2.6 客戶應承擔的義務

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Annex D (informative)
Mapping to the General Data Protection Regulation

Table D.1 gives an indicative mapping between the provisions of this document and Articles 5 to 49 except 43 of the General Data Protection Regulation of the European Union. Table D.1 shows how compliance to requirements and controls of this document can be relevant to fulfil obligations of GDPR.

NOTE This table is purely indicative. It is the organization's responsibility to assess its legal obligations and decide how to comply with them.

Table D.1 — Mapping of ISO/IEC 27701 structure to GDPR articles

表 D.1 本文件結構與 GDPR 條款之對應

Subclause of this document 本文件節次	GDPR article GDPR 條款
4.1	(24)(3), (25)(3), (28)(5), (28)(6), (28)(10), (32)(3), (40)(1), (40)(2)(a), (40)(2)(b), (40)(2)(c), (40)(2)(d), (40)(2)(e), (40)(2)(f), (40)(2)(g), (40)(2)(h), (40)(2)(i), (40)(2)(j), (40)(2)(k), (40)(3), (40)(4), (40)(5), (40)(6), (40)(7), (40)(8), (40)(9), (40)(10), (40)(11), (41)(1), (41)(2)(a), (41)(2)(b), (41)(2)(c), (41)(2)(d), (41)(3), (41)(4), (41)(5), (41)(6), (42)(1), (42)(2), (42)(3), (42)(4), (42)(5), (42)(6), (42)(7), (42)(8)
4.2	(31), (35)(9), (36)(1), (36)(2), (36)(3)(a), (36)(3)(b), (36)(3)(c), (36)(3)(d), (36)(3)(e), (36)(3)(f), (36)(5)
4.3	(32)(2)
4.4	(32)(2)
6.1.2	(32)(1)(b), (32)(2)
6.1.3	(32)(1)(b), (32)(2)
5.2	(24)(2)
5.3	(27)(1), (27)(2)(a), (27)(2)(b), (27)(3), (27)(4), (27)(5), (37)(1)(a), (37)(1)(b), (37)(1)(c), (37)(2), (37)(3), (37)(4), (37)(5), (37)(6), (37)(7), (38)(1), (38)(2), (38)(3), (38)(4), (38)(5), (38)(6), (39)(1)(a), (39)(1)(b), (39)(1)(c), (39)(1)(d), (39)(1)(e), (39)(2)
B.3.5	(5)(1)(f), (32)(2)
B.3.6	(5)(1)(f)
B.3.7	(5)(1)(f)
B.1.3.7	(5)(1)(f)
B.3.9	(5)(1)(f)
B.3.10	(5)(1)(f), (28)(1), (28)(3)(a), (28)(3)(b), (28)(3)(c), (28)(3)(d), (28)(3)(e), (28)(3)(f), (28)(3)(g), (28)(3)(h), (30)(2)(d), (32)(1)(b)
B.3.11	(5)(1)(f), (33)(1), (33)(3)(a), (33)(3)(b), (33)(3)(c), (33)(3)(d), (33)(4), (33)(5), (34)(1), (34)(2), (34)(3)(a), (34)(3)(b), (34)(3)(c), (34)(4)
B.3.12	(33)(1), (33)(2), (33)(3)(a), (33)(3)(b), (33)(3)(c), (33)(3)(d), (33)(4), (33)(5), (34)(1), (34)(2)
B.3.13	(5)(1)(f), (28)(1), (28)(3)(a), (28)(3)(b), (28)(3)(c), (28)(3)(d), (28)(3)(e), (28)(3)(f), (28)(3)(g), (28)(3)(h), (30)(2)(d), (32)(1)(b)

附錄 D (參考)
與 GDPR (一般資料保護規則)之對應

本附錄提供本文件節次與歐盟一般資料保護規則 (GDPR) 第 5 款至第 49 款 (不含第 43 款) 間之指示性對應。其顯示對本文件之要求事項及控制措施的遵循性，如何與履行 GDPR 義務相關。

然而，此純粹為指示性且依本文件，組織有責任評鑑其法律義務並決定如何遵循此等法律義務。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

B.3.14	(5)(2), (24)(2)
B.3.15	(32)(1)(d), (32)(2)
B.3.16	(32)(1)(d), (32)(2)
B.3.17	(39)(1)(b)
B.3.18	(5)(1)(f), (28)(3)(b), (38)(5)
B.3.19	(5)(1)(f)
B.3.20	(5)(1)(f), (32)(1)(a)
B.3.21	(5)(1)(f)
B.3.22	(5)(1)(f)
B.3.23	(5)(1)(f)
B.3.24	(5)(1)(f), (32)(1)(c)
B.3.25	(5)(1)(f)
B.3.26	(32)(1)(a)
B.3.27	(25)(1)
B.3.28	(5)(1)(f), (32)(1)(a)
B.3.29	(25)(1)
B.3.31	(5)(1)(f)
B.1.2.2	(5)(1)(b), (32)(4)
B.1.2.3	(10), (5)(1)(a), (6)(1)(a), (6)(1)(b), (6)(1)(c), (6)(1)(d), (6)(1)(e), (6)(1)(f), (6)(2), (6)(3), (6)(4)(a), (6)(4)(b), (6)(4)(c), (6)(4)(d), (6)(4)(e), (8)(3), (9)(1), (9)(2)(b), (9)(2)(c), (9)(2)(d), (9)(2)(e), (9)(2)(f), (9)(2)(g), (h), (9)(2)(i), (9)(2)(j), (9)(3), (9)(4), (17)(3)(a), (17)(3)(b), (17)(3)(c), (17)(3)(d), (17)(3)(e), (18)(2), (22)(2)(a), (22)(2)(b), (22)(2)(c), (22)(4)
B.1.2.4	(8)(1), (8)(2)
B.1.2.5	(7)(1), (7)(2), (9)(2)(a)
B.1.2.6	(35)(1), (35)(2), (35)(3)(a), (35)(3)(b), (35)(3)(c), (35)(4), (35)(5), (35)(7)(a), (35)(7)(b), (35)(7)(c), (35)(7)(d), (35)(8), (35)(9), (35)(10), (35)(11), (36)(1), (36)(3)(a), (36)(3)(b), (36)(3)(c), (36)(3)(d), (36)(3)(e), (36)(3)(f), (36)(5)
B.1.2.7	(5)(2), (28)(3)(e), (28)(9)
B.1.2.8	(26)(1), (26)(2), (26)(3)
B.1.2.9	(5)(2), (24)(1), (30)(1)(a), (30)(1)(b), (30)(1)(c), (30)(1)(d), (30)(1)(f), (30)(1)(g), (30)(3), (30)(4), (30)(5)
B.1.3.2	(12)(2)
B.1.3.3	(11)(2), (13)(3), (13)(1)(a), (13)(1)(b), (13)(1)(c), (13)(1)(d), (13)(1)(e), (13)(1)(f), (13)(2)(c), (13)(2)(d), (13)(2)(e), (13)(4), (14)(1)(a), (14)(1)(b), (14)(1)(c), (14)(1)(d), (14)(1)(e), (14)(1)(f), (14)(2)(b), (14)(2)(e), (14)(2)(f), (14)(3)(a), (14)(3)(b), (14)(3)(c), (14)(4), (14)(5)(a), (14)(5)(b), (14)(5)(c), (14)(5)(d), (15)(1)(a), (15)(1)(b), (15)(1)(c), (15)(1)(d), (15)(1)(e), (15)(1)(f), (15)(1)(g), (15)(1)(h), (15)(2), (18)(3), (21)(4)
B.1.3.4	(11)(2), (12)(1), (12)(7), (13)(3), (21)(4)
B.1.3.5	(7)(3), (13)(2)(c), (14)(2)(d), (18)(1)(a), (18)(1)(b), (18)(1)(c), (18)(1)(d)
B.1.3.6	(13)(2)(b), (14)(2)(c), (21)(1), (21)(2), (21)(3), (21)(5), (21)(6)
B.1.3.7	(5)(1)(d), (13)(2)(b), (14)(2)(c), (16), (17)(1)(a), (17)(1)(b), (17)(1)(c), (17)(1)(d), (17)(1)(e), (17)(1)(f), (17)(2)
B.1.3.8	(19)

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

B.1.3.9	(15)(3), (15)(4), (20)(1), (20)(2), (20)(3), (20)(4)
B.1.3.10	(15)(1)(a), (15)(1)(b), (15)(1)(c), (15)(1)(d), (15)(1)(e), (15)(1)(f), (15)(1)(g), (15)(1)(h), (12)(3), (12)(4), (12)(5), (12)(6)
B.1.3.11	(13)(2)(f), (14)(2)(g), (22)(1), (22)(3)
B.1.4.2	(5)(1)(b), (5)(1)(c)
B.1.4.3	(25)(2)
B.1.4.4	(5)(1)(d)
B.1.4.5	(5)(1)(c), (5)(1)(e)
B.1.4.6	(5)(1)(c), (5)(1)(e), (6)(4)(e), (11)(1), (32)(1)(a)
B.1.4.7	(5)(1)(c)
B.1.4.8	(13)(2)(a), (14)(2)(a)
B.1.4.9	(5)(1)(f)
B.1.4.10	(5)(1)(f)
B.1.5.2	(15)(2), (44), (45)(1), (45)(2)(a), (45)(2)(b), (45)(2)(c), (45)(3), (45)(4), (45)(5), (45)(6), (45)(7), (45)(8), (45)(9), (46)(1), (46)(2)(a), (46)(2)(b), (46)(2)(c), (46)(2)(d), (46)(2)(e), (46)(2)(f), (46)(3)(a), (46)(3)(b), (46)(4), (46)(5), (47)(1)(a), (47)(1)(b), (47)(1)(c), (47)(2)(a), (47)(2)(b), (47)(2)(c), (47)(2)(d), (47)(2)(e), (47)(2)(f), (47)(2)(g), (47)(2)(h), (47)(2)(i), (47)(2)(j), (47)(2)(k), (47)(2)(l), (47)(2)(m), (47)(2)(n), (47)(3), (49)(1)(a), (49)(1)(b), (49)(1)(c), (49)(1)(d), (49)(1)(e), (49)(1)(f), (49)(1)(g), (49)(2), (49)(3), (49)(4), (49)(5), (49)(6), (30)(1)(e), (48)
B.1.5.3	(15)(2), (30)(1)(e)
B.1.5.4	(30)(1)(e)
B.1.5.5	(30)(1)(d)
B.2.2.2	(28)(3)(f), (28)(3)(e), (28)(9), (35)(1)
B.2.2.3	(5)(1)(a), (5)(1)(b), (28)(3)(a), (29), (32)(4)
B.2.2.4	(7)(4)
B.2.2.5	(28)(3)(h)
B.2.2.6	(28)(3)(h)
B.2.2.7	(30)(3), (30)(4), (30)(5), (30)(2)(a), (30)(2)(b)
B.2.3.2	(15)(3), (17)(2), (28)(3)(e)
B.2.4.2	(5)(1)(c)
B.2.4.3	(28)(3)(g), (30)(1)(f)
B.2.4.4	(5)(1)(f)
B.2.5.2	(44), (46)(1), (46)(2)(a), (46)(2)(b), (46)(2)(c), (46)(2)(d), (46)(2)(e), (46)(2)(f), (46)(3)(a), (46)(3)(b), (48), (49)(1)(a), (49)(1)(b), (49)(1)(c), (49)(1)(d), (49)(1)(e), (49)(1)(f), (49)(1)(g), (49)(2), (49)(3), (49)(4), (49)(5), (49)(6)
B.2.5.3	(30)(2)(c)
B.2.5.4	(30)(1)(d)
B.2.5.5	(28)(3)(a)
B.2.5.6	(48)
B.2.5.7	(28)(2), (28)(4)
B.2.5.8	(28)(2), (28)(3)(d)
B.2.5.9	(28)(2)

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Annex E (informative)
Mapping to ISO/IEC 27018 and ISO/IEC 29151

ISO/IEC 27018 gives further information for organizations acting as PII processors and providing public cloud services. ISO/IEC 29151 gives additional controls and guidance for the processing of PII by PII controllers.

Table E.1 gives an indicative mapping between the provisions of this document and the provisions from ISO/IEC 27018 and ISO/IEC 29151. It shows how requirements and controls of this document can correspond to the provisions from ISO/IEC 27018 or ISO/IEC 29151.

The mapping shown in Table E.1 is purely indicative; a given link between these provisions does not mean they are equivalent.

附錄 E (參考)
與 ISO/IEC 27018 及 ISO/IEC 29151 之對應

ISO/IEC 27018 提供更多資訊，供扮演 PII 處理者並提供公用雲服務之組織使用。ISO/IEC 29151 提供額外控制措施及指引，供 PII 控制者處理 PII 之用。

表 E.1 提供本文件節次與 ISO/IEC 27018 及 ISO/IEC 29151 節次間之指示性對應。其顯示本文件之要求事項及控制措施如何與 ISO/IEC 27018 或 ISO/IEC 29151 之節次可能具某些對應。

此純粹為指示性，不宜假定節次間之給定連結意指等效。

Table E.1 — Mapping of ISO/IEC 27701 to ISO/IEC 27018 and ISO/IEC 29151		
表 E.1 — ISO/IEC 27701 與 ISO/IEC 27018 及 ISO/IEC 29151 之對應		
Subclause in this document 本文件節次	Subclause in ISO/IEC 27018 ISO/IEC 27018 節次	Subclause in ISO/IEC 29151 ISO/IEC 29151 節次
4	N/A	N/A
5	N/A	N/A
6	N/A	4.2
7	N/A	7.2.3
8	N/A	N/A
9	N/A	N/A
10	N/A	N/A
B.3.2	N/A	N/A
B.3.3, B.3.4, B.3.5, B.3.6, B.3.7, B.3.8, B.3.9, B.3.10, B.3.11, B.3.12, B.3.13, B.3.14, B.3.15, B.3.16	5.1, 5.2, 5.12, 5.13, 5.14, 5.16, 5.18, 5.20, 5.24, 5.26, 5.31, 5.33, 5.35, 5.36, A.10.1, A.10.2, A.11.8, A.11.9, A.11.10, A.11.11	5.1, 5.2, 5.12, 5.13, 5.14, 5.16, 5.18, 5.22, 5.24, 5.26, 5.31, 5.33, 5.35, 5.36
B.3.17, B.3.18	6.3, 6.6, A.11.1	6.3, 6.6
B.3.19, B.3.20, B.3.21	7.7, 7.10, 7.14, A.11.2, A.11.4, A.11.5, A.11.13	7.1, 7.2, 7.3, 7.4, 7.5, 7.6, 7.10, 7.14
B.3.22, B.3.23, B.3.24, B.3.25, B.3.26, B.3.27, B.3.28, B.3.29, B.3.30, B.3.31	8.1, 8.5, 8.13, 8.15, 8.24, 8.25, 8.26, 8.27, 8.30, 8.33, A.11.6	8.1, 8.13, 8.15, 8.24, 8.25, 8.26, 8.27, 8.30, 8.33
B.1.2.2	N/A	A.4

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

B.1.2.3	N/A	A.4.1
B.1.2.4	N/A	A.3.1
B.1.2.5	N/A	A.3.1
B.1.2.6	N/A	A.11.2
B.1.2.7	N/A	A.11.3
B.1.2.8	N/A	N/A
B.1.2.9	N/A	8.15
B.1.3.2	N/A	A.10
B.1.3.3	N/A	A.9.2
B.1.3.4	N/A	A.9
B.1.3.5	N/A	A.3.2
B.1.3.6	N/A	A.3.2
B.1.3.7	N/A	A.10.1, A.10.2
B.1.3.8	N/A	A.10.2
B.1.3.9	N/A	A.10.1
B.1.3.10	N/A	A.10.1
B.1.3.11	N/A	N/A
B.1.4.2	N/A	A.5
B.1.4.3	N/A	A.7.1
B.1.4.4	N/A	A.8
B.1.4.5	N/A	A.6
B.1.4.6	N/A	A.7.1
B.1.4.7	N/A	A.7.2
B.1.4.8	N/A	A.7.1
B.1.4.9	N/A	A.7.14
B.1.4.10	N/A	N/A
B.1.5.2	N/A	A.13.2
B.1.5.3	N/A	A.13.2
B.1.5.4	N/A	A.13.2
B.1.5.5	N/A	A.7.4
B.2.2.2	N/A	N/A
B.2.2.3	A.3.1	N/A
B.2.2.4	A.3.2	N/A
B.2.2.5	N/A	N/A
B.2.2.6	N/A	N/A
B.2.2.7	N/A	A.7.4
B.2.3.2	A.2.1	N/A
B.2.4.2	A.5.1	A.7.2
B.2.4.3	A.10.3	A.11.3
B.2.4.4	A.12.2	N/A
B.2.5.2	N/A	A.4.1, A.13.2
B.2.5.3	A.12.1	A.13.2
B.2.5.4	A.6.2	A.7.4

本標準中文翻譯僅供讀者參考, 各項原義應當以英文為唯一詮釋依據

B.2.5.5	A.6.1	A.7.3
B.2.5.6	A.6.1	A.7.3
B.2.5.7	A.8.1	A.7.5
B.2.5.8	A.8.1	N/A
B.2.5.9	A.8.1	N/A

訓練專用 禁止翻印

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Annex F (informative)

Correspondence with ISO/IEC 27701:2019

The purpose of this annex is to provide backwards compatibility with ISO/IEC 27701:2019 for organizations that are currently using that document and now wish to transition to this edition.

Table F.1 provides the correspondence of the controls specified in Annex A with those in ISO/IEC 27701:2019. 'N/A' in the first column identifies those controls not included in this document. 'New' in the second column identifies controls not included in ISO/IEC 27701:2019.

附錄 F (參考)

與 ISO/IEC 27701:2019 之對應

本附錄旨在為目前使用 ISO/IEC 27701:2019 並希望過渡至本版本的組織提供向後相容性。

表 F.1 顯示附錄 A 中規定的控制措施與 ISO/IEC 27701:2019 之間的對應關係。第一欄中的「N/A」表示本文件未包含的控制措施，第二欄中的「New」表示 ISO/IEC 27701:2019 中未包含的新控制措施。

Table F.1 — Correspondence between controls in this document and controls in ISO/IEC 27701:2019

表 F.1 — 本文件之控制措施與 ISO/IEC 27701:2019 之控制措施對應關係

ISO/IEC 27701 control identifier ISO/IEC 27701 控制措施識別符	ISO/IEC 27701: 2019 control identifier ISO/IEC 27701: 2019 控制措施識別符	Control name 控制措施名稱
A.3.3	6.2.1.1, 6.2.1.2	Policies for information security 資訊安全政策
A.3.4	6.3.1.1	Information security roles and responsibilities 資訊安全之角色及責任
N/A	6.3.1.2	Segregation of duties 職務區隔
N/A	6.4.2.1	Management responsibilities 管理階層責任
N/A	6.3.1.3	Contact with authorities 與權責機關之聯繫
N/A	6.3.1.4	Contact with special interest groups 及特殊關注方之聯繫
N/A	New	Threat intelligence 威脅情資
N/A	6.3.1.5, 6.11.1.1	Information security in project management 專案管理之資訊安全
N/A	6.5.1.1, 6.5.1.2	Inventory of information and other associated assets 資訊及其他相關資產之清冊
N/A	6.5.1.3, 6.5.2.3	Acceptable use of information and other associated assets 可接受使用資訊及其他相關聯資產
N/A	6.5.1.4	Return of assets 資產歸還
A.3.5	6.5.2.1	Classification of information

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

		資訊之分類分級
A.3.6	6.5.2.2	Labeling of information 資訊之標示
A.3.7	6.10.2.1, 6.10.2.2, 6.10.2.3	Information transfer 資訊傳送
N/A	6.6.1.1, 6.6.1.2	Access control 存取控制
A.3.8	6.6.2.1	Identity management 身分管理
N/A	6.6.2.4, 6.6.3.1, 6.6.4.3	Authentication information 鑑別資訊
A.3.9	6.6.2.2, 6.6.2.5, 6.6.2.6	Access rights 存取權限
A.3.10	6.12.1.1, 6.12.1.2	Addressing information security within supplier agreements 於供應者協議中闡明資訊安全
N/A	6.12.1.3	Managing information security in the ICT supply chain 管理 ICT 供應鏈中之資訊安全
N/A	6.12.2.1, 6.12.2.2	Monitoring, review and change management of supplier services 供應者服務之監視、審查及變更管理
N/A	New	Information security for use of cloud services 使用雲端服務之資訊安全
N/A	6.13.1.1	Information security incident management planning and preparation 資訊安全事故管理規劃與準備
A.3.11	6.13.1.4	Assessment and decision on information security events 資訊安全事件的評鑑與決策
A.3.12	6.13.1.5	Response to information security incidents 對資訊安全事故之回應
N/A	6.13.1.6	Learning from information security incidents 由資訊安全事故中學習
N/A	6.13.1.7	Collection of evidence 證據之蒐集
N/A	6.14.1.1, 6.14.1.2, 6.14.1.3	Information security during disruption 中斷期間之資訊安全
N/A	New	ICT readiness for business continuity 營運持續之 ICT 備妥性
A.3.13	6.15.1.1, 6.15.1.5	Legal, statutory, regulatory and contractual requirements 法律、法令、法規及契約要求事項

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

N/A	6.15.1.2	Intellectual property rights 智慧財產權
A.3.14	6.15.1.3	Protection of records 紀錄之保護
N/A	6.15.1.4	Privacy and protection of PII 隱私及 PII 保護
A.3.15	6.15.2.1	Independent review of information security 資訊安全之獨立審查
A.3.16	6.15.2.2, 6.15.2.3	Compliance with policies, rules and standards for information security 資訊安全政策、規則及標準之遵循性
N/A	6.9.1.1	Documented operating procedures 書面紀錄之運作程序
N/A	6.4.1.1	Screening 篩選
N/A	6.4.1.2	Terms and conditions of employment 聘用條款及條件
A.3.17	6.4.2.2	Information security awareness, education and training 資訊安全認知及教育訓練
N/A	6.4.2.3	Disciplinary procedures 獎懲過程
N/A	6.4.3.1	Responsibilities after termination or change of employment 聘用終止或變更後之責任
A.3.18	6.10.2.4	Confidentiality or non-disclosure agreements 機密性或保密協議
N/A	6.3.2.2	Remote working 遠端工作
N/A	6.13.1.2, 6.13.1.3	Information security event reporting 資訊安全事件通報
N/A	6.8.1.1	Physical security perimeter 實體安全周界
N/A	6.8.1.2, 6.8.1.6	Physical entry 實體進入
N/A	6.8.1.3	Securing offices, rooms and facilities 保全辦公室、房間及設施
N/A	New	Physical security monitoring 實體安全監視
N/A	6.8.1.4	Protecting against physical and environmental threats 防範實體及環境威脅
N/A	6.8.1.5	Working in secure areas 於安全區域內工作
A.3.19	6.8.2.9	Clear desk and clear screen 桌面淨空及螢幕淨空

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

N/A	6.8.2.1	Equipment siting and protection 設備安置及保護
N/A	6.8.2.6	Security of assets off-premises 場所外資產之安全
A.3.20	6.5.3.1, 6.5.3.2, 6.5.3.3, 6.8.2.5	Storage media 儲存媒體
N/A	6.8.2.2	Supporting utilities 支援之公用服務事業
N/A	6.8.2.3	Cabling security 佈纜安全
N/A	6.8.2.4	Equipment maintenance 設備維護
A.3.21	6.8.2.7	Secure disposal or re-use of equipment 設備汰除或重新使用之保全
A.3.22	6.3.2.1, 6.8.2.8	User endpoint devices 使用者端點裝置
N/A	6.6.2.3	Privileged access rights 特殊存取權限
N/A	6.6.4.1	Information access restriction 資訊存取限制
N/A	6.6.4.5	Access to source code 對原始碼之存取
A.3.23	6.6.4.2	Secure authentication 安全鑑別
N/A	6.9.1.3	Capacity management 容量管理
N/A	6.9.2.1	Protection against malware 防範惡意軟體
N/A	6.9.6.1	Management of technical vulnerabilities 技術脆弱性管理
N/A	New	Configuration management 組態管理
N/A	New	Information deletion 資訊刪除
N/A	New	Data masking 資料遮罩
N/A	New	Data leakage prevention 資料洩漏預防
A3.24	6.9.3.1	Information backup 資訊備份
N/A	6.14.2.1	Redundancy of information processing facilities
A.3.25	6.9.4.1,	Logging

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

	6.9.4.2, 6.9.4.3	資訊處理設施之多備
N/A	New	Monitoring activities 監視活動
N/A	6.9.4.4	Clock synchronization 鐘訊同步
N/A	6.6.4.4	Use of privileged utility programme(s) 具特殊權限公用程式之使用
N/A	6.9.5.1, 6.9.6.2	Installation of software on operational systems 運作中系統之軟體安裝
N/A	6.10.1.1	Network security 網路安全
N/A	6.10.1.2	Security of network services 網路服務之安全
N/A	6.10.1.3	Segregation of networks 網路之區隔
N/A	New	Web filtering 網頁過濾
A.3.26	6.7.1.1, 6.7.1.2	Use of cryptography 密碼技術之使用
A.3.27	6.11.2.1	Secure development life cycle 安全開發生命週期
A.3.28	6.11.1.2, 6.11.1.3	Application security requirements 應用系統安全要求事項
A.3.29	6.11.2.5	Secure system architecture and engineering principles 保全系統架構與工程原則
N/A	New	Secure coding 安全程式設計
N/A	6.11.2.8, 6.11.2.9	Security testing in development and acceptance 開發及驗收中之安全測試
A.3.30	6.11.2.7	Outsourced development 委外開發
N/A	6.9.1.4, 6.11.2.6	Separation of development, testing and production environments 開發、測試與運作環境之區隔
N/A	6.9.1.2, 6.11.2.2, 6.11.2.3, 6.11.2.4	Change management 變更管理
A.3.31	6.11.3.1	Test information 測試資訊
N/A	6.9.7.1	Protection of information systems during audit testing 稽核測試期間資訊系統之保護

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Table F.2 provides the correspondence of the controls specified in clause 6 in ISO/IEC 27701:2019 with those in this document. 'N/A' in the second column identifies those controls not included in this document.

F.2 顯示 ISO/IEC 27701:2019 第 6 節所規定控制措施與本文件之間的對應關係。第二欄中的「N/A」表示本文件未包含的控制措施。

Table F.2 — Correspondence between controls in ISO/IEC 27701:2019 and controls in this document

表 F.2 — ISO/IEC 27701:2019 之控制措施與本文件之控制措施對應關係

ISO/IEC 27701: 2019 control identifier ISO/IEC 27701:2019 控制措施識別符	ISO/IEC 27701 control identifier ISO/IEC 27701 控制措施識別符	Control name according to ISO/IEC 27701:2019 ISO/IEC 27701:2019 控制措施名稱
6.2.1.1	A.3.3	Policies for information security 資訊安全政策
6.2.1.2	A.3.3	Review of policies for information security 資訊安全政策之審查
6.3.1.1	A.3.4	Information security roles and responsibilities 資訊安全之角色及責任
6.3.1.2	N/A	Segregation of duties 職務區隔
6.3.1.3	N/A	Contact with authorities 與權責機關之聯繫
6.3.1.4	N/A	Contact with special interest groups 與特殊關注群組之聯繫
6.3.1.5	N/A	Information security in project management 專案管理之資訊安全
6.3.2.1	A.3.22	Mobile device policy 行動裝置政策
6.3.2.2	N/A	Teleworking 遠距工作
6.4.1.1	N/A	Screening 篩選
6.4.1.2	N/A	Terms and conditions of employment 聘用條款與條件
6.4.2.1	N/A	Management responsibilities 管理階層責任
6.4.2.2	A.3.17	Information security awareness, education and training 資訊安全認知及教育訓練
6.4.2.3	N/A	Disciplinary procedures 獎懲過程
6.4.3.1	N/A	Termination or change of employment responsibilities 聘用責任之終止或變更
6.5.1.1	N/A	Inventory of assets 資產清冊
6.5.1.2	N/A	Ownership of assets 資產擁有權

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

6.5.1.3	N/A	Acceptable use of assets 資產之可被接受的使用
6.5.1.4	N/A	Return of assets 資產之歸還
6.5.2.1	A.3.5	Classification of information 資訊之分類分級
6.5.2.2	A.3.6	Labelling of information 資訊之標示
6.5.2.3	N/A	Handling of assets 資產之處置
6.5.3.1	A.3.20	Management of removable media 可移除式媒體之管理
6.5.3.2	A.3.20	Disposal of media 媒體之汰除
6.5.3.3	A.3.20	Physical media transfer 實體媒體傳送
6.6.1.1	N/A	Access control policy 存取控制政策
6.6.1.2	N/A	Access to networks and network services 對網路及網路服務之存取
6.6.2.1	A.3.8	User registration and de-registration 使用者註冊及註銷
6.6.2.2	A.3.9	User access provisioning 使用者存取權限之配置
6.6.2.3	N/A	Management of privileged access rights 具特殊存取權限之管理
6.6.2.4	N/A	Management of secret authentication information of users 使用者之秘密鑑別資訊的管理
6.6.2.5	A.3.9	Review of user access rights 使用者存取權限之審查
6.6.2.6	A.3.9	Removal or adjustment of access rights 存取權限之移除或調整
6.6.3.1	N/A	Use of secret authentication information 秘密鑑別資訊之使用
6.6.4.1	N/A	Information access restriction 資訊存取限制
6.6.4.2	A.3.23	Secure log-on procedures 保全登入程序
6.6.4.3	N/A	Password management system 通行碼管理系統
6.6.4.4	N/A	Use of privileged utility programme(s) 具特殊權限公用程式之使用
6.6.4.5	N/A	Access control to program source code 對程式源碼之存取控制

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

6.7.1.1	A.3.26	Policy on the use of cryptographic controls 使用密碼式控制措施之政策
6.7.1.2	A.3.26	Key management 金鑰管理
6.8.1.1	N/A	Physical security perimeter 實體安全周界
6.8.1.2	N/A	Physical entry controls 實體進入控制措施
6.8.1.3	N/A	Securing offices, rooms and facilities 保全之辦公室、房間及設施
6.8.1.4	N/A	Protecting against external and environmental threats 防範外部及環境威脅
6.8.1.5	N/A	Working in secure areas 於保全區域內工作
6.8.1.6	N/A	Delivery and loading areas 交付及裝卸區
6.8.2.1	N/A	Equipment siting and protection 設備安置及保護
6.8.2.2	N/A	Supporting utilities 支援之公用服務事業
6.8.2.3	N/A	Cabling security 佈纜安全
6.8.2.4	N/A	Equipment maintenance 設備維護
6.8.2.5	N/A	Removal of assets 財產之攜出
6.8.2.6	N/A	Security of equipment and assets off-premises 場所外設備及資產的安全
6.8.2.7	A.3.21	Secure disposal or re-use of equipment 設備汰除或再使用之保全
6.8.2.8	A.3.22	Unattended user equipment 無人看管之使用者設備
6.8.2.9	A.3.19	Clear desk and clear screen policy 桌面淨空及螢幕淨空政策
6.9.1.1	N/A	Documenting operating procedures 文件化運作程序
6.9.1.2	N/A	Change management 變更管理
6.9.1.3	N/A	Capacity management 容量管理
6.9.1.4	N/A	Separation of development, testing and operational environments 開發、測試及運作環境之區隔
6.9.2.1	N/A	Controls against malware

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

		防範惡意軟體之控制措施
6.9.3.1	A.3.24	Information backup 資訊備份
6.9.4.1	A.3.25	Event logging 事件存錄
6.9.4.2	A.3.25	Protection of log information 日誌資訊之保護
6.9.4.3	A.3.25	Administrator and operator logs 管理者及操作者日誌
6.9.4.4	N/A	Clock synchronization 鐘訊同步
6.9.5.1	N/A	Installation of software on operational systems 運作中系統之軟體安裝
6.9.6.1	N/A	Management of technical vulnerabilities 技術脆弱性管理
6.9.6.2	N/A	Restriction on software installation 對軟體安裝之限制
6.9.7.1	N/A	Information systems audit controls 資訊系統稽核控制措施
6.10.1.1	N/A	Network controls 網路控制措施
6.10.1.2	N/A	Security in network services 網路服務之安全
6.10.1.3	N/A	Segregation in networks 網路之區隔
6.10.2.1	A.3.7	Information transfer policies and procedures 資訊傳送政策及程序
6.10.2.2	A.3.7	Agreements for information transfer 資訊傳送協議
6.10.2.3	A.3.7	Electronic messaging 電子傳訊
6.10.2.4	A.3.18	Confidentiality or non-disclosure agreements 機密性或保密協議
6.11.1.1	N/A	Information security requirements analysis and specification 資訊安全要求事項分析及規格
6.11.1.2	A.3.28	Securing application services on public networks 保全公共網路之應用服務
6.11.1.3	A.3.28	Protecting application services transactions 保護應用服務交易
6.11.2.1	A.3.27	Secure development policy 保全開發政策
6.11.2.2	N/A	System change control procedures 系統變更控制程序

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

6.11.2.3	N/A	Technical review of applications after operating platform changes 運作平台變更後，應用之技術審查
6.11.2.4	N/A	Restrictions of changes to software packages 軟體套件變更之限制
6.11.2.5	A.3.29	Secure systems engineering principles 保全系統工程原則
6.11.2.6	N/A	Secure development environment 保全開發環境
6.11.2.7	A.3.30	Outsourced development 委外開發
6.11.2.8	N/A	System security testing 系統安全測試
6.11.2.9	N/A	System acceptance testing 系統驗收測試
6.11.3.1	A.3.30	Protection of test data 測試資料之保護
6.12.1.1	A.3.10	Information security policy for supplier relationships 供應者關係之資訊安全政策
6.12.1.2	A.3.10	Addressing security within supplier agreements 於供應者協議中闡明安全性
6.12.1.3	N/A	Information and communication technology supply chain 資訊及通訊技術供應鏈
6.12.2.1	N/A	Monitoring and review of supplier services 供應者服務之監視及審查
6.12.2.2	N/A	Managing changes to supplier services 管理供應者服務之變更
6.13.1.1	N/A	Responsibilities and procedures 責任及程序
6.13.1.2	N/A	Reporting information security events 通報資訊安全事件
6.13.1.3	N/A	Reporting information security weaknesses 通報資訊安全弱點
6.13.1.4	A.3.11	Assessment and decisions on information security events 資訊安全事件評估及決策
6.13.1.5	A.3.12	Response to information security incidents 對資訊安全事故之回應
6.13.1.6	N/A	Learning from information security incidents 由資訊安全事故中學習
6.13.1.7	N/A	Collection of evidence 證據之收集
6.14.1.1	N/A	Planning information security continuity 規劃資訊安全持續
6.14.1.2	N/A	Implementing information security continuity

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

		實作資訊安全持續
6.14.1.3	N/A	Verify, renew and evaluate information security continuity 證、審查及評估資訊安全持續
6.14.2.1	N/A	Availability of information processing facilities 資訊處理設施之可用性
6.15.1.1	A.3.13	Identification of applicable legislation and contractual requirements 適用之法規及契約的要求事項之識別
6.15.1.2	N/A	Intellectual property rights 智慧財產權
6.15.1.3	A.3.14	Protection of records 紀錄之保護
6.15.1.4	N/A	Privacy and protection of personally identifiable information 個人可識別資訊之隱私及保護
6.15.1.5	A.3.13	Regulation of cryptographic controls 密碼式控制措施的監管
6.15.2.1	A.3.15	Independent review of information security 資訊安全之獨立審查
6.15.2.2	A.3.16	Compliance with security policies and standards 安全政策及標準之遵循性
6.15.2.3	A.3.16	Technical compliance review 技術遵循性審查